

Report N° 17

Full Malicious URL Investigation & Threat Correlation

ID of scenario:15-lec-30&31(Malicious Attachments&urls)-13-golden

Student: Mohammed Rida Lakhdari

Team: Purple Team Bootcamp (Golden)

Supervisor: Mohammed Baqer Hasan

Anmar Mohammed

Scenario receipt date: April 5, 2026

Delivery date: June 9, 2026

Contents

1	Scenario	4
2	Executive Summary	5
2.1	Threat Cluster Summary	5
3	Lab Environment & Investigation Methodology	5
3.1	Analysis Toolchain:	5
3.2	Investigation Methodology	5
4	Category A — Phishing & Social Engineering Sites	6
4.1	Targets	6
4.2	Analysis	6
4.3	Category A — Evidence Summary	6
4.3.1	Link 1 — informacoes-limpabrasil2026.netlify.app	7
4.3.2	Link 2 — walletedinar.com (Tunisia La Poste “e-Dinar” clone)	9
4.3.3	Link 106 — 051516xx.vectorprospera.digital	12
4.3.4	Link 11 — flintbrowser.pages.dev (fake “Flint Browser Pro”)	15
4.3.5	Link 13 — livre-acessofeiraao.shop (BR lure on GitHub Pages)	18
4.4	Key Takeaways — Category A	21
5	Category B — Crypto Wallet Drainers	21
5.1	Targets	21
5.2	Analysis	21
5.3	Category B — Evidence Summary	22
5.3.1	Link 5 — trzr-wallt-io.pages.dev	22
5.3.2	Link 7 — us-en-io-download.pages.dev (fake Trezor Bridge)	25
5.3.3	Link 9 — en-uphuuld-walet-us.pages.dev	28
5.3.4	Key Takeaways — Category B	31
6	Category C — IoT Botnet C2 & Malware Delivery	31
6.1	Primary Distribution / C2 Servers	31
6.2	Loader / Infected-Bot Hosts	32
6.3	Analysis	32
6.4	Category C — Evidence Summary	32
6.4.1	Link 17 — 45.156.87.253/main_mpsl	33
6.4.2	Link 24 — 185.208.159.132/mpsl	36
6.4.3	Link 58 — 222.127.71.141:56631/i (live Mirai/Mozi payload)	39
6.4.4	Link 41 — 114.239.199.122:59871/i	42
6.4.5	Link 69 — 110.39.239.111:52560/i	45
6.4.6	Key Takeaways — Category C	48
7	Techniques Identified	49
7.1	Delivery & Evasion Techniques	49
7.2	MITRE ATT&CK Mapping	49
8	Risk Assessment	50

9 Indicators of Compromise (IOC)	50
9.1 Malicious Domains (C1 + C2)	50
9.2 Malicious URLs — Phishing & Crypto (C1 + C2)	50
9.3 Botnet Loader / Infected-Bot Hosts (C3)	51
10 Recommendations	52
11 Knowledge Graph & Attack Workflow	53
12 Lessons Learned	55
13 Conclusion	56
13.1 Report Objectives Status	56

1 Scenario

An email campaign targets employees using a shortened URL that leads to a phishing page or exploit kit.

Tasks

Phase 1: Initial Analysis

1. Submit URL to ANY.RUN (use virustotal)
2. Expand shortened URL (if any)
3. Track full redirection chain

Phase 2: Deep Analysis

Monitor:

- DNS requests
- HTTP/HTTPS traffic
- Process activity
- File execution (if any)

Phase 3: Identify Techniques

Check for:

- URL obfuscation
- URL shortening
- Domain shadowing
- Use of cloud services
- HTTPS abuse

Phase 4: Risk Assessment

Answer:

- Is it phishing / malware / exploit kit?
- Is credential theft possible?
- Are users at risk?

Phase 5: Reporting

Write a professional report including:

- Findings
- Indicators of Compromise (IOCs):
 - o Domains
 - o IPs
 - o URLs
- Risk level (Low / Medium / High)
- Recommendations

2 Executive Summary

This investigation analyses a batch of 113 suspect URLs harvested from an e-mail campaign that delivered a shortened link to employees. Working as a SOC analyst / threat hunter, the goals are to:

- Expand and trace each link, then triage it with **VirusTotal** and **ANY.RUN** dynamic sandboxing.
- Cluster the indicators into coherent threat groups and attribute.
- Identify the delivery and evasion techniques in use and map them to **MITRE ATT&CK**.
- Produce an actionable risk assessment, a consolidated IOC set, and prioritised recommendations.

2.1 Threat Cluster Summary

Cluster	Description	# IOCs
A — Phishing & Social Engineering	Credential / financial lures on abused free-hosting	8
B — Crypto Wallet Drainers	Hardware-wallet (Trezor) typosquats, seed-phrase theft	6
C — IoT Botnet C2 & Malware Delivery	Mirai/Gafgyt multi-arch payloads & loaders	99
Total		113

3 Lab Environment & Investigation Methodology

3.1 Analysis Toolchain:

Tool	Role in the investigation
VirusTotal	Multi-engine reputation, passive DNS, resolutions, communicating files
VirusTotal Graph	Visual pivoting across domains, IPs, URLs and dropped files
ANY.RUN	Interactive sandbox: live DNS, HTTP, process and file-execution telemetry

3.2 Investigation Methodology

The five-phase workflow below was applied to every indicator:

Phase 1. Initial analysis submit URL to VirusTotal, expand any shortener, record the full redirection chain.

Phase 2. Deep analysis detonate in ANY.RUN; monitor DNS, HTTP/HTTPS, process activity and file execution.

Phase 3. Technique identification check for obfuscation, shortening, domain shadowing, cloud abuse and HTTPS abuse.

Phase 4. Risk assessment classify (phishing / malware / exploit kit), judge credential-theft potential and user exposure.

Phase 5. Reporting consolidate findings, IOCs, risk level and recommendations.

4 Category A — Phishing & Social Engineering Sites

4.1 Targets

#	Host (defanged)	Assessment
1	informacoes-limpabrasil2026[.]netlify[.]app	Phishing
2	walletedinar[.]com	Phishing (financial)
3	Skillwicked[.]cc	Suspicious / Phishing
4	walletedinar[.]com	Phishing (financial)
11	flintbrowser[.]pages[.]dev	Fake software / Malware lure
12	cadastrolimpaa[.]shop	Phishing
13	livre-acesso-feirao[.]shop	Phishing
106	051516xx[.]vectorprospera[.]digital	Credential phishing

4.2 Analysis

This cluster is dominated by a **Brazilian-Portuguese debt-clearance scam genre**: `informacoes-limpabrasil2026[.]netlify[.]app`, `cadastrolimpaa[.]shop` and `livre-acesso-feirao[.]shop` impersonate credit-relief / government registration portals to harvest CPF numbers, personal data and payment details. They are deployed on **free hosting and cheap .shop domains**, which provide automatic valid TLS certificates letting the pages display a padlock and appear trustworthy. `051516xx[.]vectorprospera[.]digital` uses a random numeric sub-label and a `?=check` parameter typical of templates credential-harvest kits, while `flintbrowser[.]pages[.]dev` poses as a downloadable “browser” and is better treated as a fake-software delivery lure. `Skillwicked[.]cc` is a throwaway .cc landing/redirector that requires sandbox confirmation of its final stage. Dynamic analysis also reclassified `walletedinar[.]com` into this category: rather than a crypto seed-phrase drainer, it is a **clone of Tunisia’s La Poste payment wallet** built for account/credential harvesting.

4.3 Category A — Evidence Summary

	Link 1	Link 2	Link 106
Host	informacoes-limpabrasil2026[.]netlify[.]app	walletedinar[.]com	051516xx[.]vectorprospera[.]digital
Lure	BR “limpa Brasil” credit/-gov portal	Tunisia La Poste “e-Dinar” wallet	Random-subdomain credential page
VT detections	8/95	20/92	16/95 (19/95 in Graph)
HTTP status	404	200 (live)	403
Live at analysis?	No — Netlify takedown	Yes	No — NXDOMAIN
Serving IP	63[.]176[.]8[.]218 AS16509 Amazon/Netlify	173[.]230[.]137[.]142 AS63949 Akamai-Linode, nginx	172[.]67[.]149[.]206 Cloudflare
Domain / registrar	Netlify subdomain	NameSilo, 06 Dec 2025	.digital (unknown)
TLS	Valid (auto)	Valid	Cloudflare TLS
VT first seen	2026-04-05	2026-02-23	2026-04-14
Verdict	PHISHING	PHISHING	PHISHING

	Link 11	Link 13
Host	flintbrowser[.]pages[.]dev	livre-acesso-feirao[.]shop
Lure	Fake “Flint Browser Pro” — bait aimed at security professionals	BR “feira / livre acesso” credit lure
VT detections	1/95 (1/95 in Graph)	1/95 (1/95 in Graph)
HTTP status	200	200
Live at analysis?	Yes — full site rendered	No — NXDOMAIN at detonation
Serving IP	172[.]66[.]44[.]107 Cloudflare	185[.]199[.]108[.]153 GitHub Pages
Domain / registrar	Cloudflare Pages subdomain	.shop (no longer resolving)
TLS	Valid (auto)	Valid (GitHub)
Body size	3.01 KB	6.51 KB
VT first seen	2026-04-05 (last 2026-04-12)	2026-04-05
Verdict	PHISHING	PHISHING

4.3.1 Link 1 — informacoes-limpabrazil2026.netlify.app

ANY.RUN detonation (Windows 10) shows the page now returns Netlify’s “*Site not found*” HTTP 404 shell the abusive content has already been removed by Netlify’s abuse team. The indicator pivot resolves the host to 63[.]176[.]8[.]218 with a valid auto-issued TLS certificate.

VirusTotal returns **8/95**, with BitDefender, ESET, Fortinet, G-Data, Sophos, Lionic, CyRadar and ADMINUSLabs all labelling it phishing/malicious.

The VT-Graph confirms a brief active window (first seen 2026-04-05, last seen 2026-04-09), characteristic of disposable, rapidly-rotated phishing hosting.

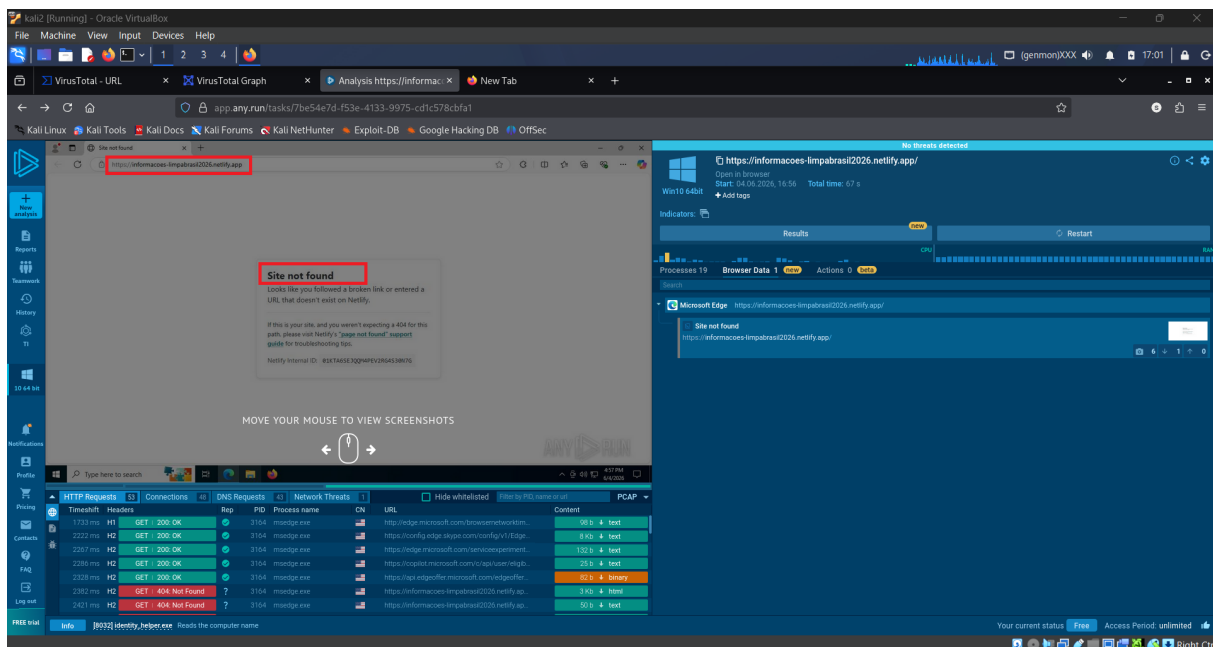


Figure 1: Link 1 — ANY.RUN

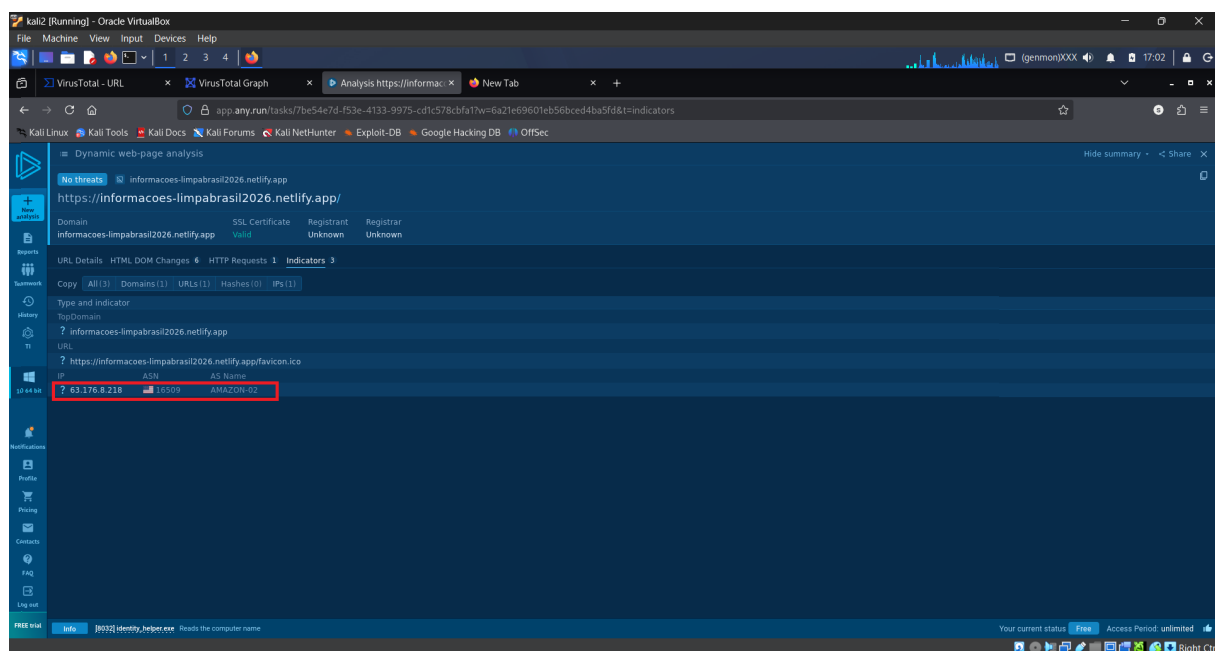


Figure 2: Link 1 — ANY.RUN indicators

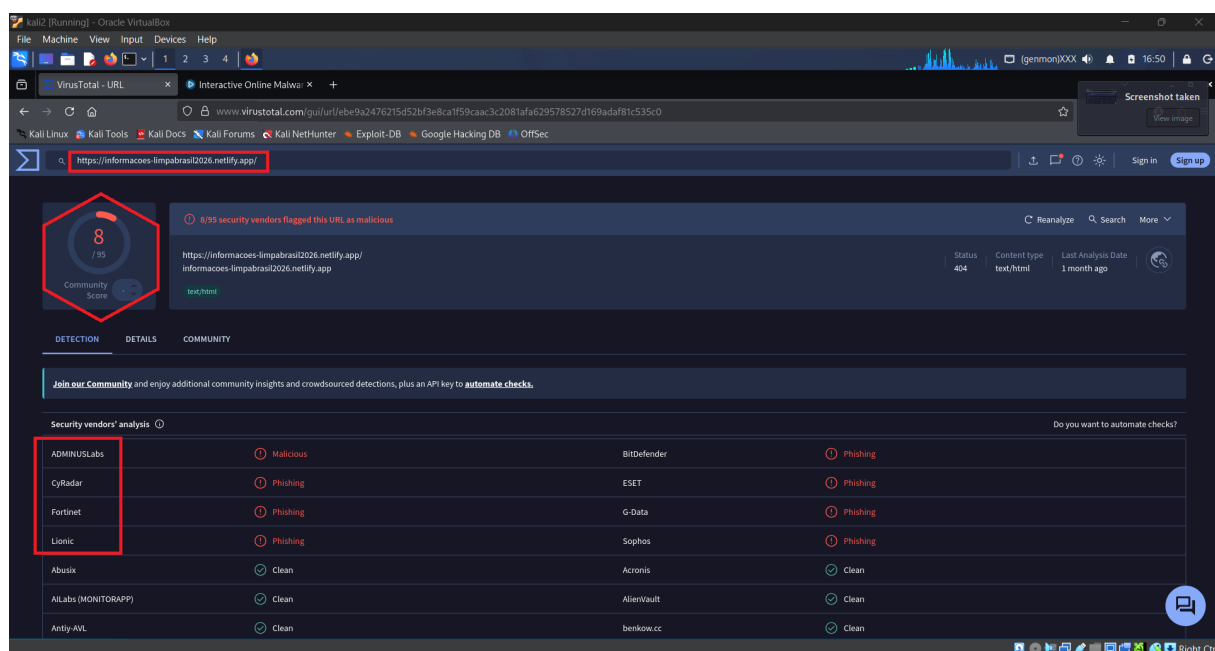


Figure 3: Link 1 — VirusTotal

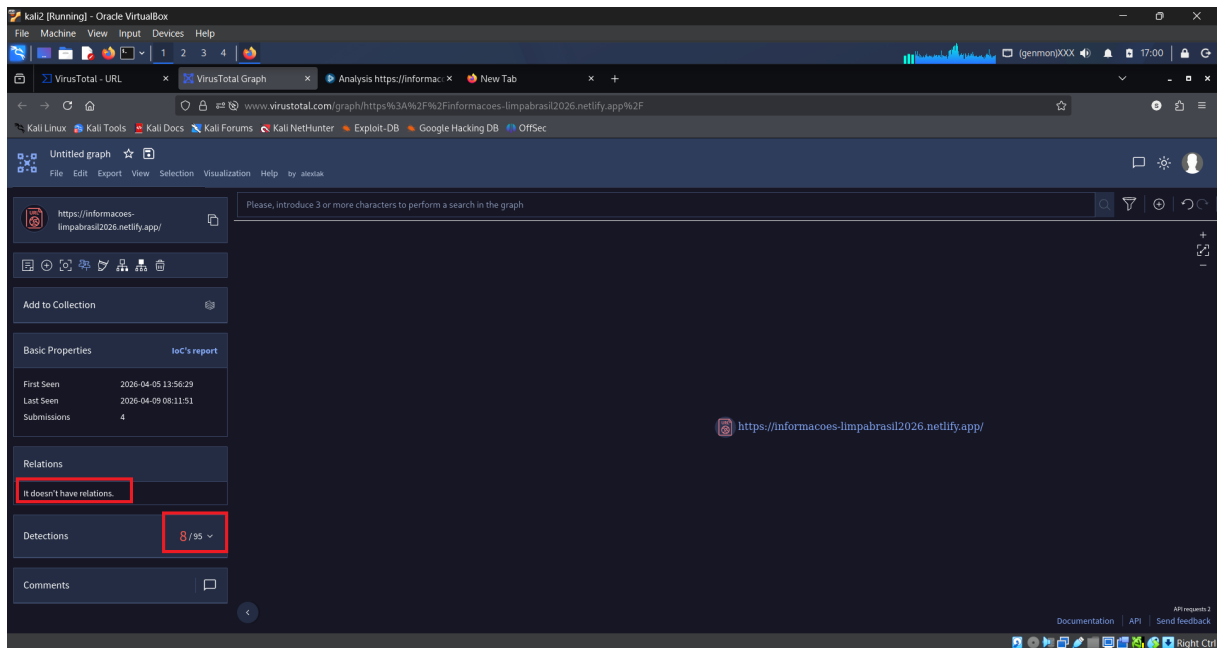


Figure 4: Link 1 — VirusTotal Graph

4.3.2 Link 2 — walletedinar.com (Tunisia La Poste “e-Dinar” clone)

ANY.RUN rendered a polished French-language fintech site “*Wallet E-dinar*” impersonating Tunisia’s La Poste *e-Dinar* payment wallet, complete with *Se connecter / Ouvrir un compte* flows for account and credential harvesting.

ANY.RUN enumerated **73 indicators** (8 domains, 33 URLs, 28 hashes, 4 IPs), served from 173[.]230[.]137[.]142 behind `nginx/1.18.0`.

VirusTotal flags **20/92** Kaspersky, BitDefender, Fortinet, G-Data, Dr.Web, CRDF, Cluster25 and alphaMountain among them with a negative community score, first submitted 2026-02-23 and still active 2026-05-31 across **57 submissions**.

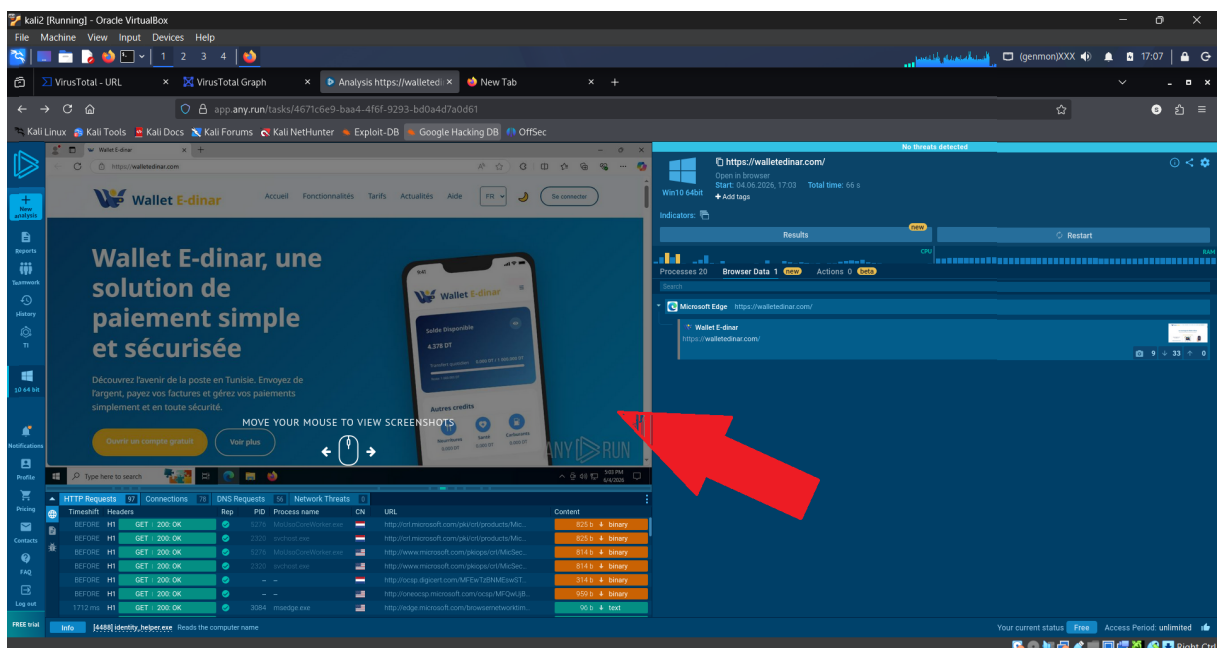


Figure 5: Link 2 — ANY.RUN

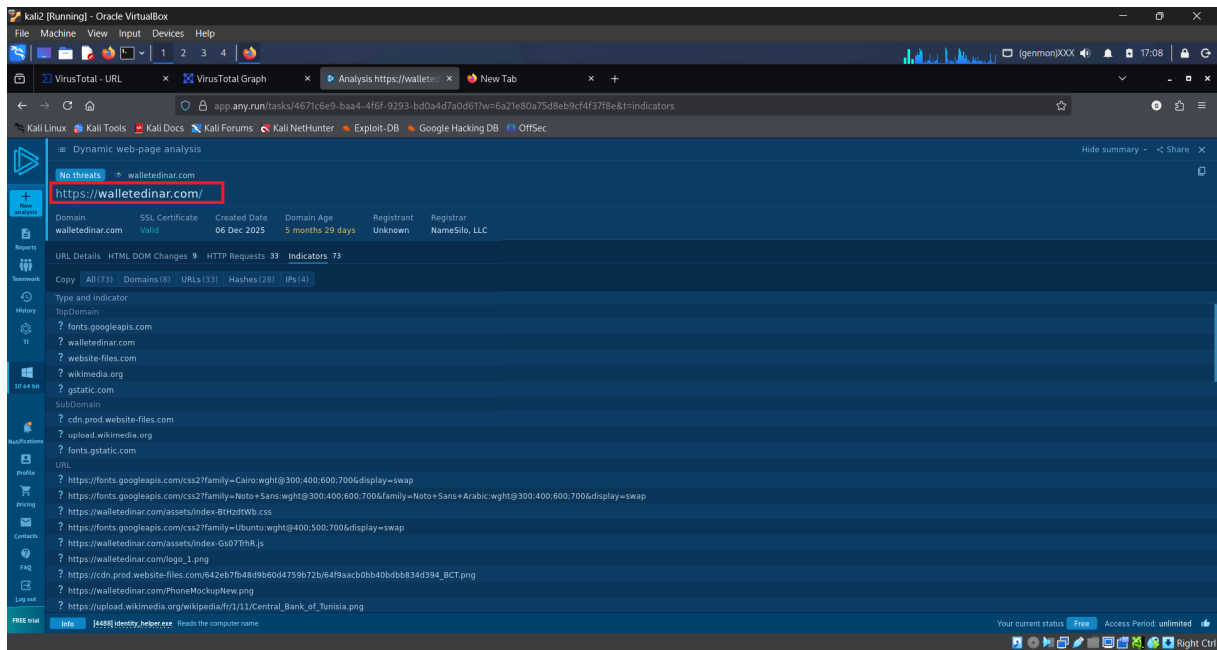


Figure 6: Link 2 — ANY.RUN indicators

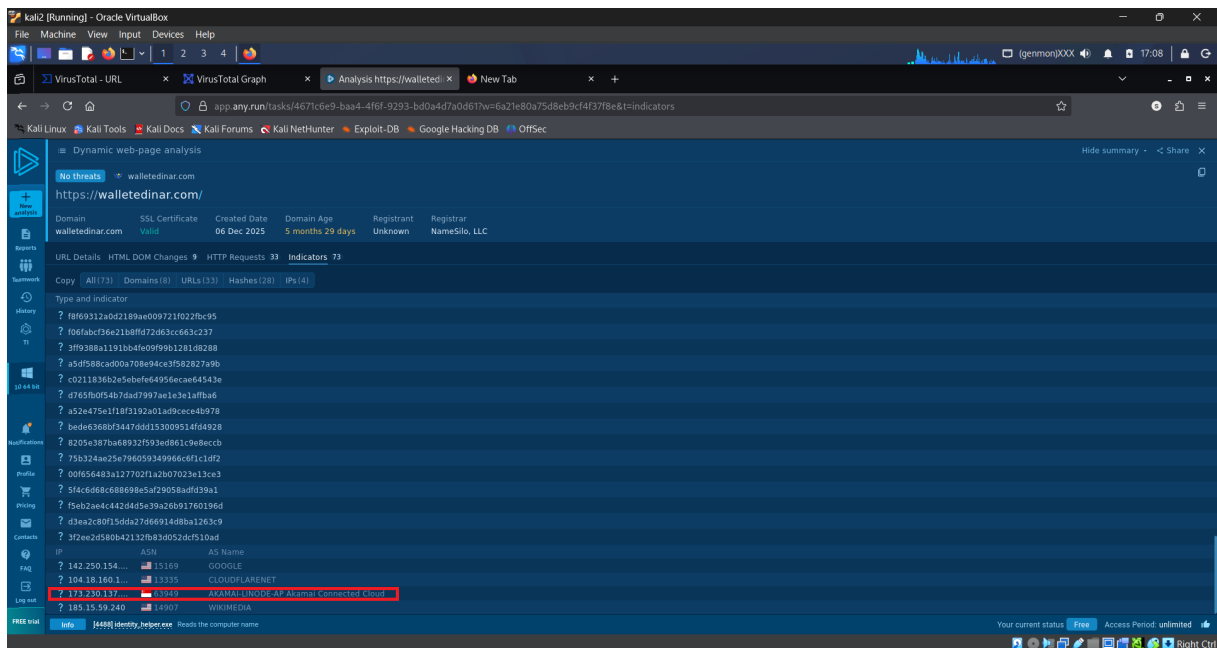


Figure 7: Link 2 — ANY.RUN indicators

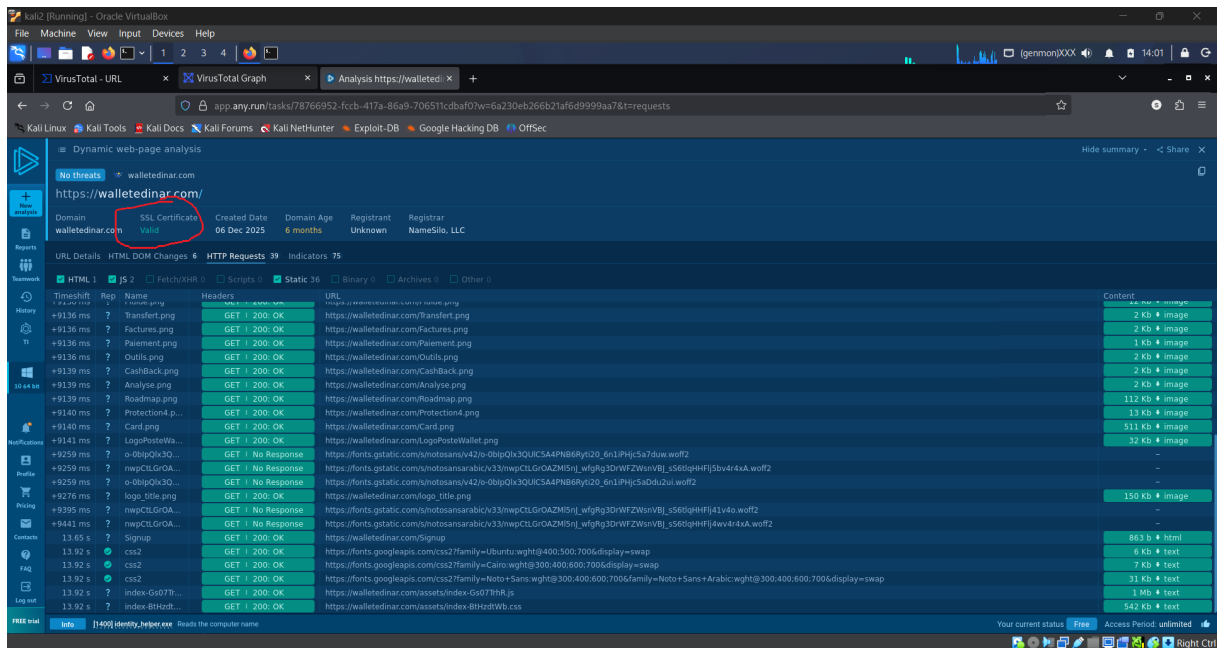


Figure 8: Link 2 — ANY.RUN HTTP requests

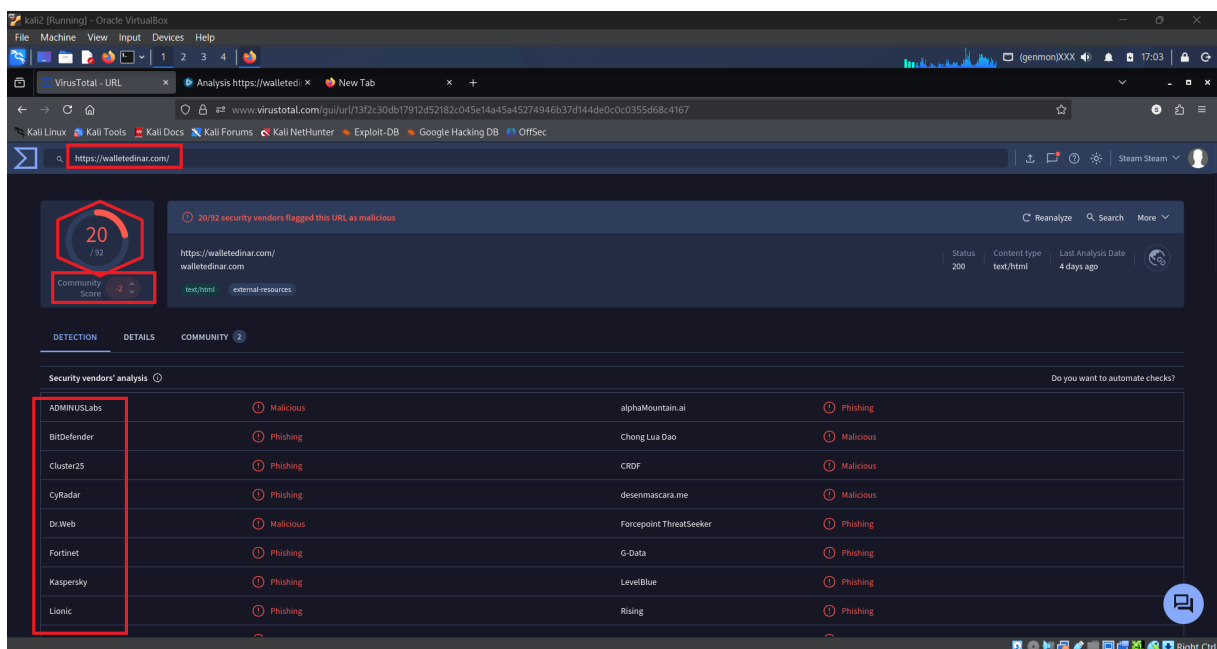


Figure 9: Link 2 — VirusTotal

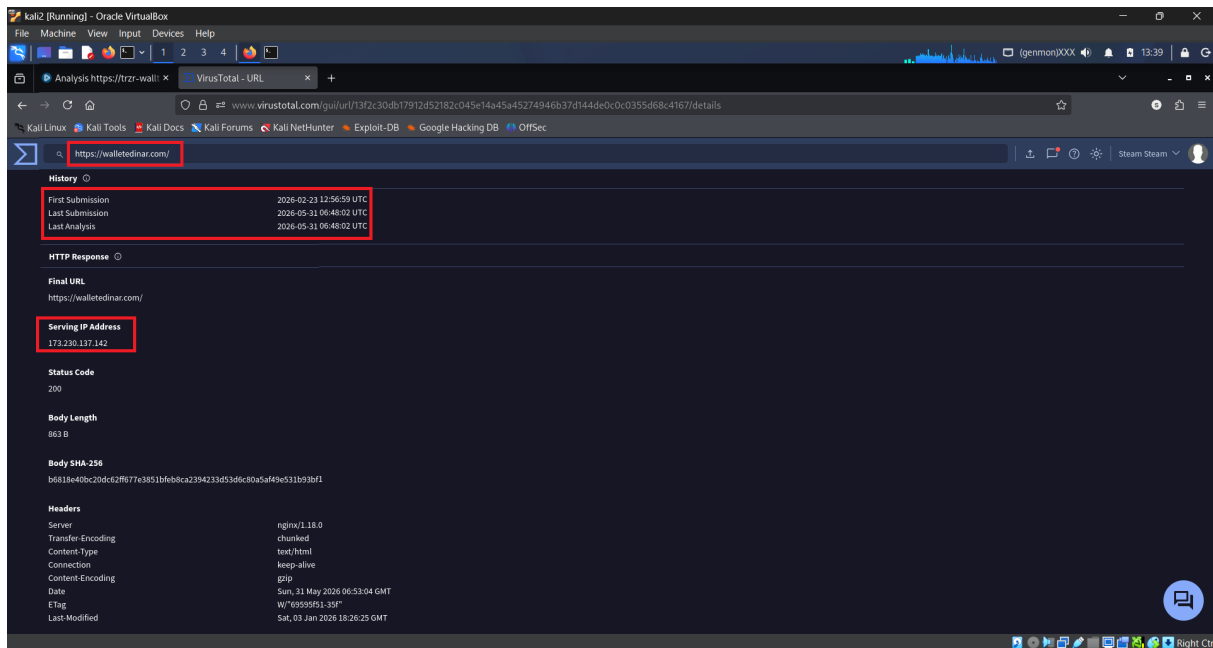


Figure 10: Link 2 — VirusTotal details

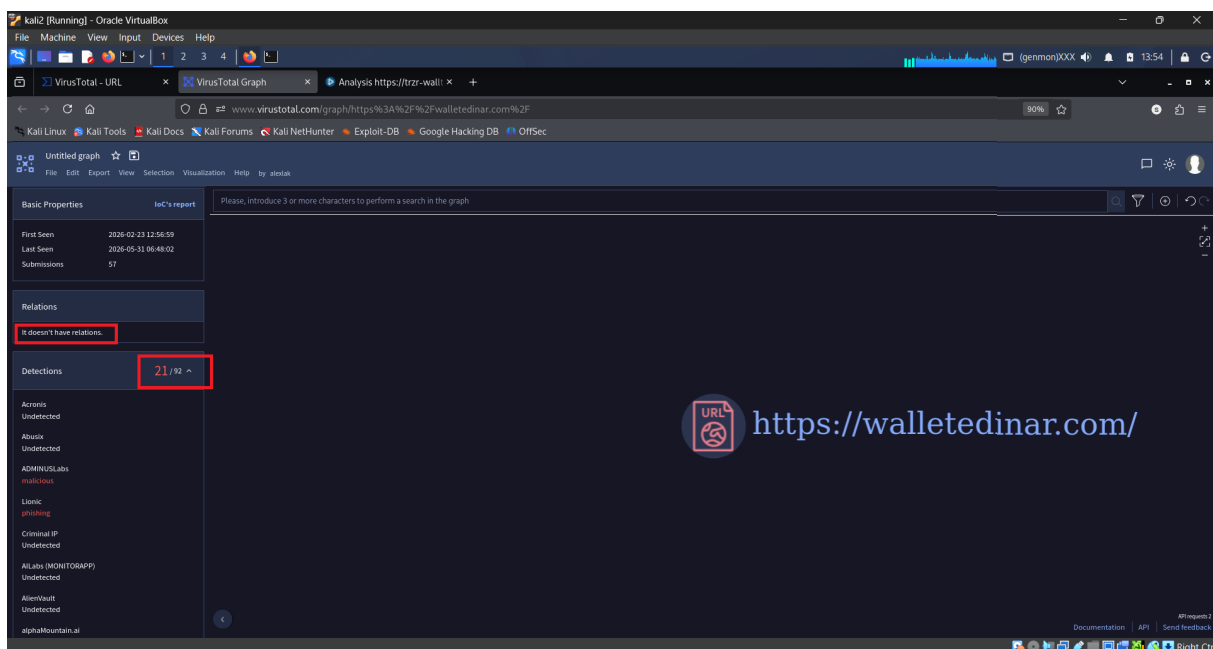


Figure 11: Link 2 — VirusTotal Graph

4.3.3 Link 106 — 051516xx.vectorprospera.digital

ANY.RUN reports DNS_PROBE_FINISHED_NXDOMAIN (“can’t reach this page”).

VirusTotal’s last fetch returned HTTP 403 from Cloudflare (172[.]67[.]149[.]206).

VirusTotal **16/95** (rising to 19/95 in the Graph view) with a mix of phishing and malware labels (Fortinet and G-Data “Malware”; Kaspersky and Sophos “Phishing”, plus Seclookup, SOCRadar and MalwareURL). First seen 2026-04-14, with no VT relations.

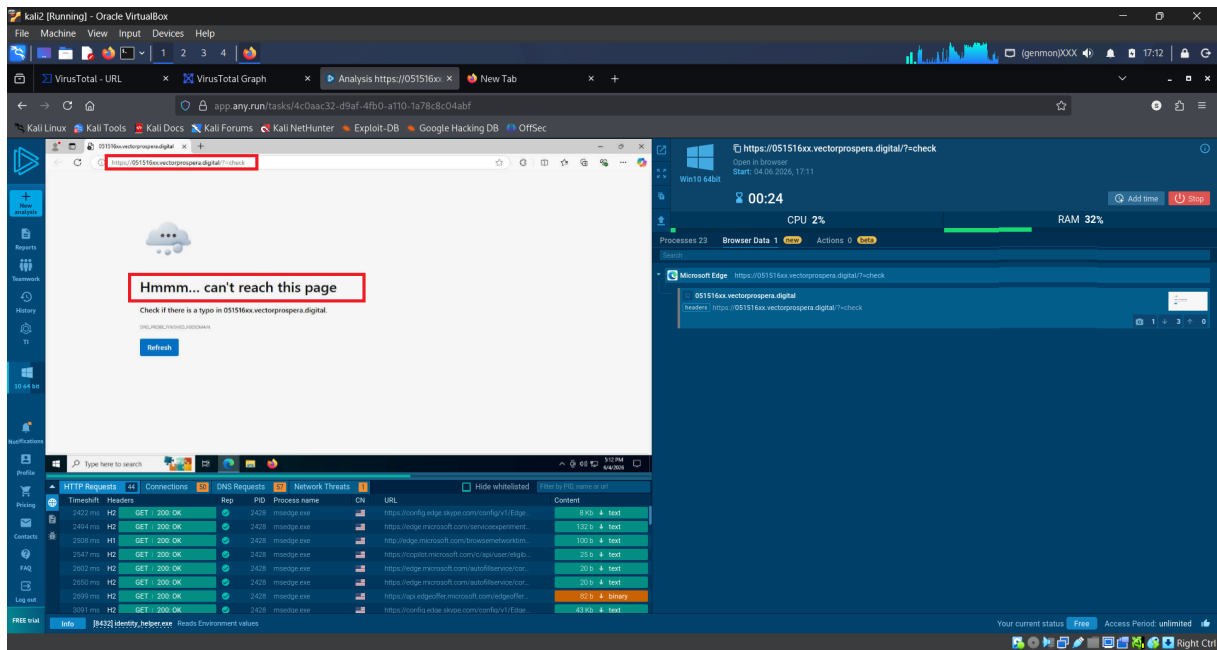


Figure 12: Link 106 — ANY.RUN: domain no longer resolves (DNS_PROBE_FINISHED_NXDOMAIN), confirming takedown.

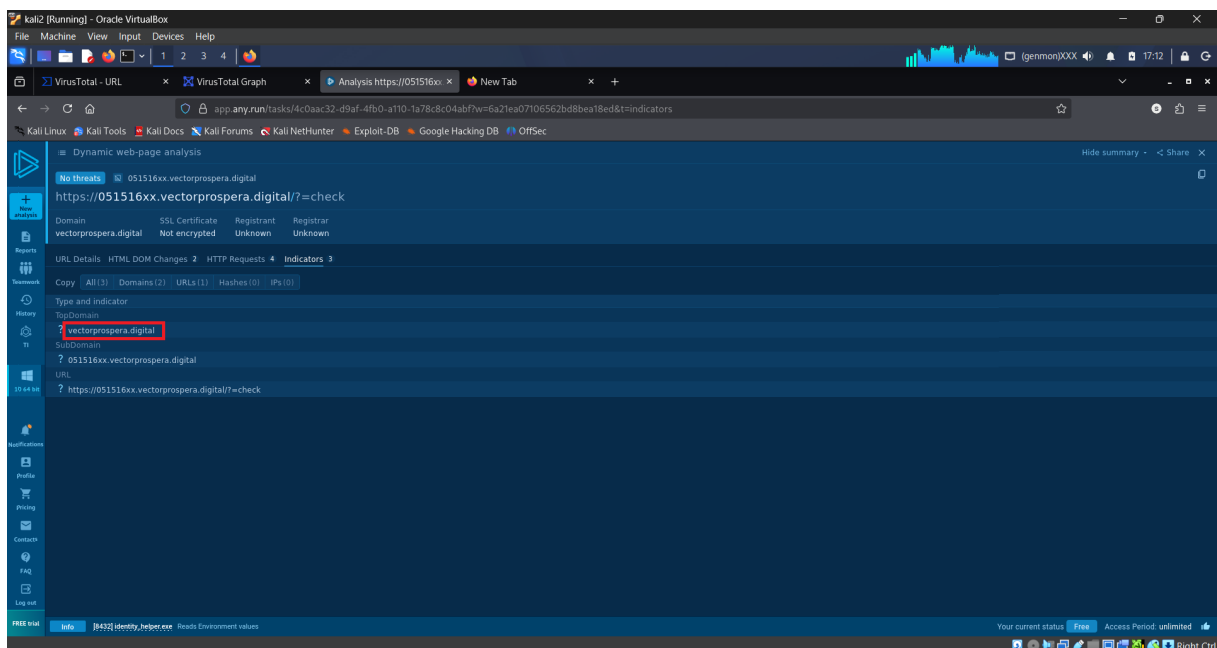


Figure 13: Link 106 — ANY.RUN indicators:

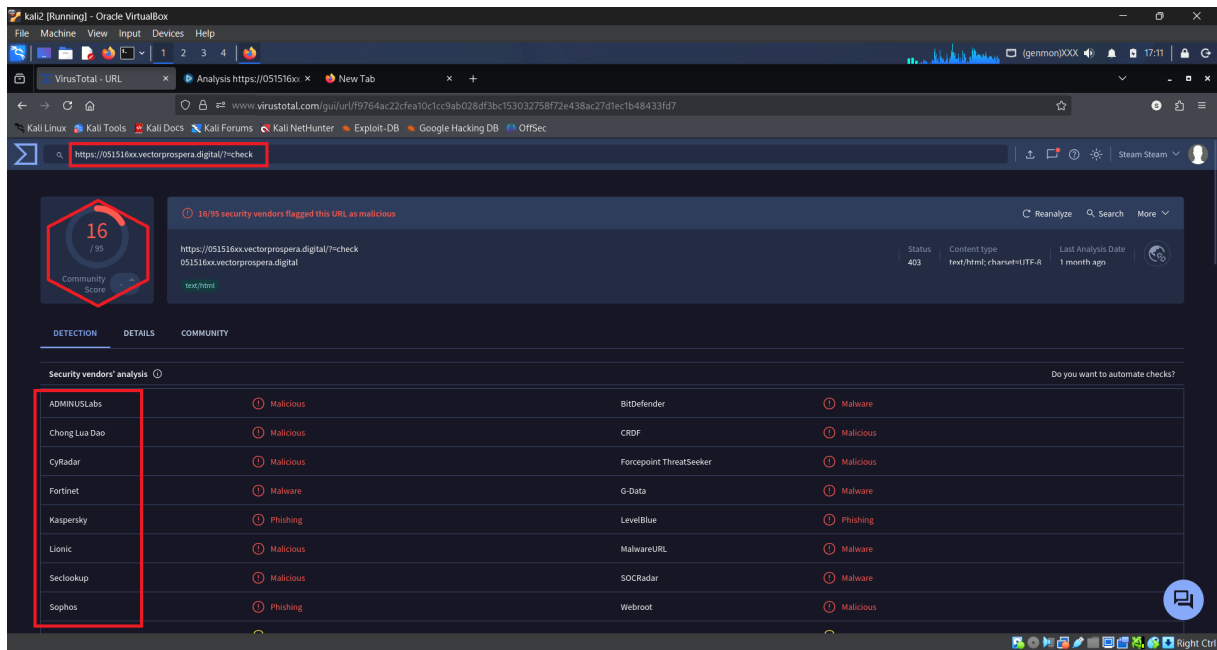


Figure 14: Link 106 — VirusTotal

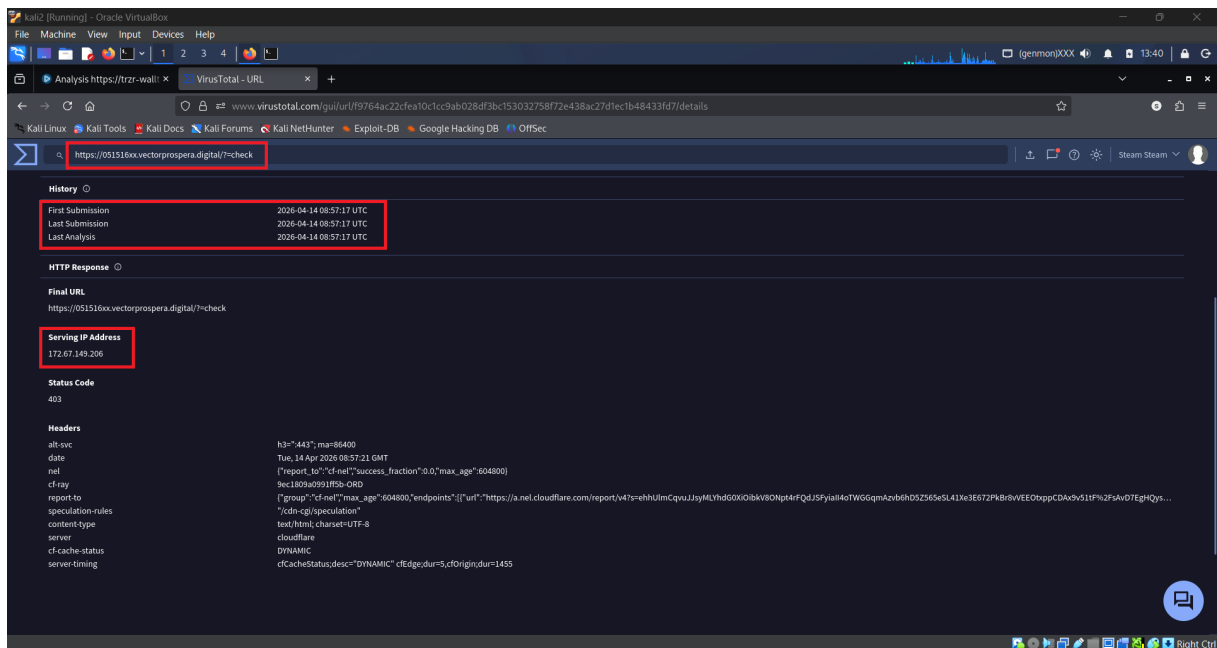


Figure 15: Link 106 — VirusTotal details

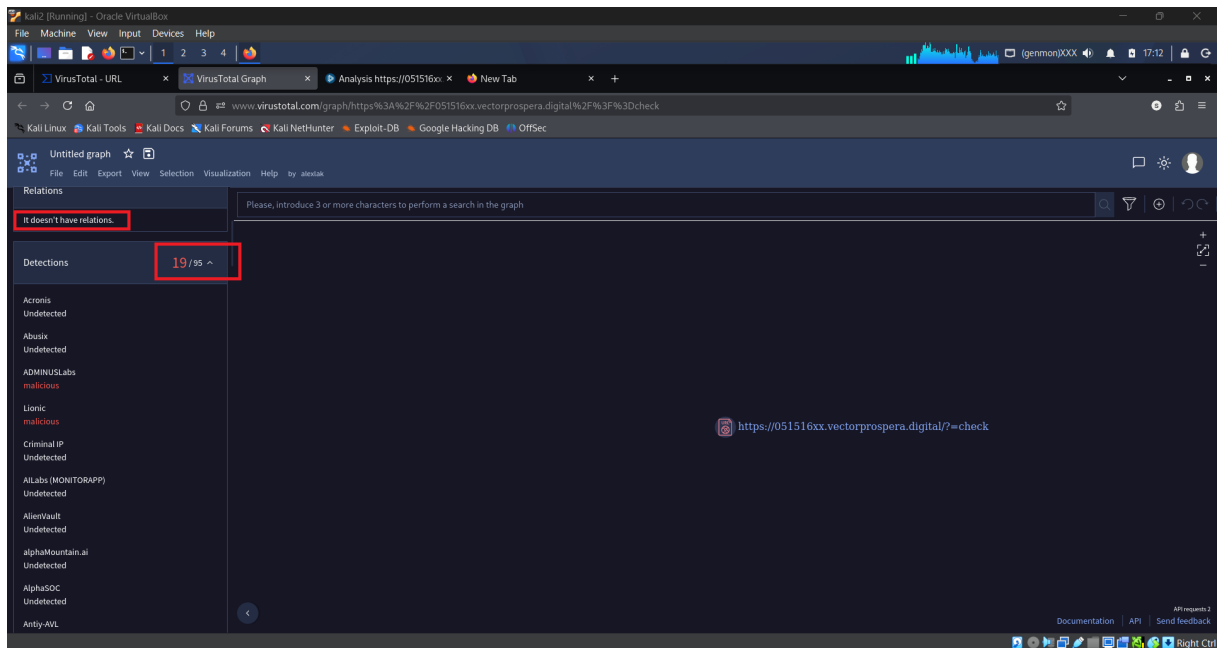


Figure 16: Link 106 — VirusTotal Graph

4.3.4 Link 11 — flintbrowser.pages.dev (fake “Flint Browser Pro”)

ANY.RUN renders a slick “*Flint Browser Pro*” site “*Secure Browsing for Security Professionals*” with a prominent *Download Free* button and a fake *Fingerprint Protection Dashboard*.

Targeting the security community (with GitHub-style framing) is a watering-hole-style trick, and the download almost certainly delivers a trojanised installer.

VirusTotal 1/95 (only alphaMountain.ai, phishing) so this is an **emerging, low-reputation threat** that score- or signature-based blocking will miss.

Served from 172[.]66[.]44[.]107 (Cloudflare), 200 OK, 3.01 KB; first seen 2026-04-05, last 2026-04-12; VT Graph 1/95 with no relations.

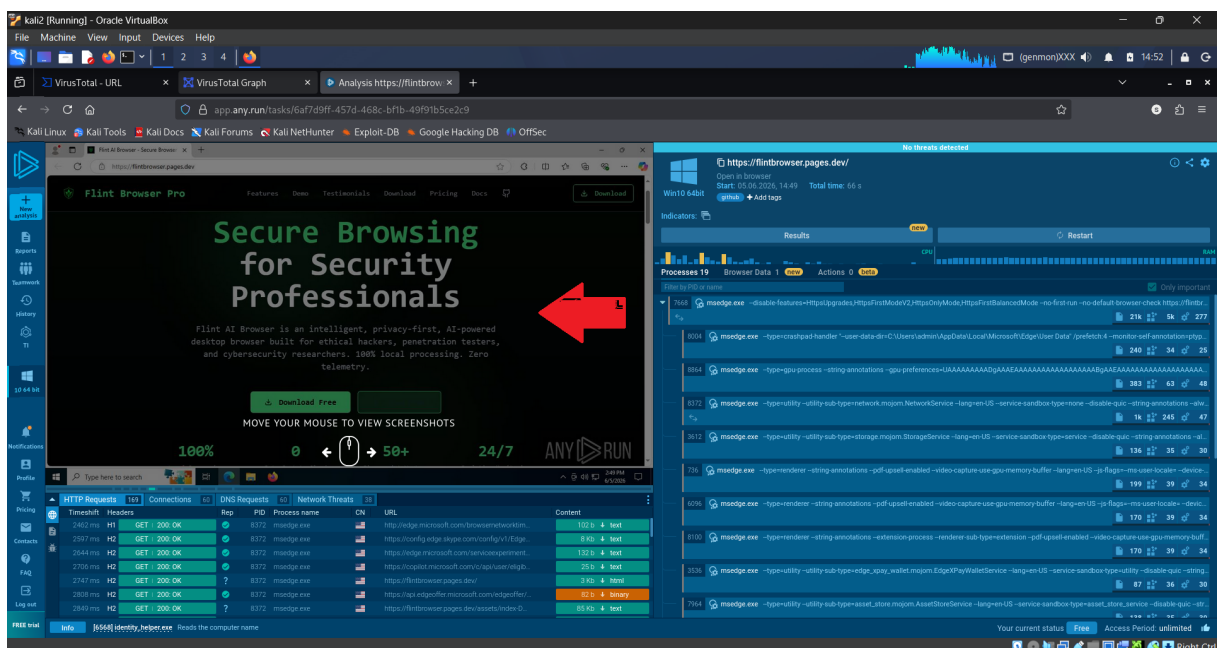


Figure 17: Link 11 — ANY.RUN

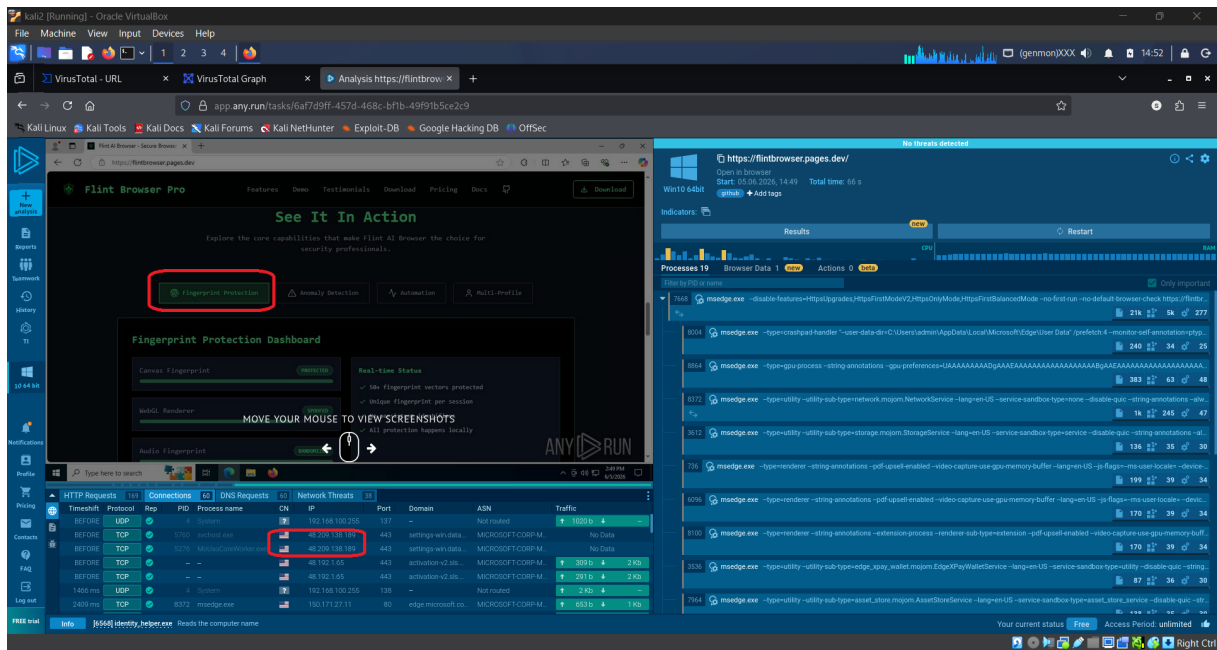


Figure 18: Link 11 — ANY.RUN

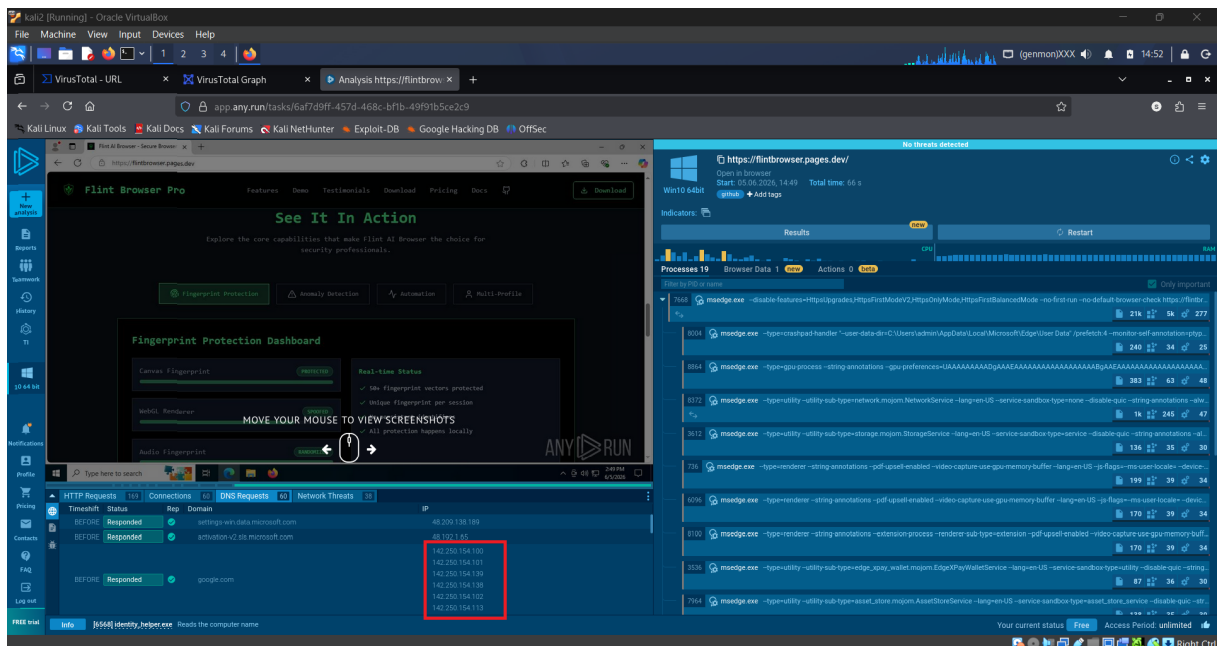


Figure 19: Link 11 — ANY.RUN DNS

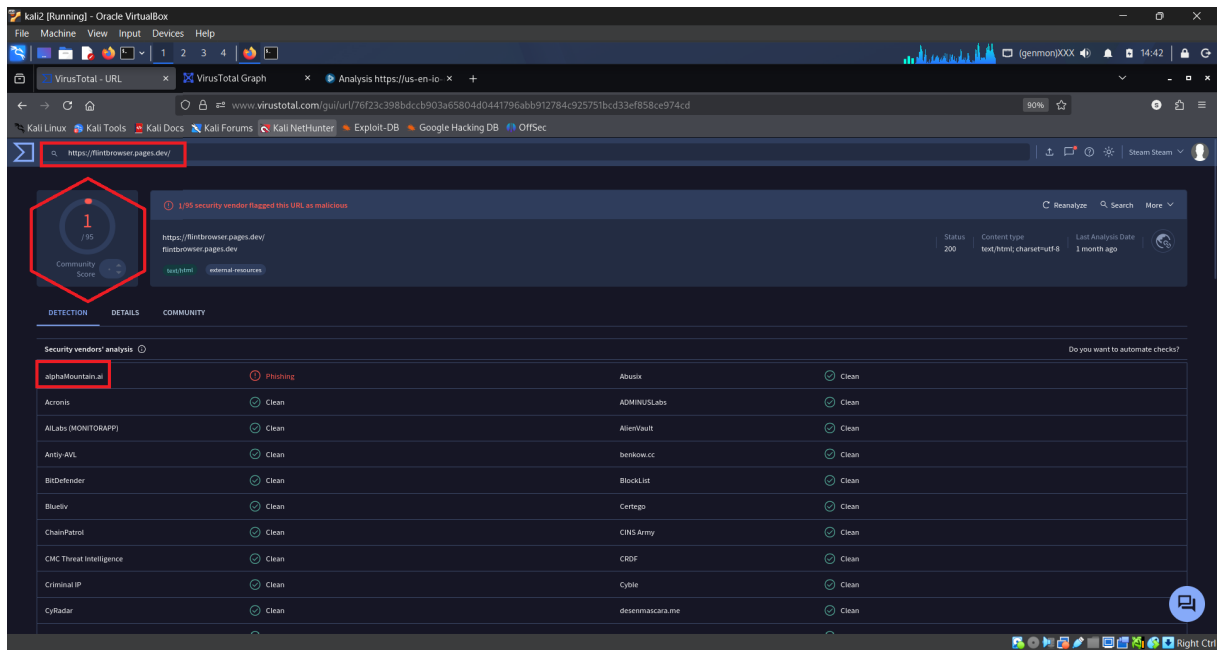


Figure 20: Link 11 — VirusTotal

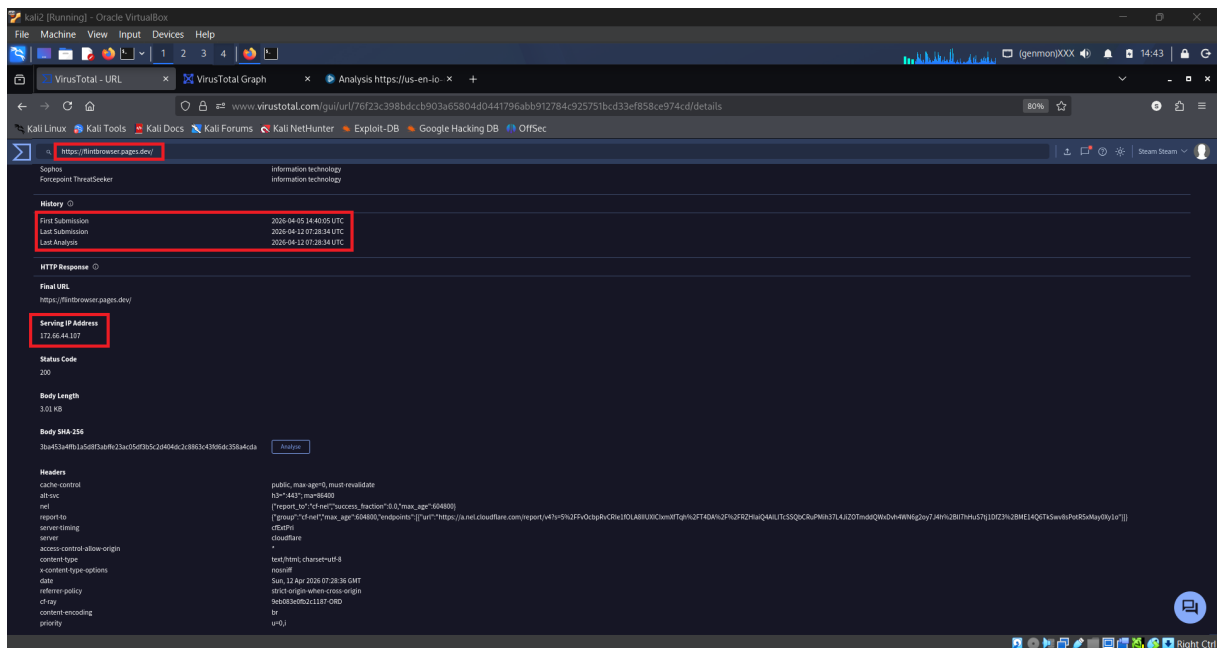


Figure 21: Link 11 — VirusTotal details

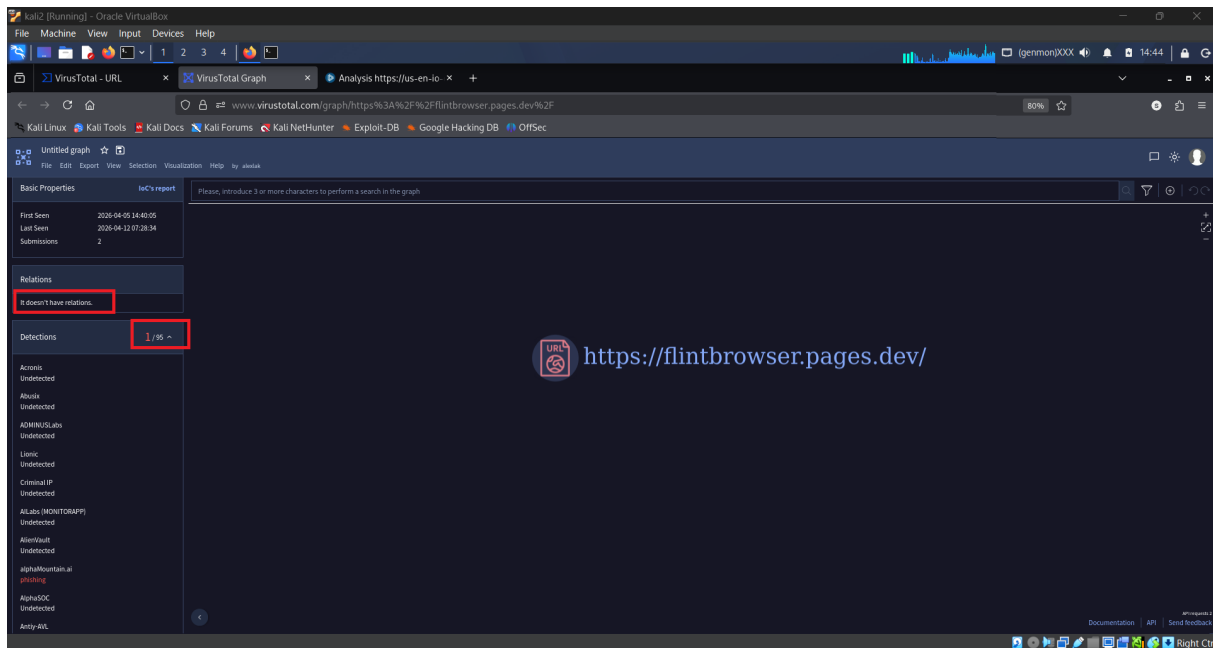


Figure 22: Link 11 — VirusTotal Graph

4.3.5 Link 13 — livre-acessoferiao.shop (BR lure on GitHub Pages)

The notable detail is **hosting**: VirusTotal resolves it to 185[.]199[.]108[.]153 with **Server: GitHub.com**.

VirusTotal **1/95** (ESET, phishing) and by detonation time the **.shop** domain no longer resolved (NXDOMAIN), so the page itself is already gone while the campaign pattern remains. HTTP 200, 6.51 KB; first seen 2026-04-05; VT Graph 1/95, no relations.

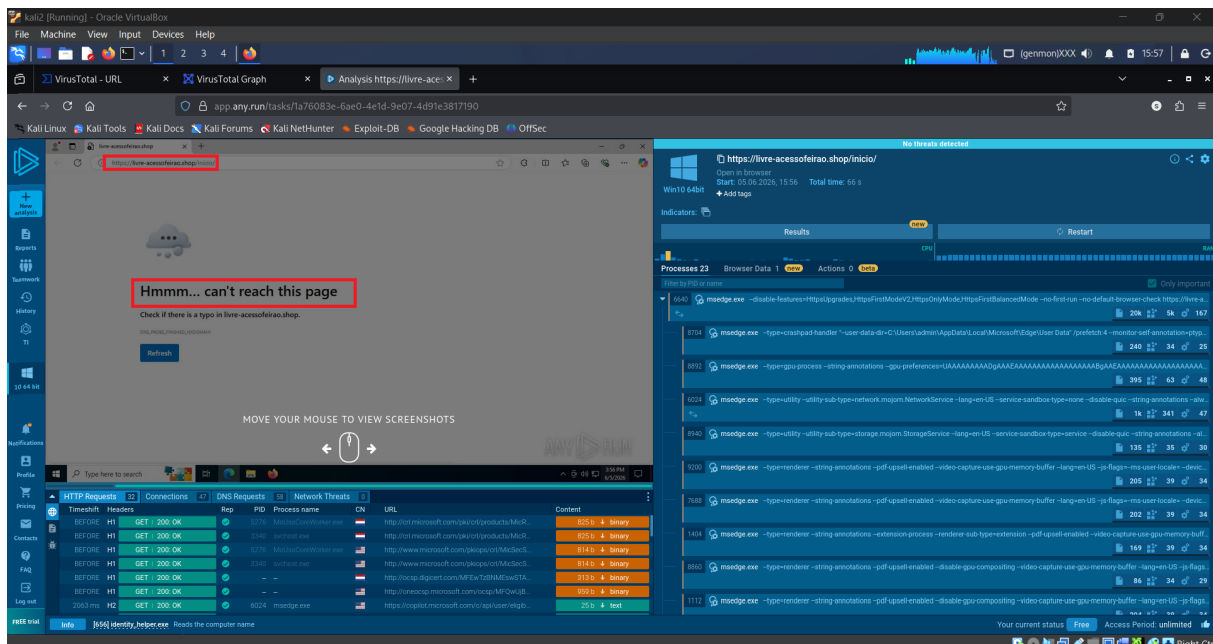


Figure 23: Link 13 — ANY.RUN

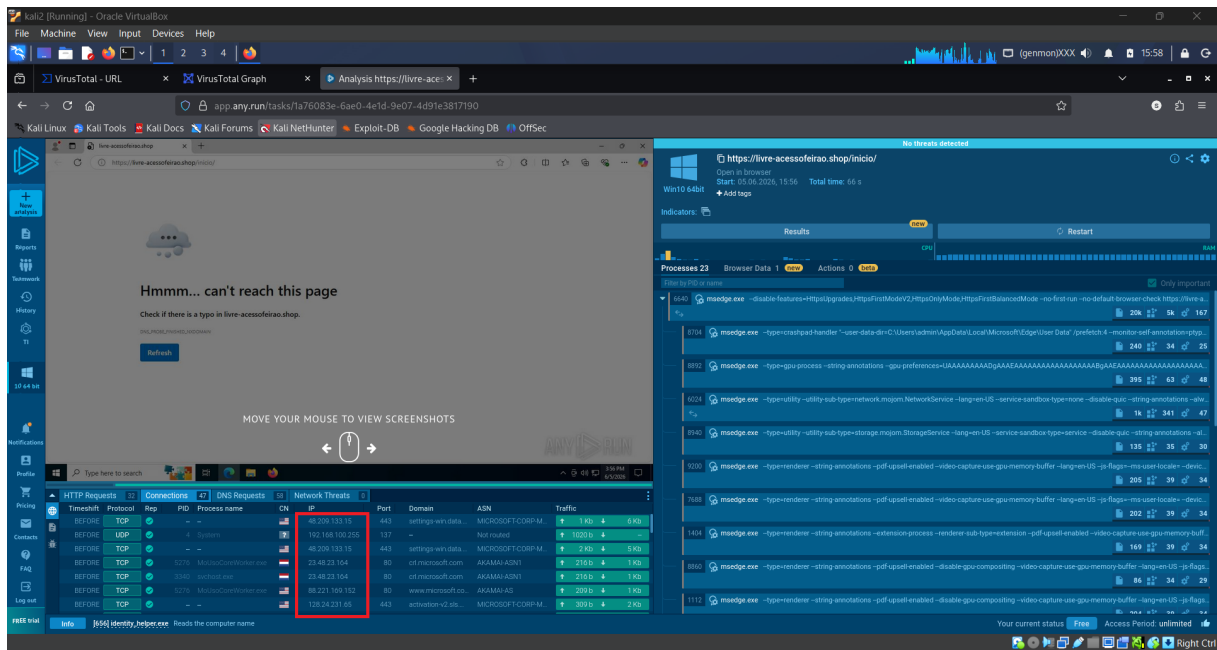


Figure 24: Link 13 — ANY.RUN connections

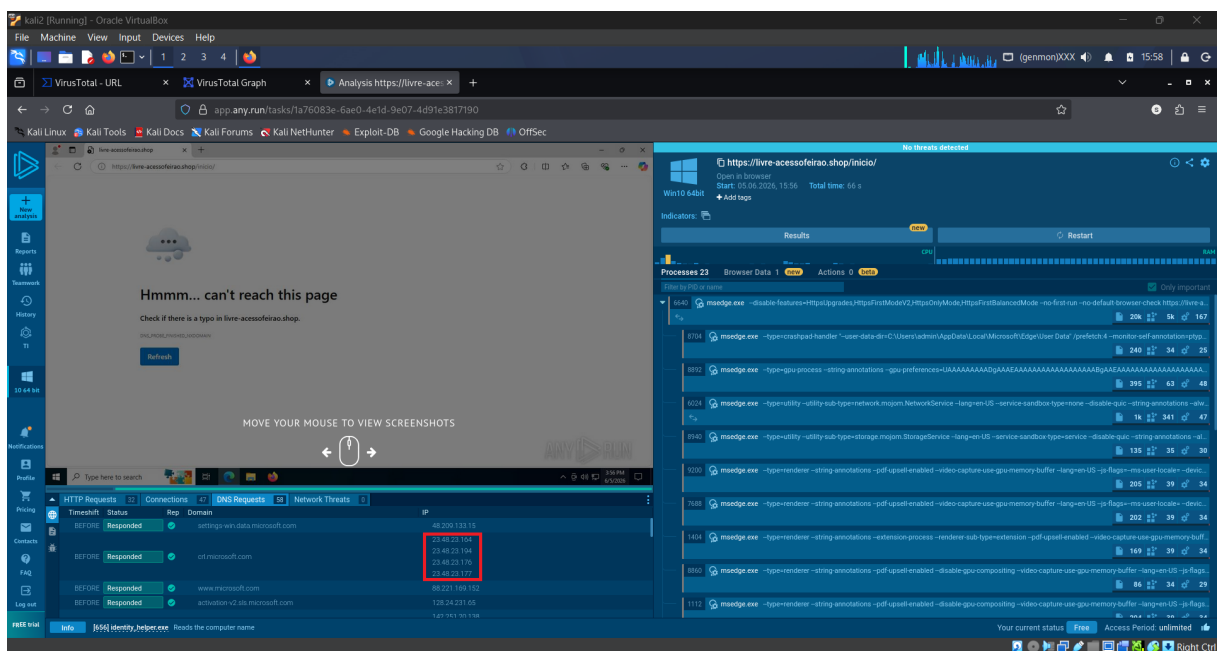


Figure 25: Link 13 — ANY.RUN DNS

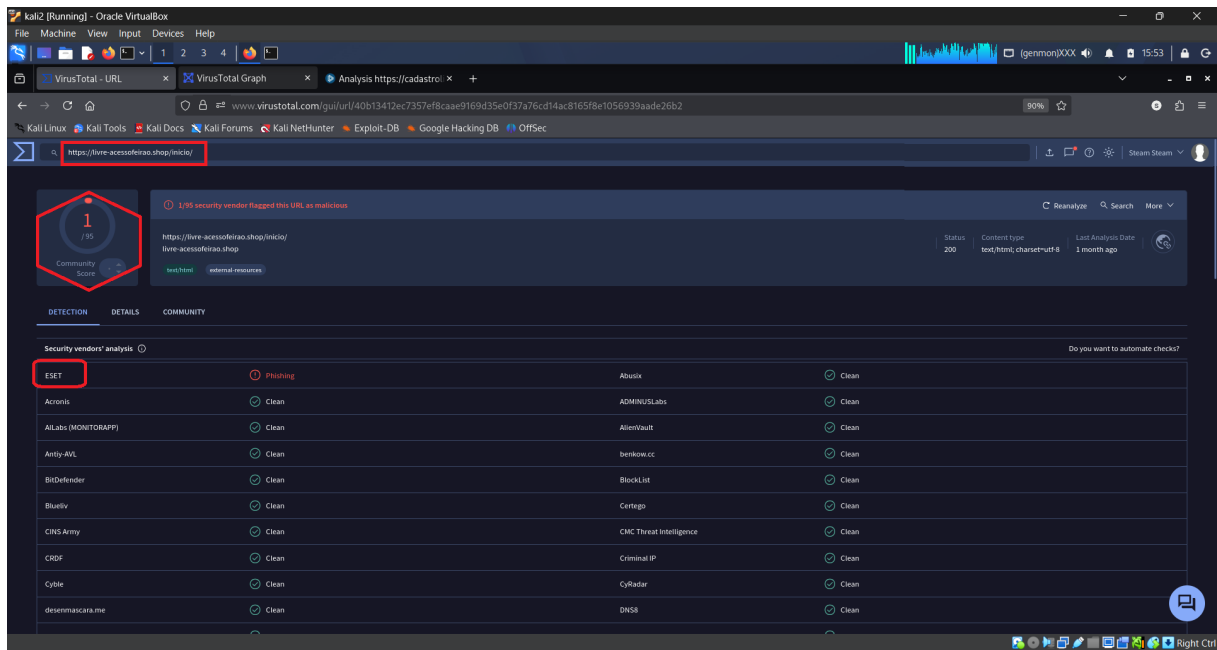


Figure 26: Link 13 — VirusTotal

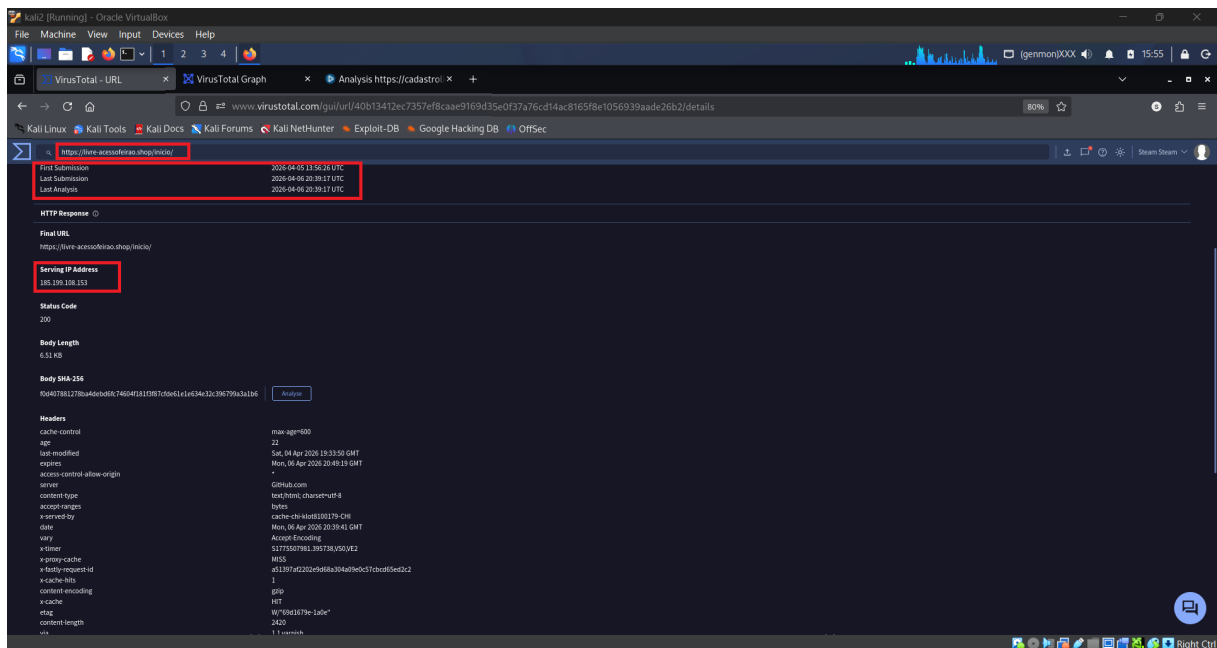


Figure 27: Link 13 — VirusTotal details

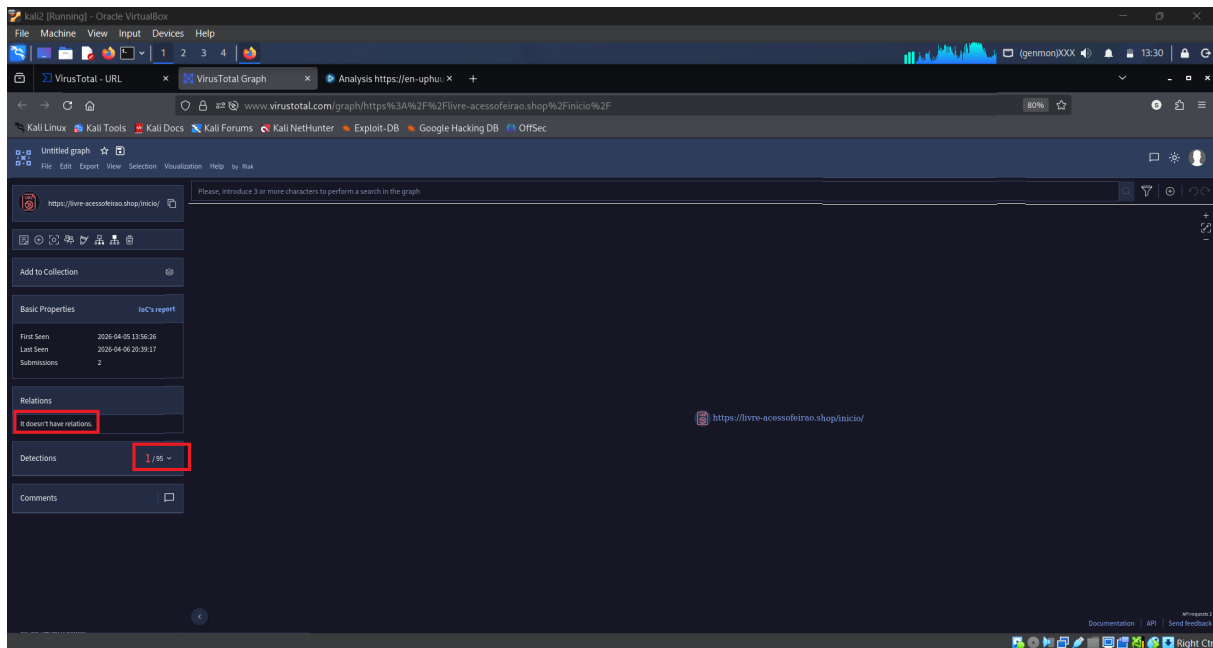


Figure 28: Link 13 — VirusTotal Graph

4.4 Key Takeaways — Category A

- **Trusted-host abuse** Netlify, Cloudflare, Linode/Akamai and Webflow, all with valid TLS, are used to make lures look legitimate.
- **Regional, targeted lures** Brazilian (*limpa Brasil*) and Tunisian (*La Poste e-Dinar*) financial themes indicate localized social engineering, not random spam.
- **Emerging / low-detection lures exist** the fake *Flint Browser* (link 11) sits at just 1/95, a reminder that VT score alone is not a safe gate for newly-stood-up infrastructure.

5 Category B — Crypto Wallet Drainers

5.1 Targets

#	Host (defanged)	Assessment
5	trzr-wallt-io[.]pages[.]dev	Seed-phrase drainer
6	trzr-wallt-io[.]pages[.]dev	Seed-phrase drainer
7	us-en-io-download[.]pages[.]dev	Seed-phrase drainer
8	us-en-io-download[.]pages[.]dev	Seed-phrase drainer
9	en-uphuuld-walet-us[.]pages[.]dev	Seed-phrase drainer
10	en-uphuuld-walet-us[.]pages[.]dev	Seed-phrase drainer

5.2 Analysis

Category B is a **hardware-wallet phishing / drainer set** built on Cloudflare Pages (*.pages.dev). The three pages.dev hosts are deliberate **typosquats / homoglyph spoofs of trezor.io** note the mangled fragments **trzr-wallt**, **io-download** and **uphuuld-walet**. These pages mimic the Trezor Suite setup / firmware-update flow and ultimately request the victim's **recovery (seed) phrase**, once submitted, the attacker imports the wallet and drains all assets an **irreversible** loss.

5.3 Category B — Evidence Summary

	Link 5	Link 7	Link 9
Host	trzr-wallt-io[.]pages[.]dev	us-en-io-download[.]pages[.]dev	en-uphuuld-walet-us[.]pages[.]dev
Spoof target	Trezor wallet (trezor.io)	Trezor Bridge download (trezor.io)	Crypto wallet (uphold homograph)
VT detections	6/95	10/95	9/95
HTTP status	200 / 403 (Cloudflare-gated)	200 (live)	451 (ANY.RUN) / 200 at VT
Observed at analysis	Cloudflare “Suspected Phishing” + Turnstile gate	Live fake Trezor Bridge download page	HTTP 451 + 9 network threats
Serving IP	172[.]66[.]47[.]84 Cloudflare	172[.]66[.]46[.]248 Cloudflare	172[.]66[.]44[.]232 Cloudflare
Body size	5.22 KB	7.57 KB	7.16 KB
VT first seen	2026-04-05	2026-04-05	2026-04-05
Verdict	DRAINER	DRAINER	DRAINER

5.3.1 Link 5 — trzr-wallt-io.pages.dev

VirusTotal flags **6/95** (ADMINUSLabs malicious; BitDefender, G-Data, Kaspersky, LevelBlue and Sophos phishing).

In ANY.RUN the task is tagged *phishing* / *Malicious activity*, but the site has already been caught by Cloudflare’s brand-protection: visiting it yields Cloudflare’s “*Suspected Phishing*” interstitial behind a *Turnstile* human-check, and the origin returns HTTP 403 Forbidden.

The 16 collected indicators are accordingly almost all Cloudflare infrastructure `cloudflare[.]com`, the Turnstile challenge host, and `104[.]18[.]94[.]41` (AS13335).

Served from `172[.]66[.]47[.]84` (Cloudflare); first/last VT submission 2026-04-05; VT Graph 6/95, no relations. This is a hardware-wallet seed-phrase drainer whose takedown is already in progress.

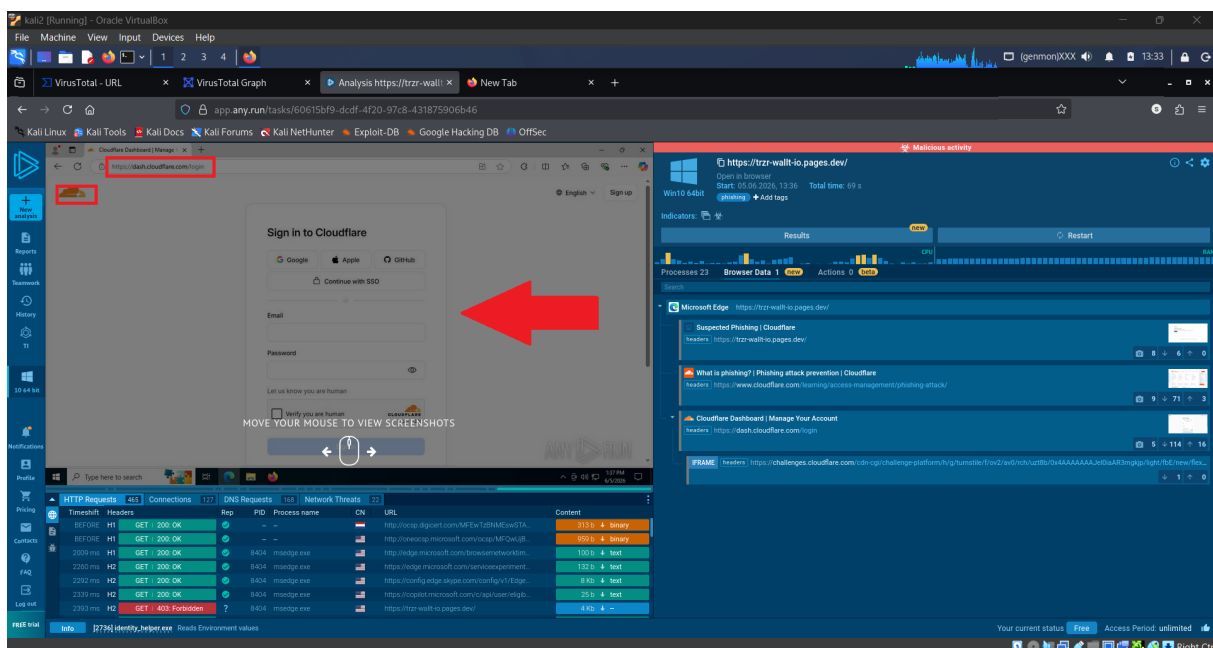


Figure 29: Link 5 — ANY.RUN (tagged phishing/Malicious)

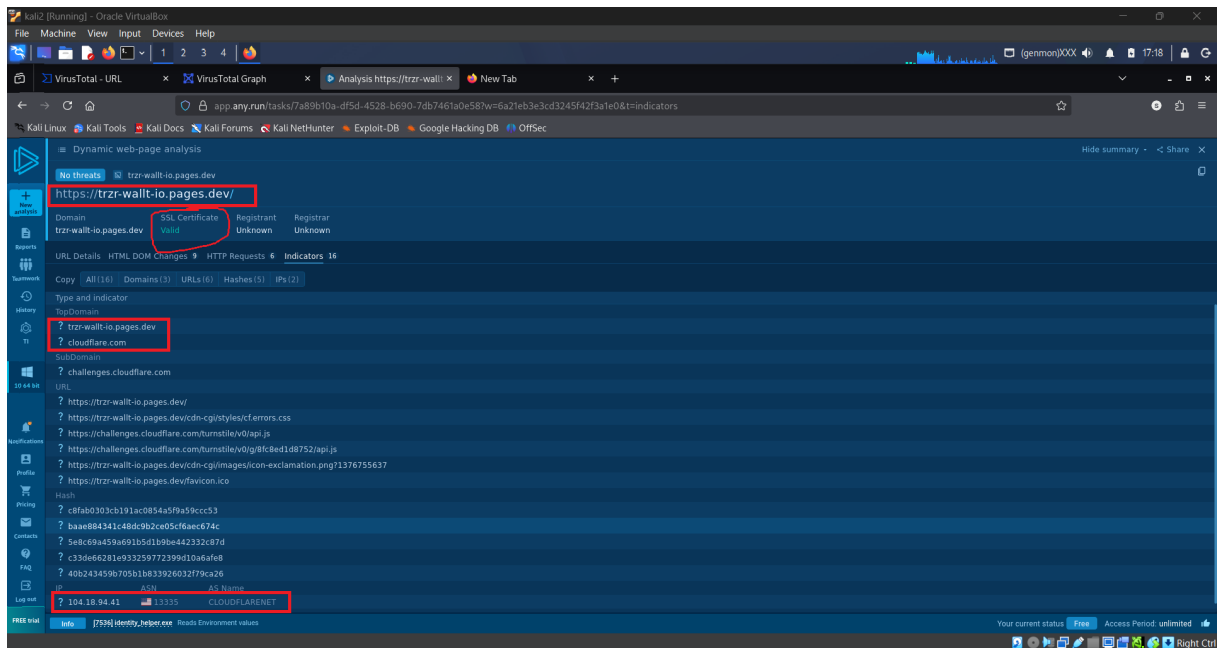


Figure 30: Link 5 — ANY.RUN indicators

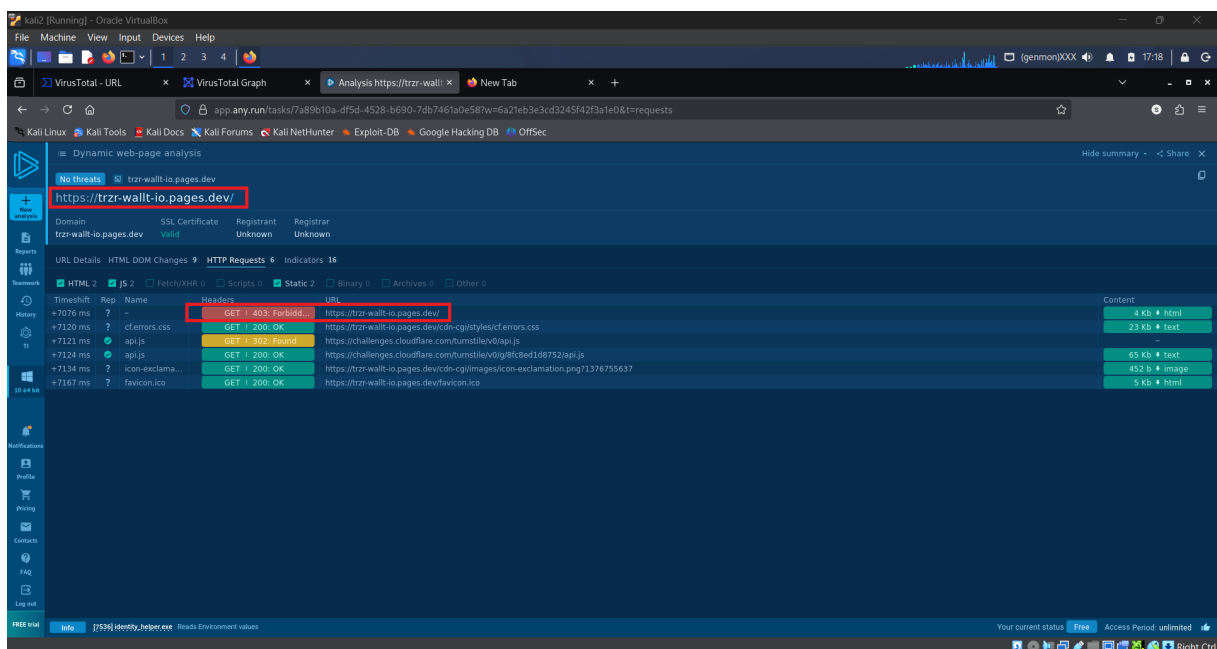


Figure 31: Link 5 — ANY.RUN HTTP

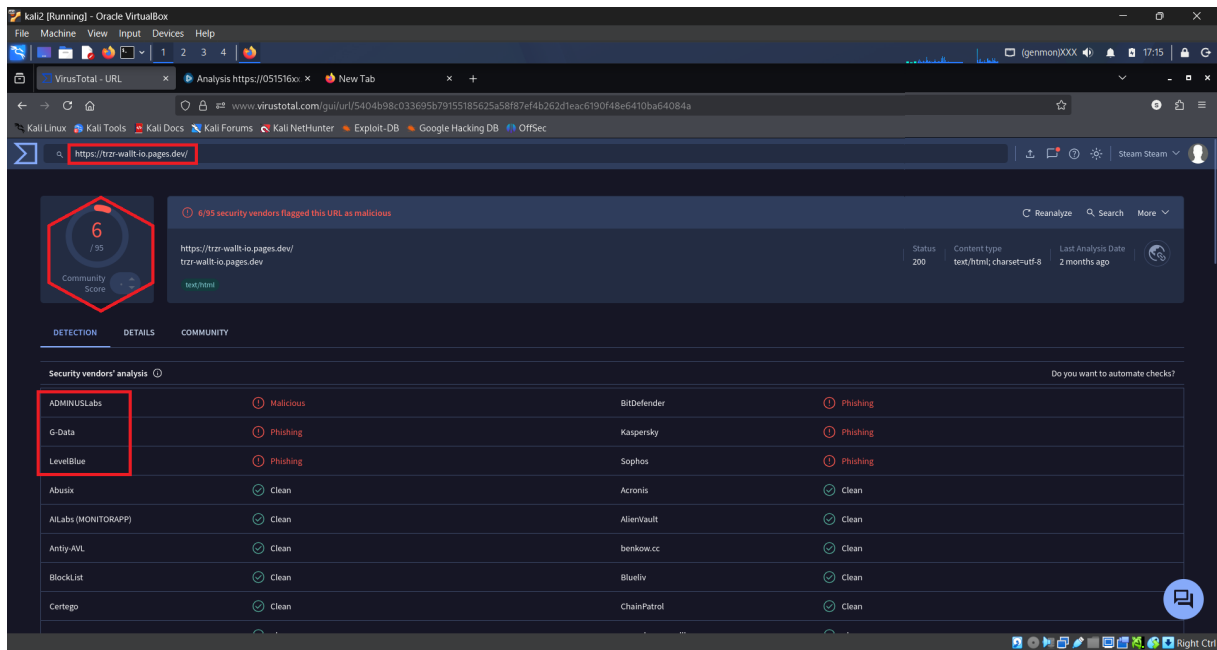


Figure 32: Link 5 — VirusTotal

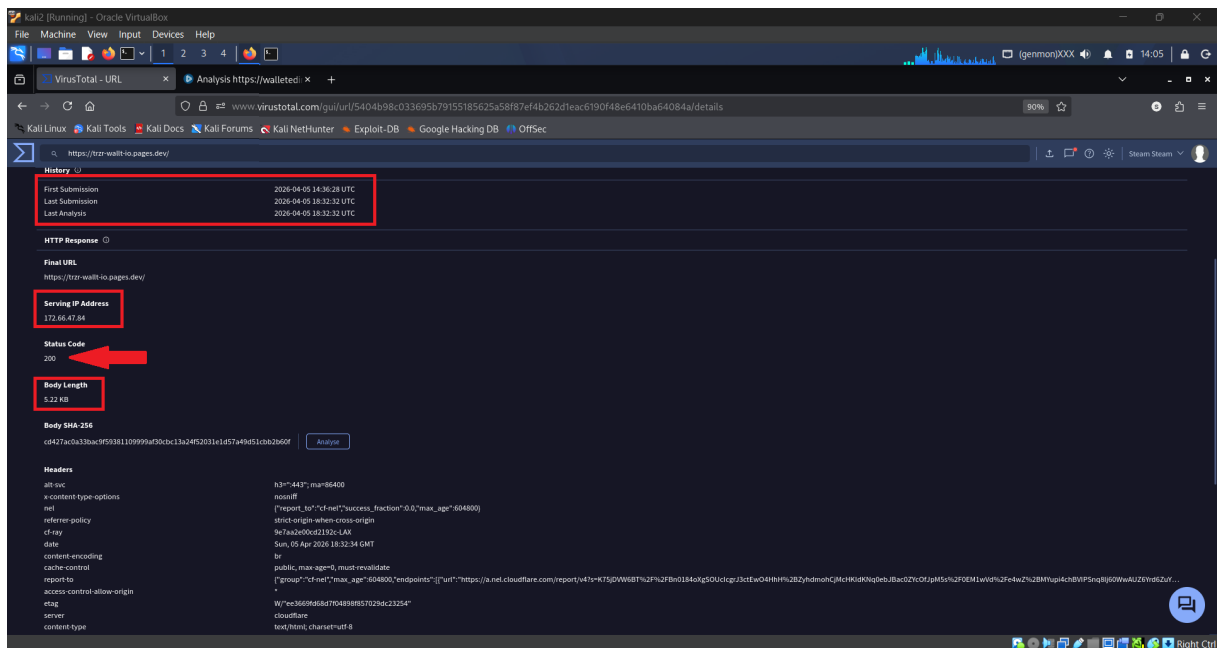


Figure 33: Link 5 — VirusTotal details

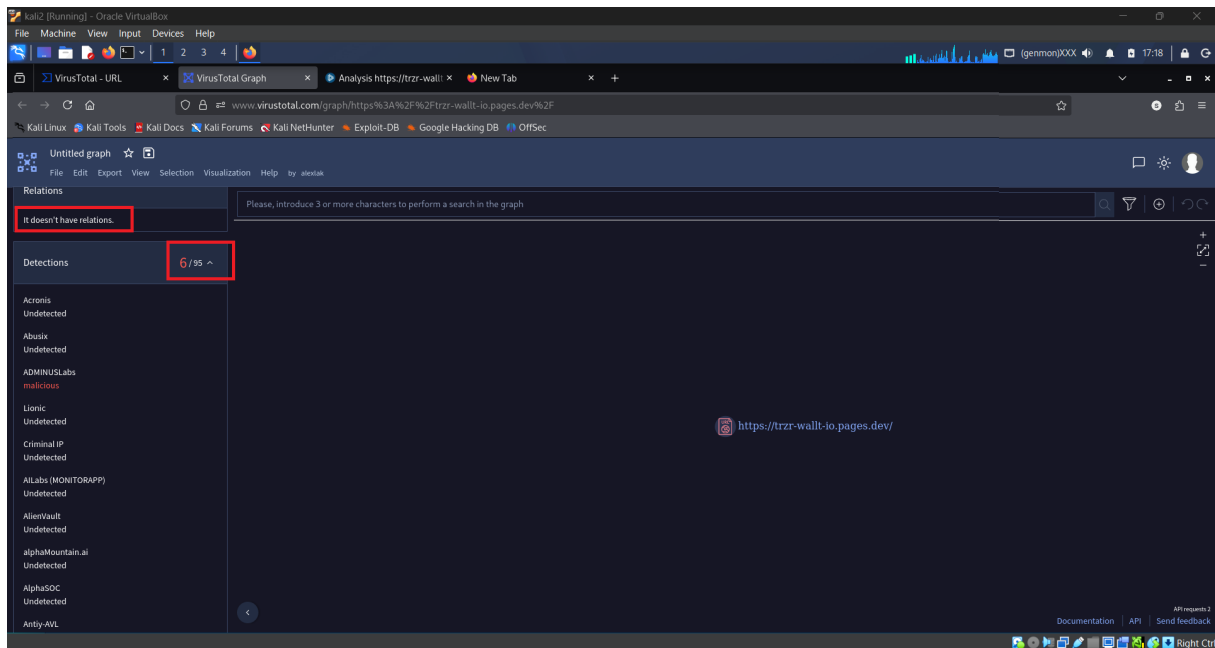


Figure 34: Link 5 — VirusTotal Graph

5.3.2 Link 7 — us-en-io-download.pages.dev (fake Trezor Bridge)

ANY.RUN renders a polished fake *Trezor Bridge* download page step-by-step install instructions, a prominent *Download Trezor Bridge Now* button, an FAQ (“*Is Trezor Bridge free?*”), and an *Official Resources* block that links to the **real** `trezor[.]io` and `wiki[.]trezor[.]io` (some returning 404) to borrow legitimacy.

VirusTotal flags **10/95** (ADMINUSLabs malicious; alphaMountain, BitDefender, CyRadar, Fortinet, G-Data, Kaspersky, LevelBlue, Lionix and Sophos phishing).

Served from 172[.]66[.]46[.]248 (Cloudflare), 200 OK, 7.57 KB; first seen 2026-04-05; VT Graph 10/95, no relations.

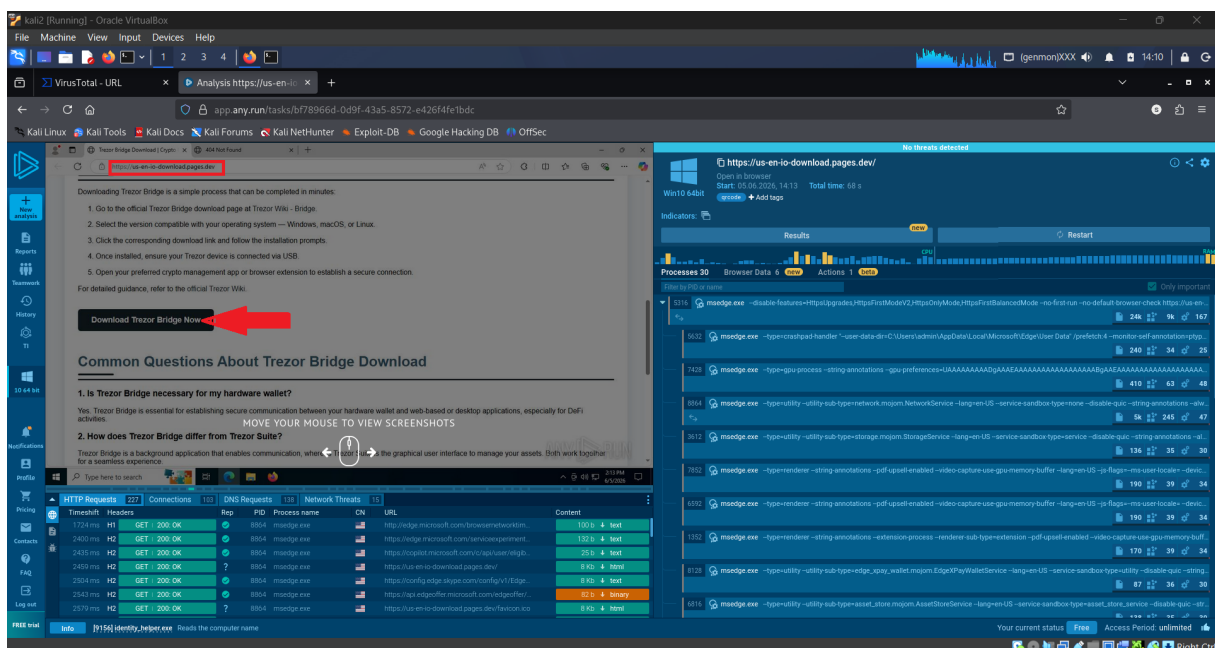


Figure 35: Link 7 — ANY.RUN

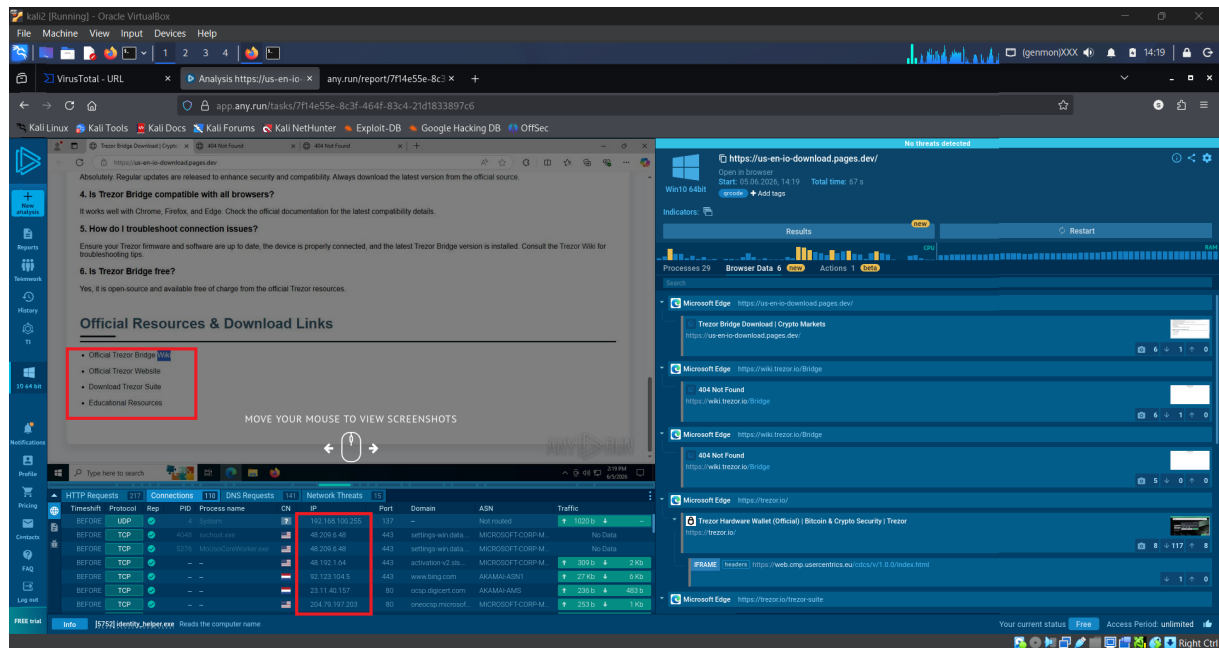


Figure 36: Link 7 — ANY.RUN

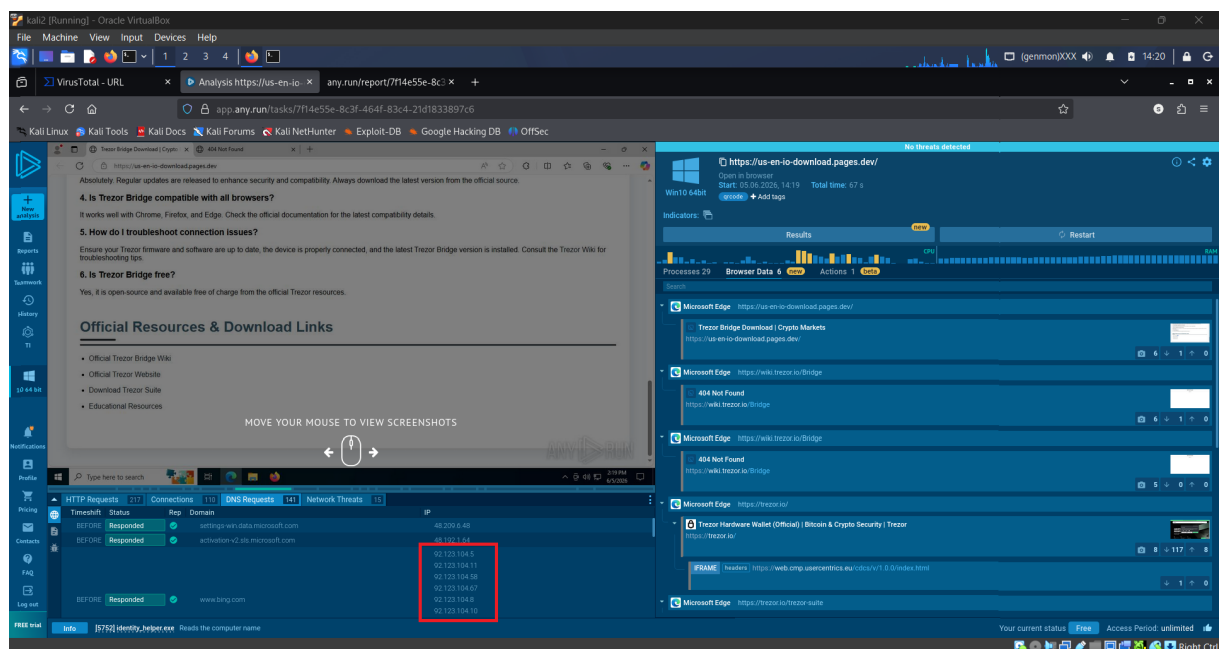


Figure 37: Link 7 — ANY.RUN DNS

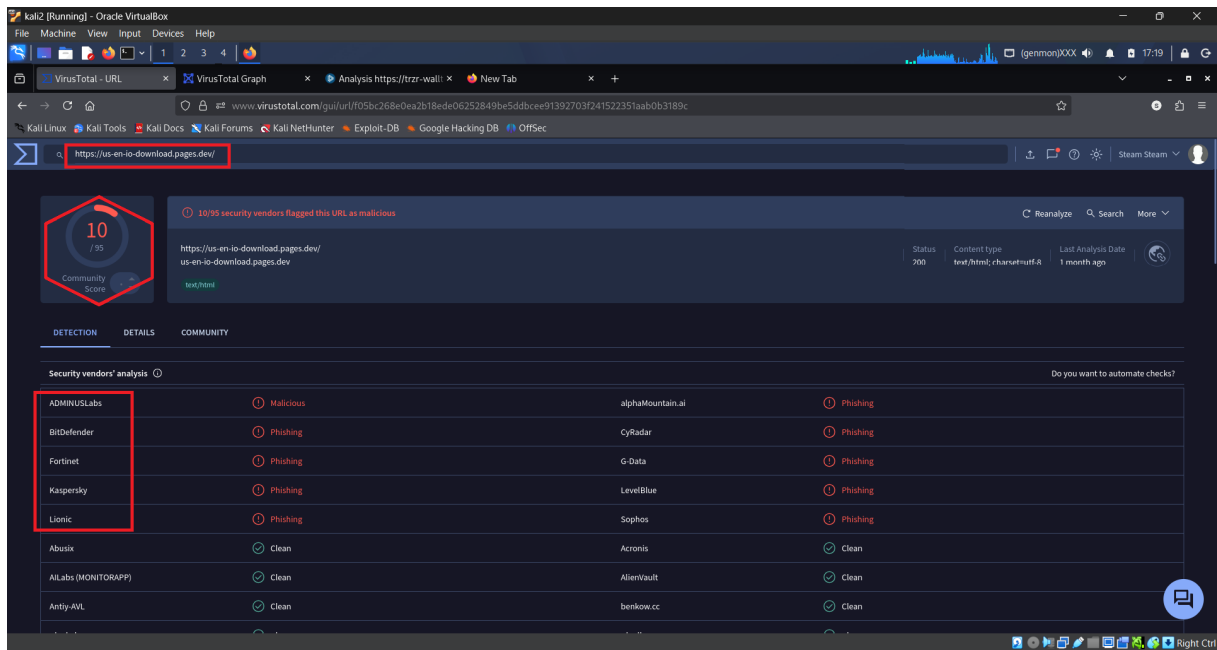


Figure 38: Link 7 — VirusTotal

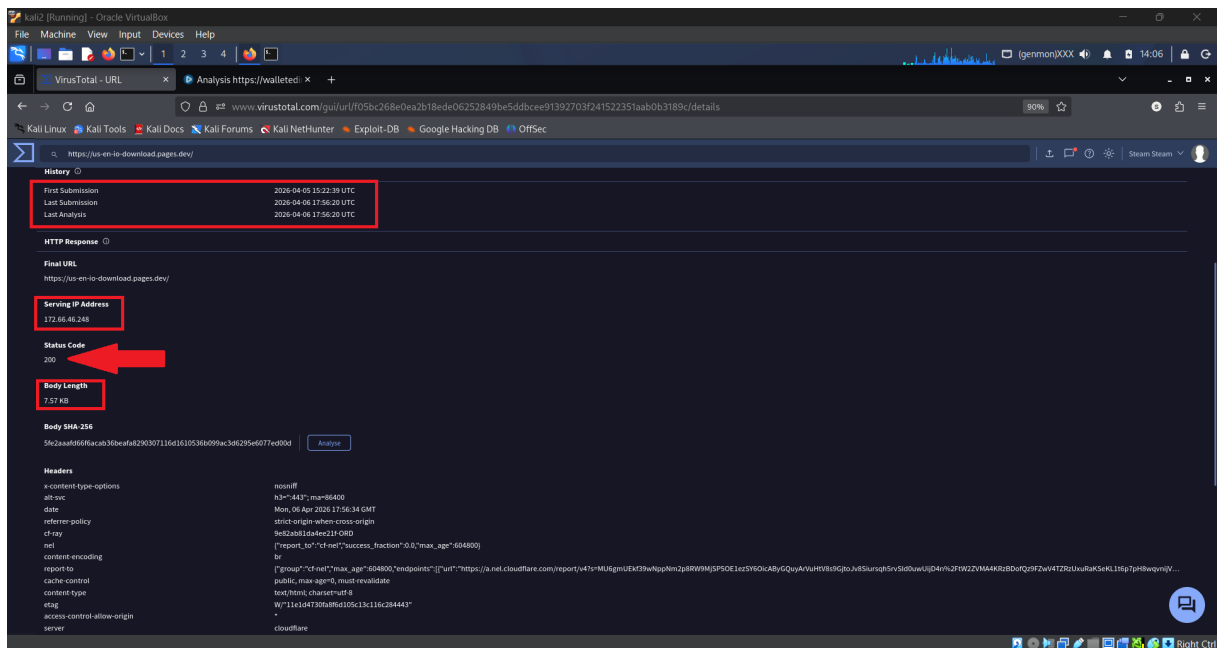


Figure 39: Link 7 — VirusTotal details

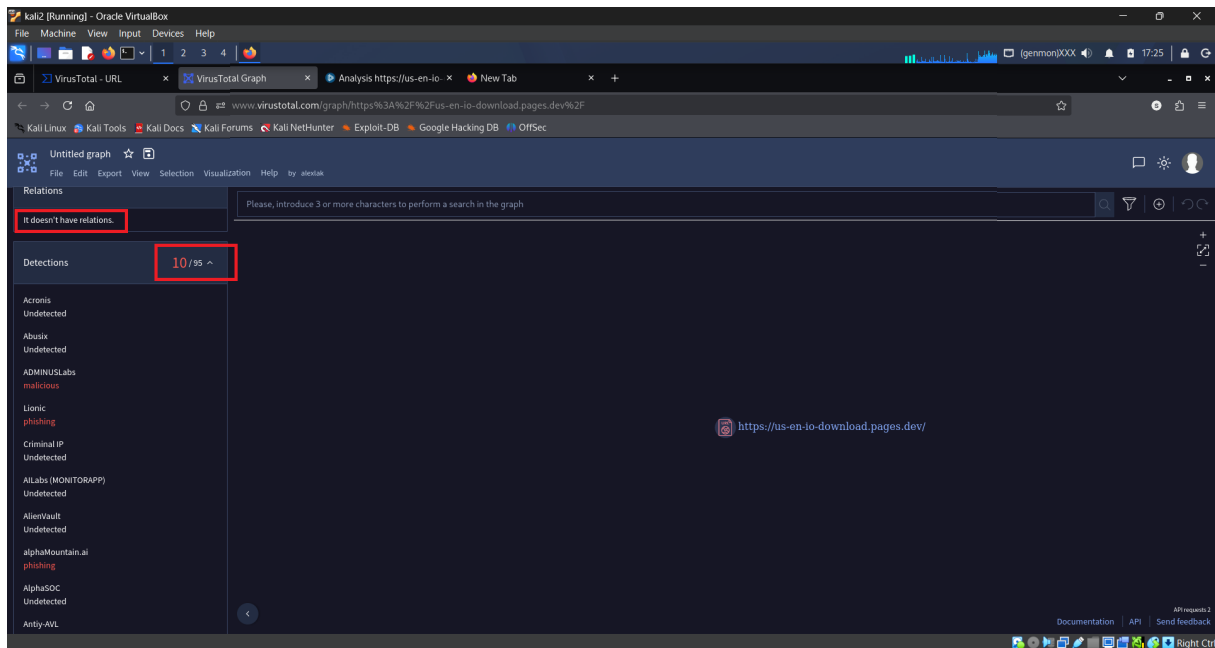


Figure 40: Link 7 — VirusTotal Graph

5.3.3 Link 9 — en-uphuuld-walet-us.pages.dev

VirusTotal flags **9/95** (ADMINUSLabs *Malicious*, BitDefender, G-Data, Sophos, Gridinsoft and Fortinet), with Forcepoint categorising it as *phishing and fraud*.

In ANY.RUN the origin returns **HTTP 451** and the run surfaces **9 network threats**.

Served from 172[.]66[.]44[.]232 (Cloudflare), 200 OK at VT capture, 7.16 KB; first seen 2026-04-05; VT Graph 7/95, no relations.

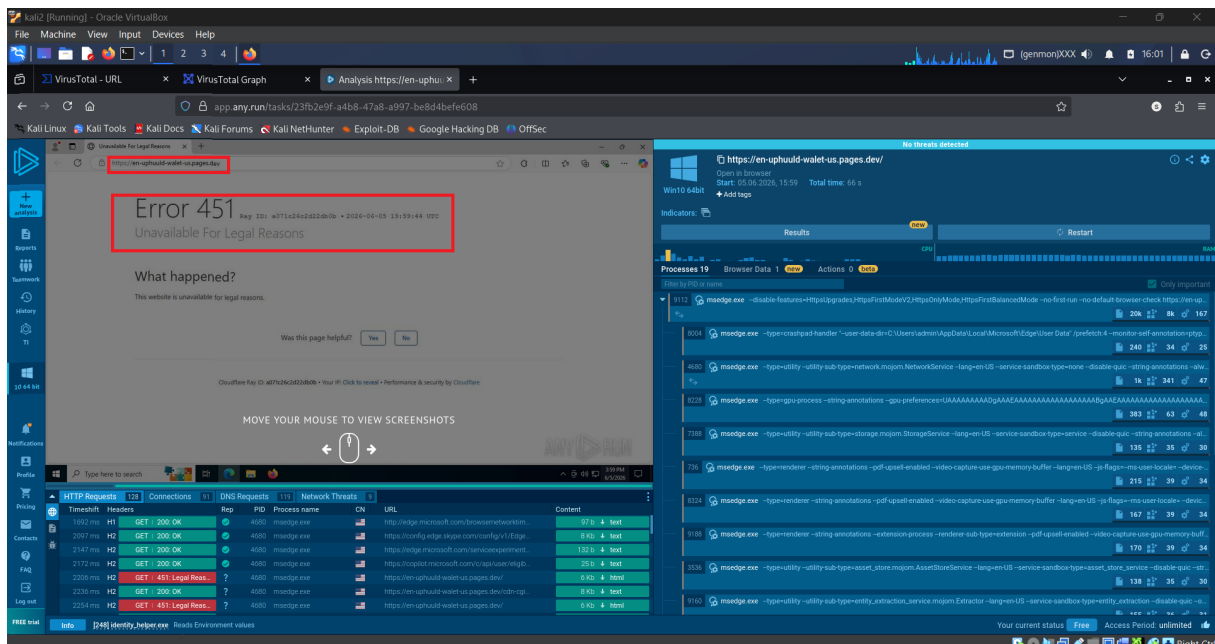


Figure 41: Link 9 — ANY.RUN

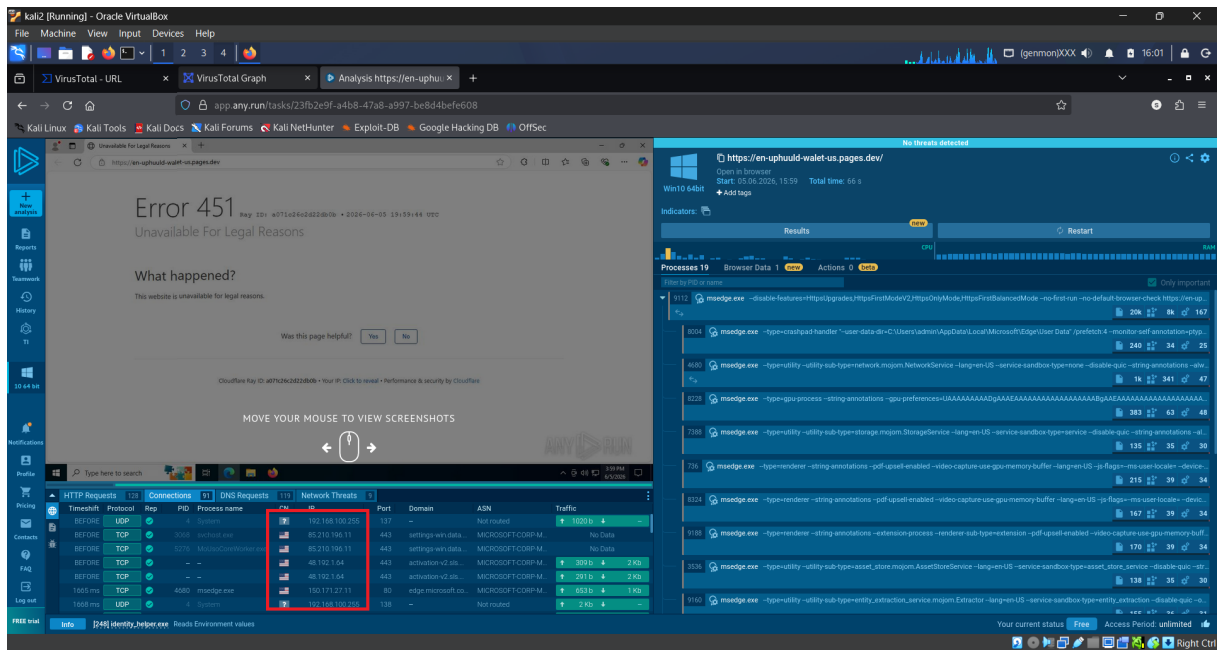


Figure 42: Link 9 — ANY.RUN connections

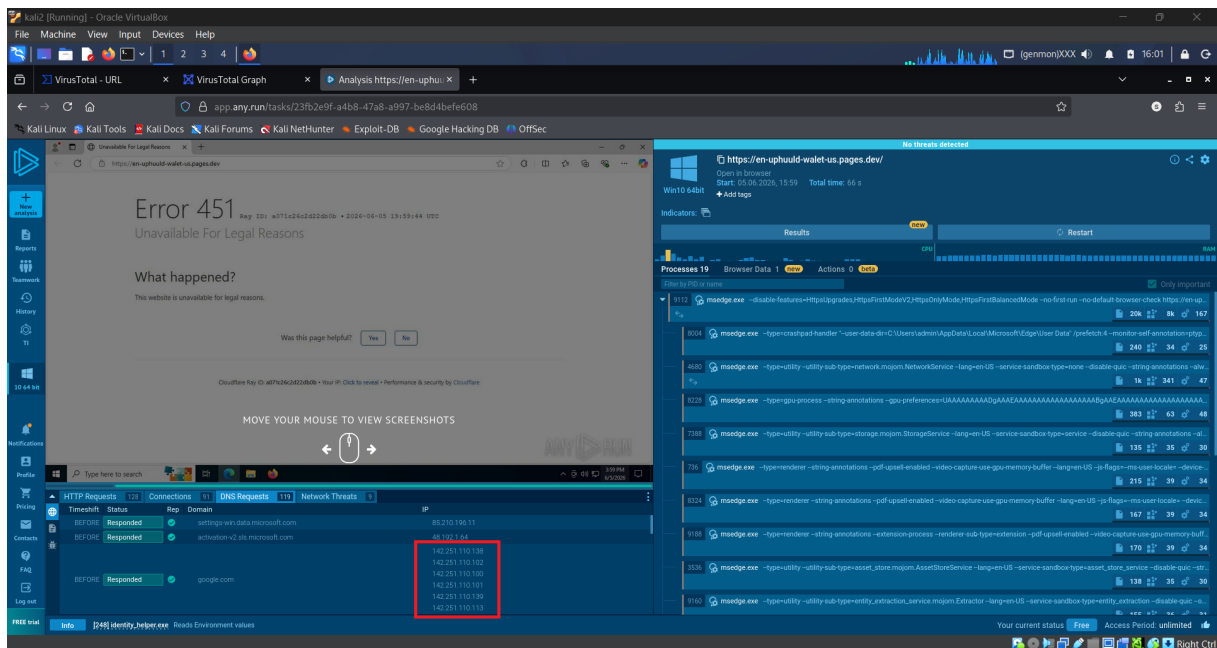


Figure 43: Link 9 — ANY.RUN DNS

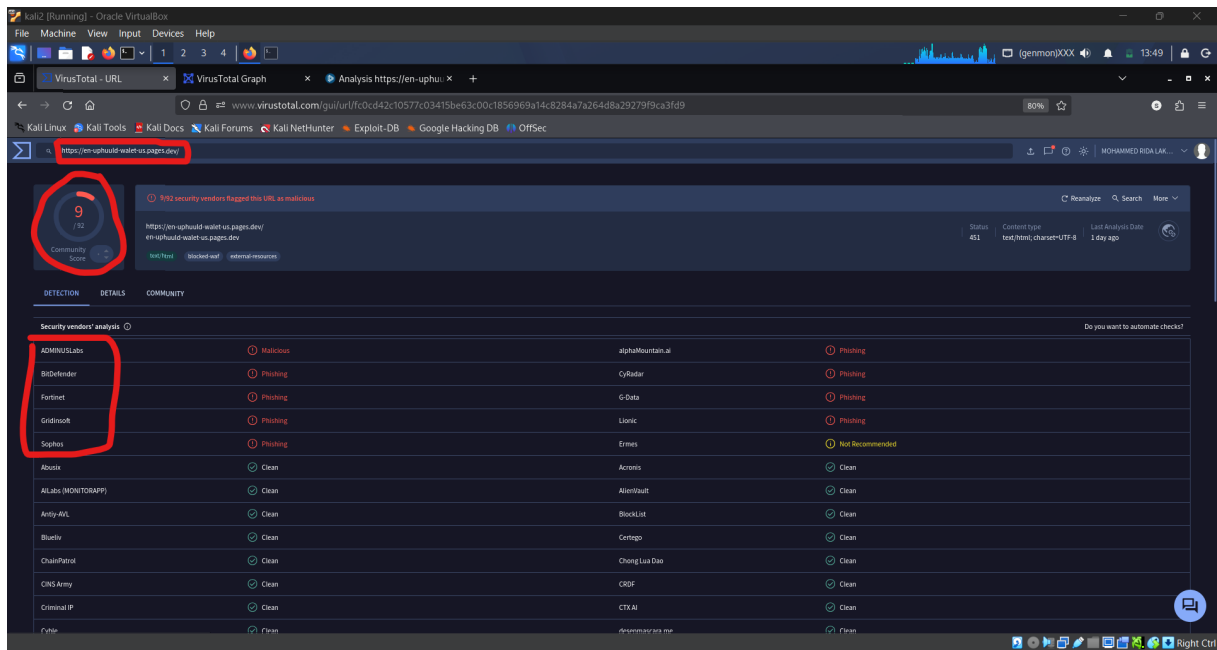


Figure 44: Link 9 — VirusTotal

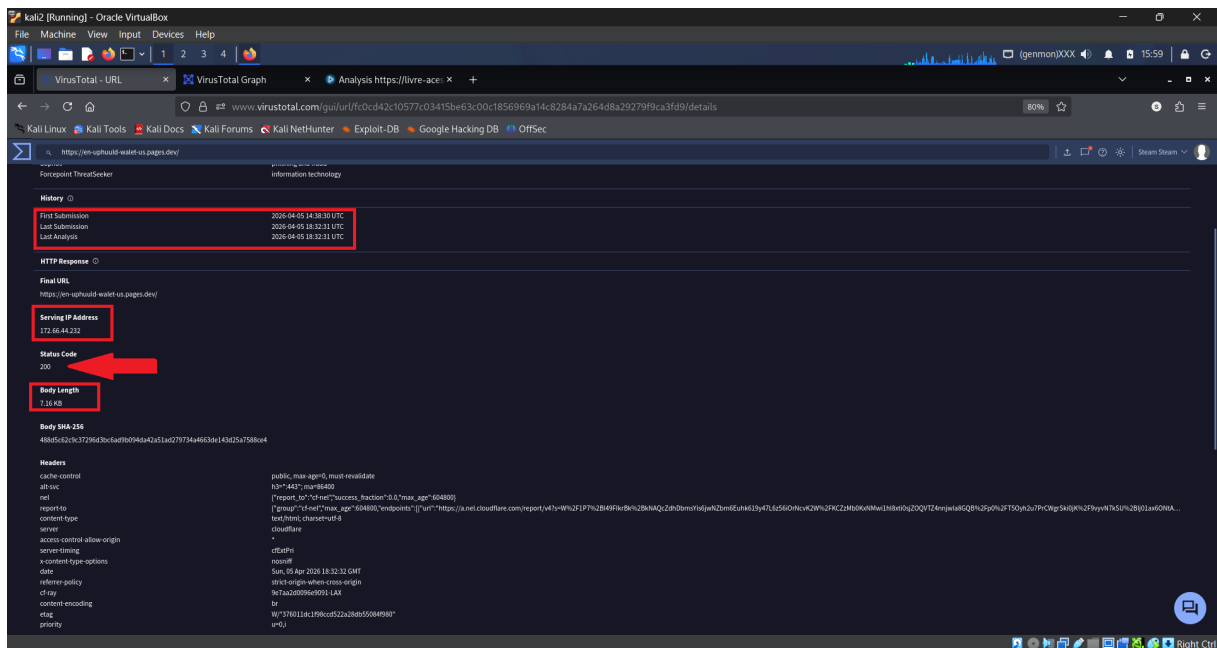


Figure 45: Link 9 — VirusTotal details

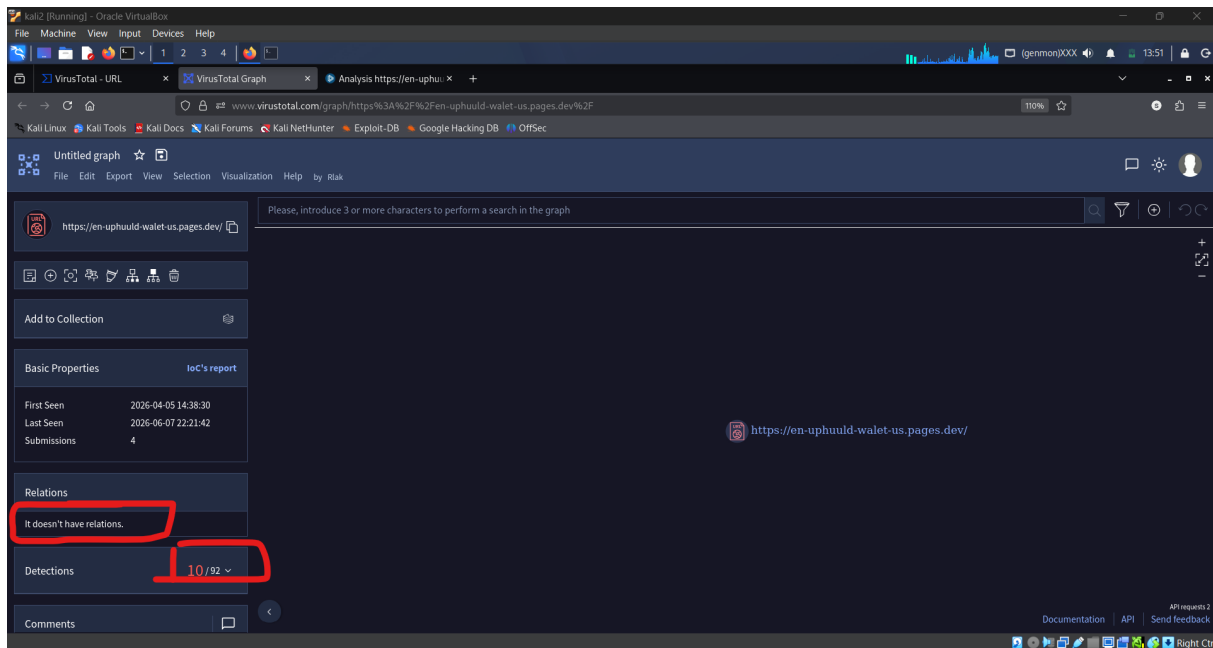


Figure 46: Link 9 — VirusTotal Graph

5.3.4 Key Takeaways — Category B

- **Take-down is uneven** Cloudflare's anti-phishing has already gated link 5 (403 / Suspected Phishing), while link 7 was still fully live and convincing.
- **Irreversible impact** seedphrase entry or a trojanised Bridge installer means total, unrecoverable crypto loss.
- **Modest detection (6–10/95)** fresh infrastructure; block the *.pages.dev typosquat patterns and brand-keyword combinations rather than relying on reputation scores.

6 Category C — IoT Botnet C2 & Malware Delivery

6.1 Primary Distribution / C2 Servers

Server	Path scheme	Architecture binaries observed
45[.]156[.]87[.]253	/main_*	main_arm, main_arm5, main_arm6, main_arm7, main_m68k, main_mips, main_mpsl, main_ppc, main_sh4, main_x86, main_x86_64
185[.]208[.]159[.]132	/<arch>	arm, arm5, arm6, arm7, harm5, harm6, harm7, hmips, mips, mpsl
38[.]60[.]216[.]39	/bins/*	arm4, mips, mpsl, ppc, sh4

The architecture set (arm/arm4/arm5/arm6/arm7, mips/mpsl, sh4, ppc, m68k, x86/x86_64) and the main_, /bins/ and h-prefixed naming conventions are signatures of the Mirai/Gafgyt lineage. Delivery is plain **HTTP only** (no TLS), in deliberate contrast to Categories A and B.

6.2 Loader / Infected-Bot Hosts

Approximately 47 distinct IPs serve a two-stage loader: a `/bin.sh` shell script that detects the device architecture and pulls the matching binary, plus a `/i` infection endpoint. Many fall in network ranges allocated to Asian and regional consumer ISPs, consistent with hijacked routers/DVRs/IoT devices. The full list is in the IOC appendix (Table 3).

6.3 Analysis

Five Category C endpoints were taken through the full workflow: two architecture-specific Mirai/Gafgyt binaries (links 17 & 24) and three loader / payload endpoints (links 58, 41 & 69). The two binary hosts were **dormant** (the browser connection timed out) when detonated, whereas the loader endpoints were live on VirusTotal: 222[.]127[.]71[.]141 and 114[.]239[.]199[.]122 each served an identically-sized **300.74 KB** packed ELF (`application/zip`, `nginx`) strong evidence that the **same payload is redistributed across multiple bots** and both are attributed by Cluster25 to **MIRAI / MOZI**. Link 69 (110[.]39[.]239[.]111) is a confirmed MOZI bot that returned a small `image/png` loader response at capture. Detonating the loader endpoints in the ANY.RUN browser still timed out, because `/i` hands back a raw binary/loader rather than a render-able page and the hosts are reachable only intermittently between campaigns.

6.4 Category C — Evidence Summary

	Link 17	Link 24	Link 58
Endpoint	45[.]156[.]87[.]253/ <code>main_mpsl</code>	185[.]208[.]159[.]132/ <code>mpsl</code>	222[.]127[.]71[.]141: 56631/ <code>i</code>
Role	Mirai/Gafgyt MIPSEL binary	Mirai/Gafgyt MIPSEL binary	Mirai/Mozi loader payload
VT detections	5/95	13/95	14/95
Threat-intel	Guardpot: Telnet brute-force (IoT)	Forcepoint: malicious web sites	Cluster25: MIRAI, MOZI
Served at analysis	Timed out (host dormant)	Timed out (host dormant)	HTTP 200, <code>application/zip</code> , 300.74 KB ELF, <code>nginx</code>
Port	80	80	56631 (non-standard)
Serving IP	45[.]156[.]87[.]253	185[.]208[.]159[.]132	222[.]127[.]71[.]141
VT first seen	2026-04-05	2026-04-05	2026-04-05
VT Graph	9/95	16/95	16/95
Verdict	BOTNET	BOTNET	BOTNET

	Link 41	Link 69
Endpoint	114[.]239[.]199[.]122:59871/i	110[.]39[.]239[.]111:52560/i
Role	Mirai/Mozi loader payload (live ELF)	Mirai/Mozi loader endpoint (live)
VT detections	14/95	17/95
Threat-intel	Cluster25: MIRAI, MOZI	Cluster25: MOZI
Served at analysis	HTTP 200, application/zip, 300.74 KB ELF (Content-Length 307960), nginx	HTTP 200, image/png, 4.65 KB loader response
Body SHA-256	12013662...d4b0ef	e4222715...d561f2
Sandbox (ANY.RUN)	Browser timed out (ERR_CONNECTION_TIMED_OUT); 1 network threat	Browser timed out (ERR_CONNECTION_TIMED_OUT); 1 network threat
Port	59871 (non-standard)	52560 (non-standard)
Serving IP	114[.]239[.]199[.]122	110[.]39[.]239[.]111
VT first seen	2026-04-05	2026-04-05
VT Graph	16/95	19/95
Verdict	BOTNET	BOTNET

6.4.1 Link 17 — 45.156.87.253/main_mpsl

VirusTotal flags **5/95** (Fortinet, G-Data and Kaspersky *Malware*, GreyNoise and SOCRadar *Malicious*, alphaMountain, AlphaSOC, Gridinsoft and Guardpot *Suspicious*) with a community score of -11 .

Crucially, the crowd-sourced context shows Guardpot observing this IP conducting **Telnet brute-force login attempts** (the classic Mirai/IoT spread vector), first seen 2026-04-02.

In ANY.RUN the endpoint simply times out, the host was dormant between campaigns so only sandbox/Microsoft background traffic appears.

First VT submission 2026-04-05; VT Graph 9/95, no relations.

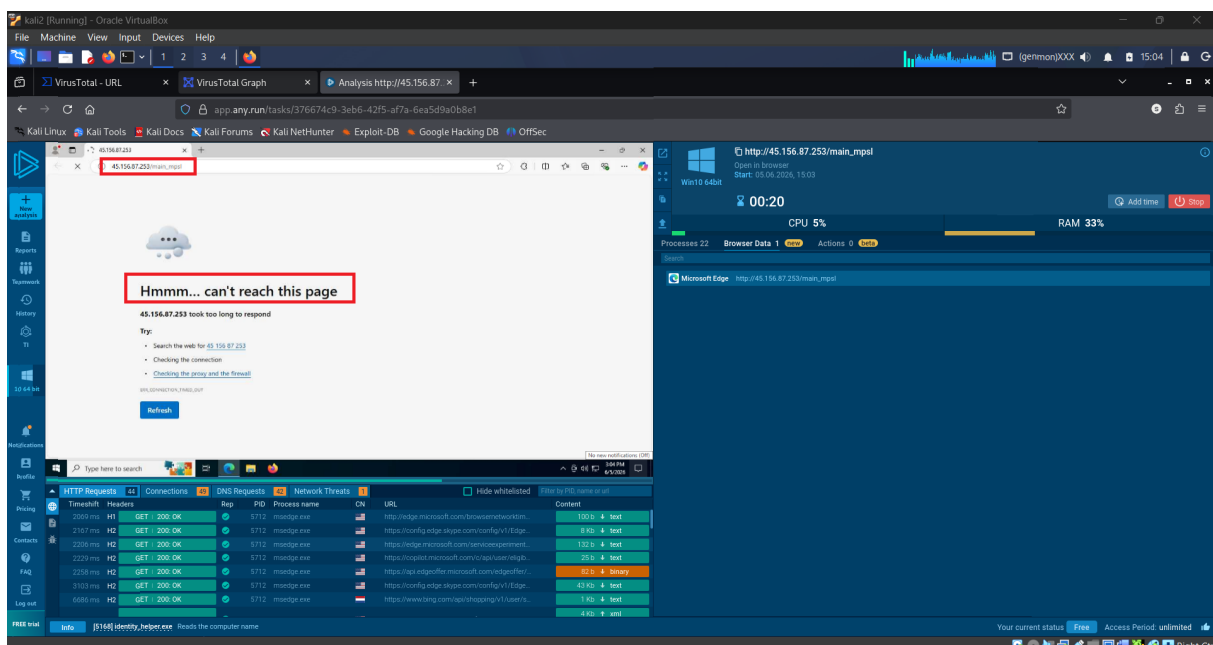


Figure 47: Link 17 — ANY.RUN

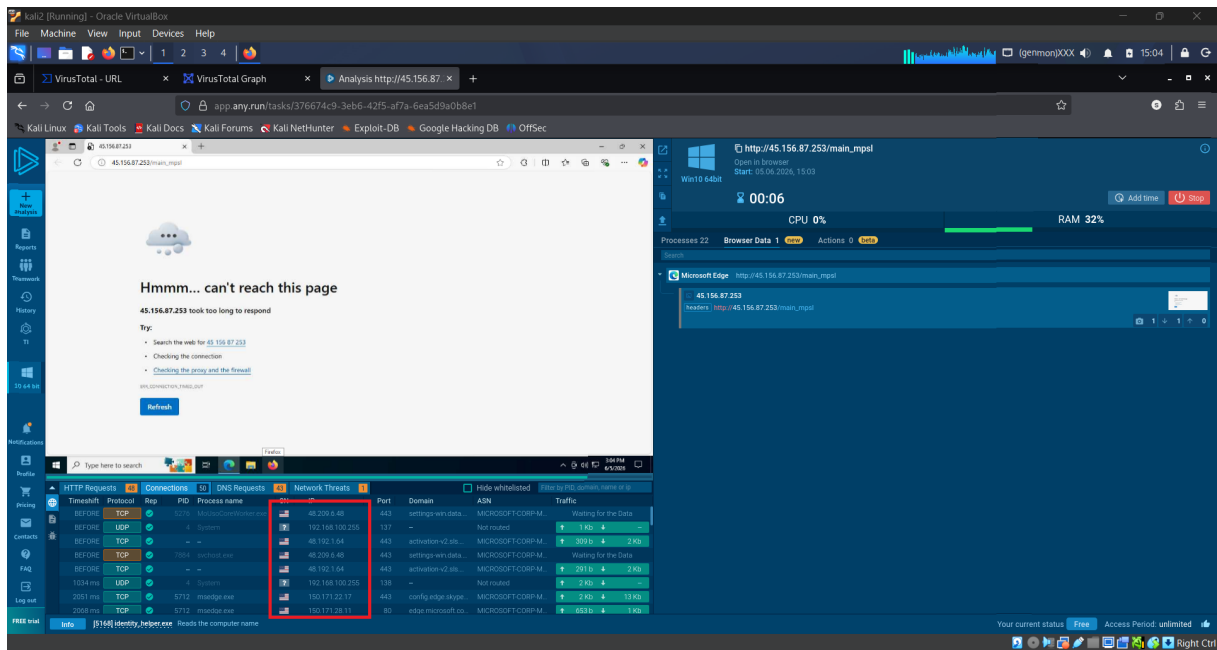


Figure 48: Link 17 — ANY.RUN connections

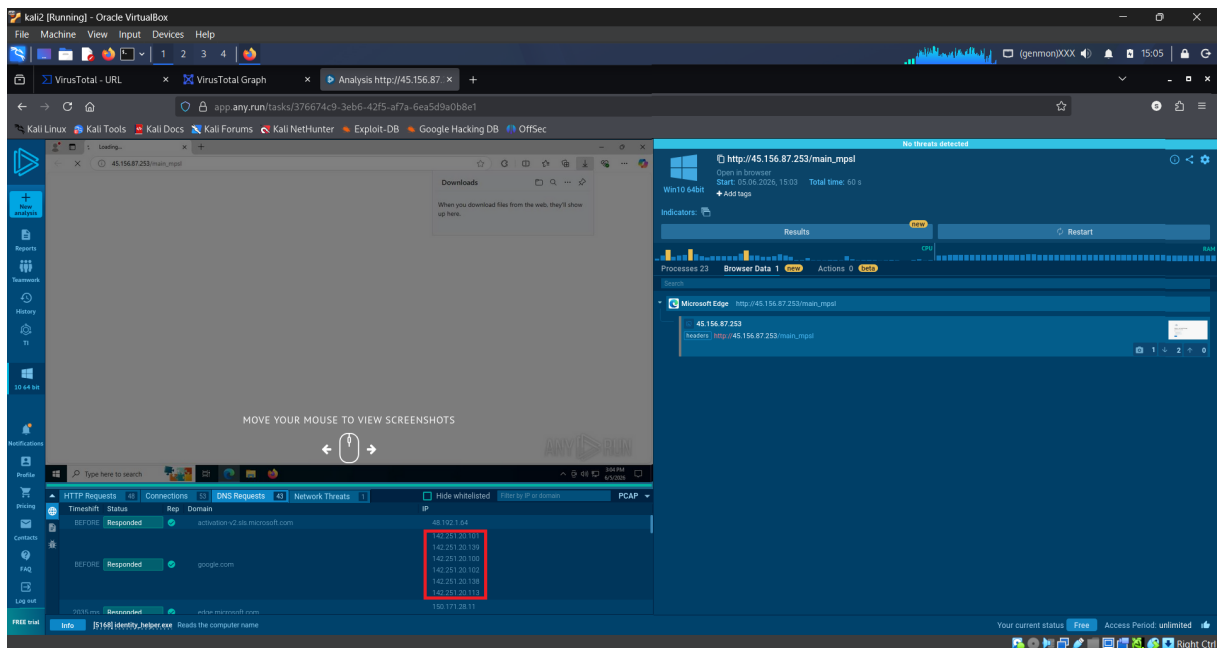


Figure 49: Link 17 — ANY.RUN DNS

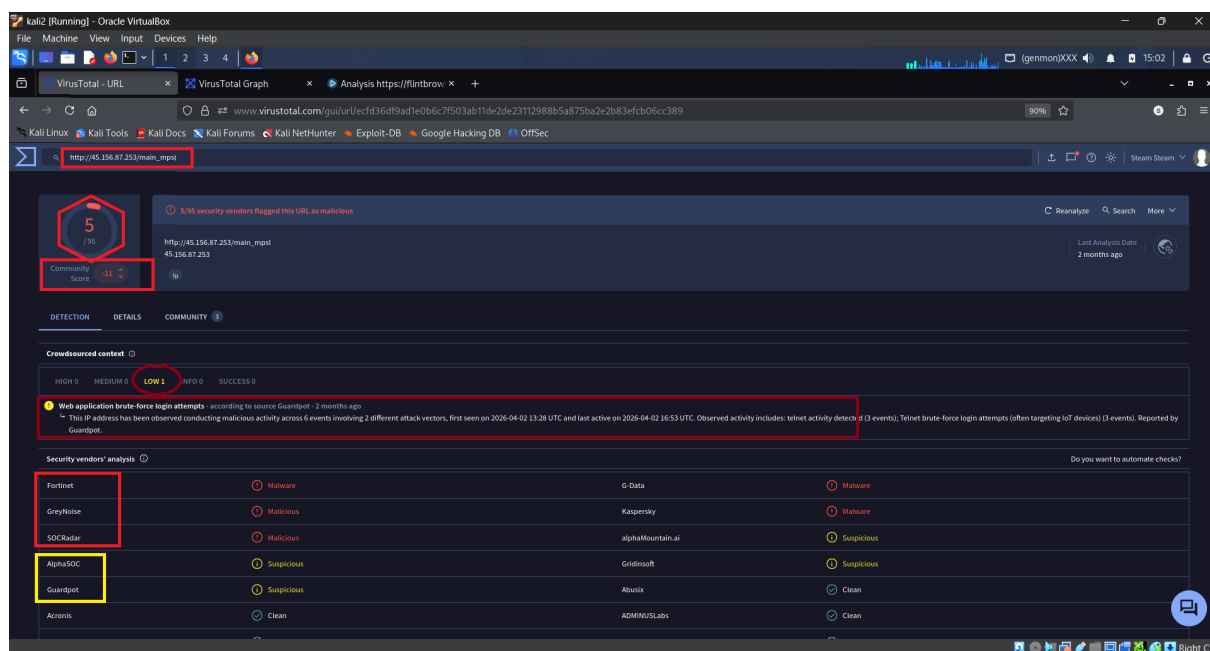


Figure 50: Link 17 — VirusTotal

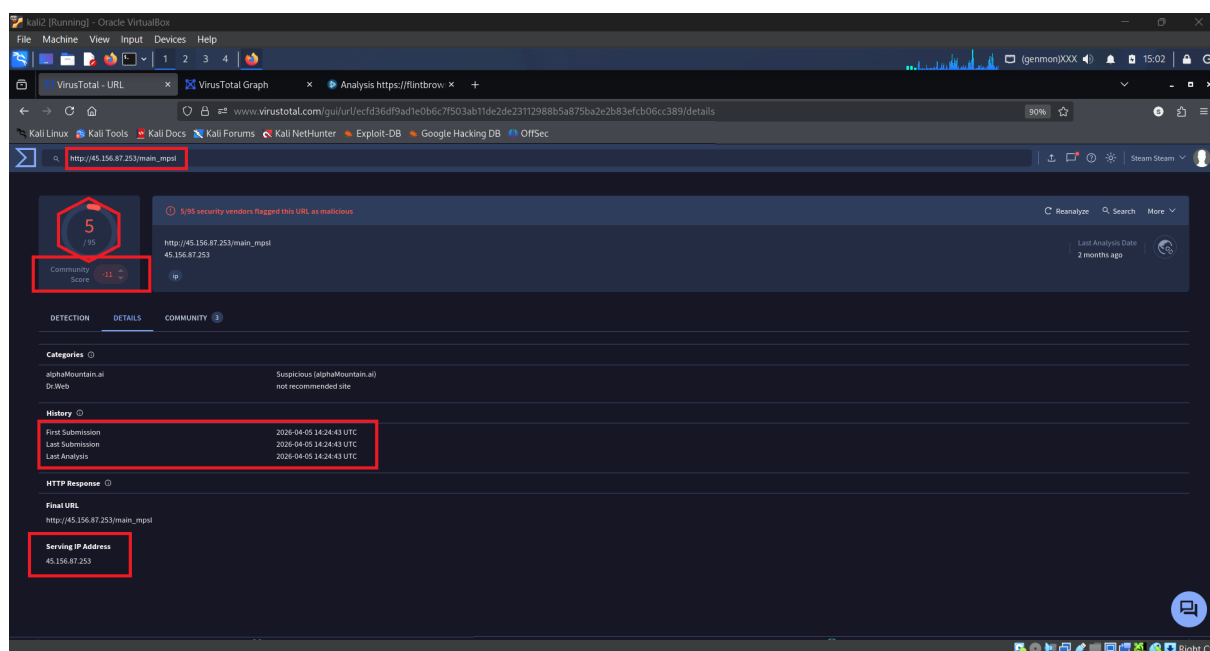


Figure 51: Link 17 — VirusTotal details

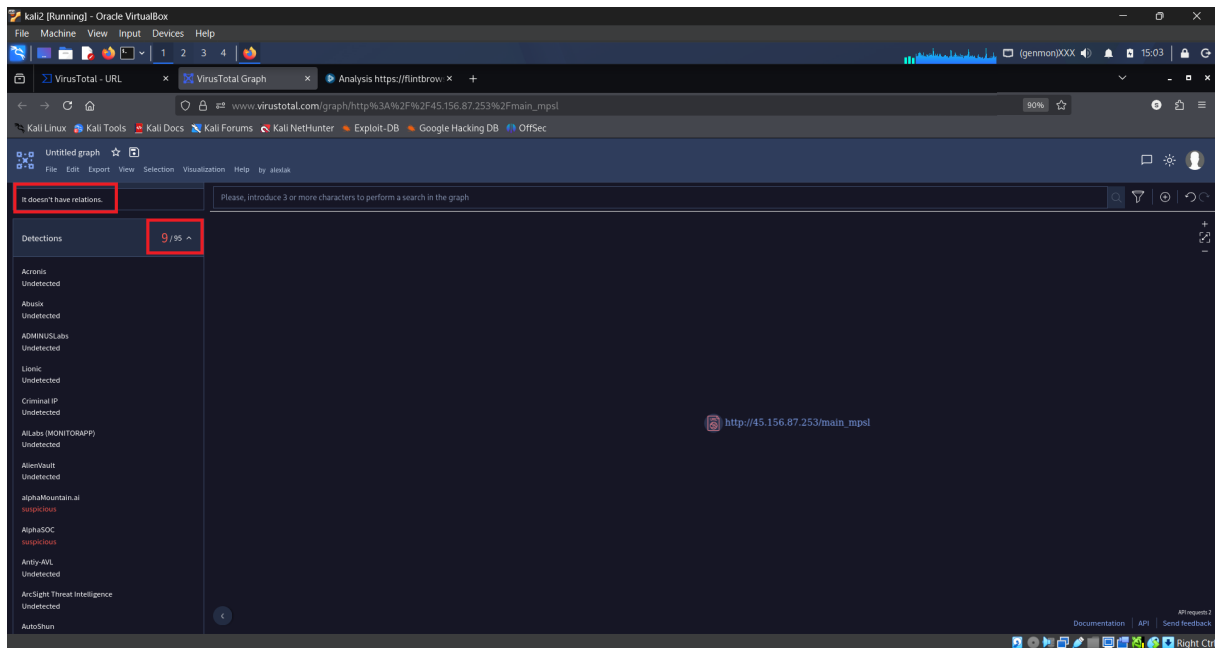


Figure 52: Link 17 — VirusTotal Graph

6.4.2 Link 24 — 185.208.159.132/mpsl

It is more widely flagged VirusTotal **13/95** (BitDefender, Fortinet, G-Data, MalwareURL and SOCRadar *Malware*; alphaMountain, Chong Lua Dao, CRDF, CyRadar, Lionic, Cluster25, Criminal IP and Forcepoint *Malicious*), with Forcepoint categorising it as *malicious web sites*. Like link 17 the host had timed out by analysis time.

First VT submission 2026-04-05; VT Graph 16/95, no relations.

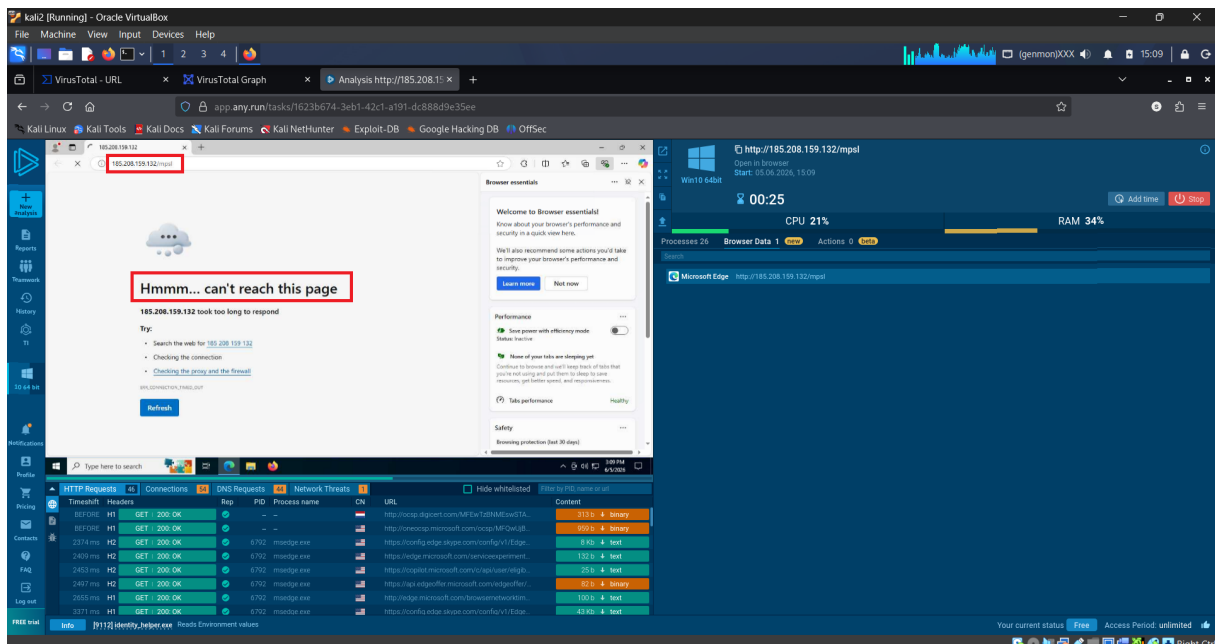


Figure 53: Link 24 — ANY.RUN

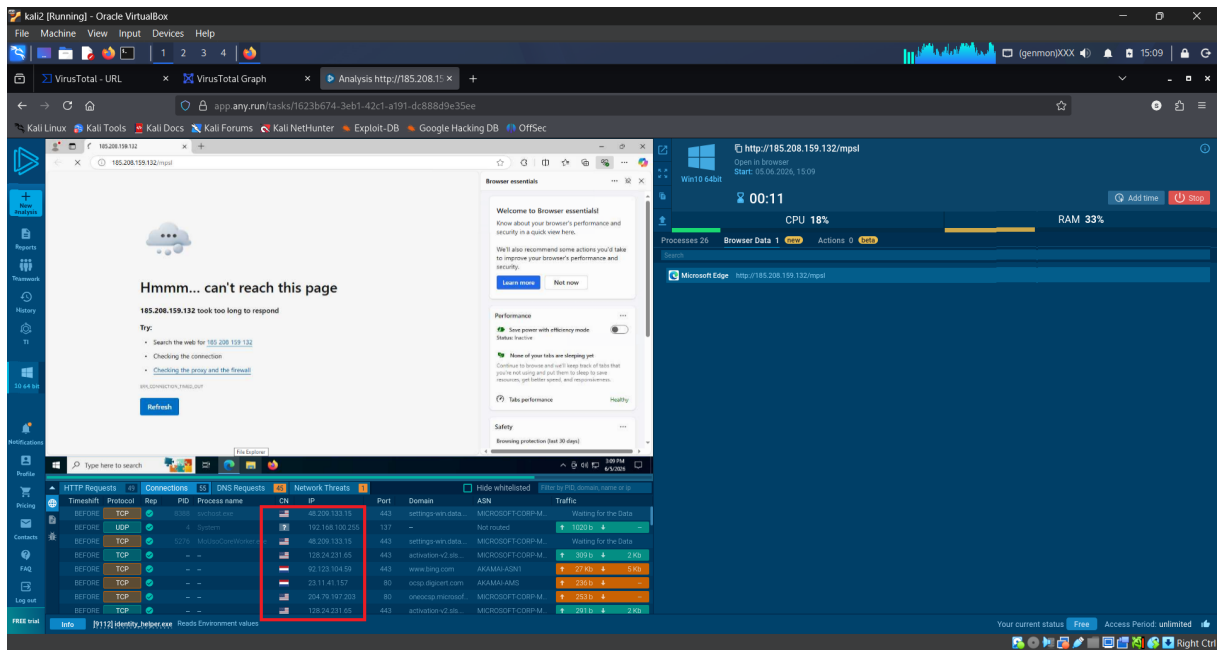


Figure 54: Link 24 — ANY.RUN connections

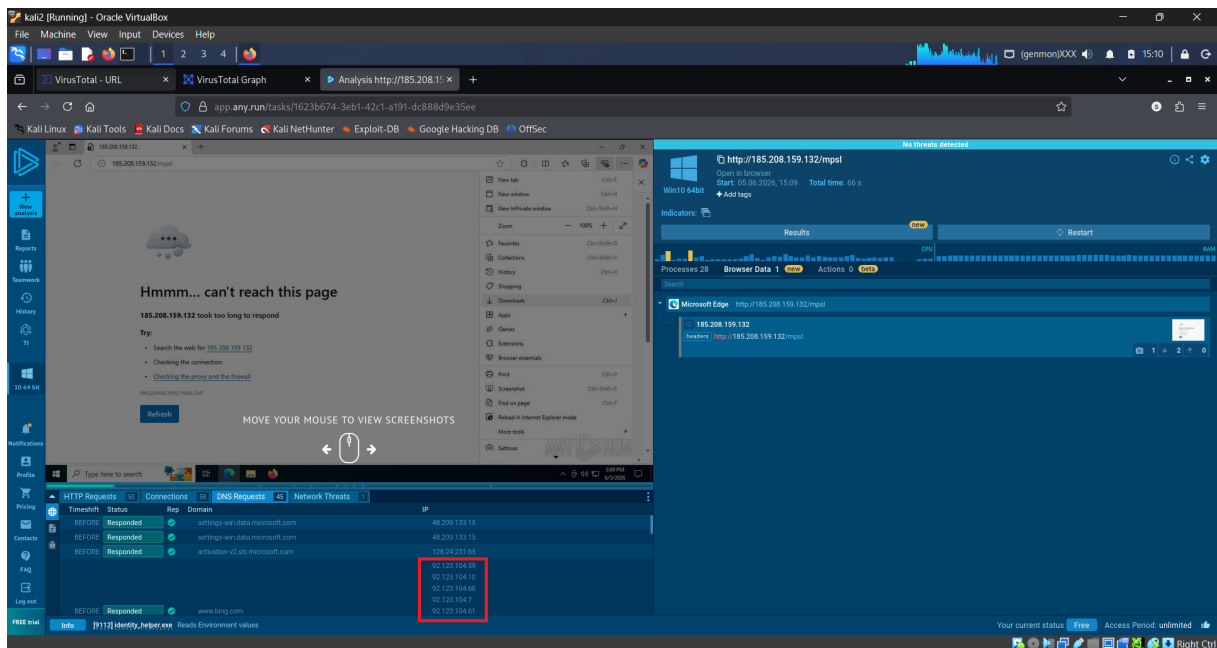


Figure 55: Link 24 — ANY.RUN DNS

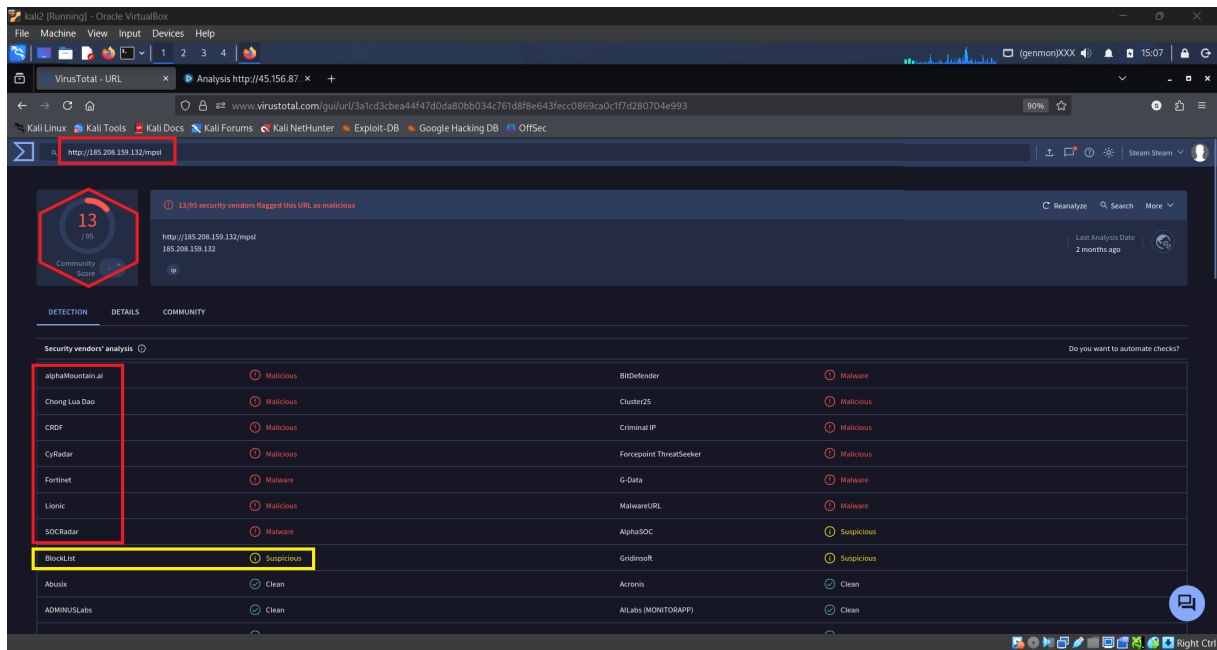


Figure 56: Link 24 — VirusTotal

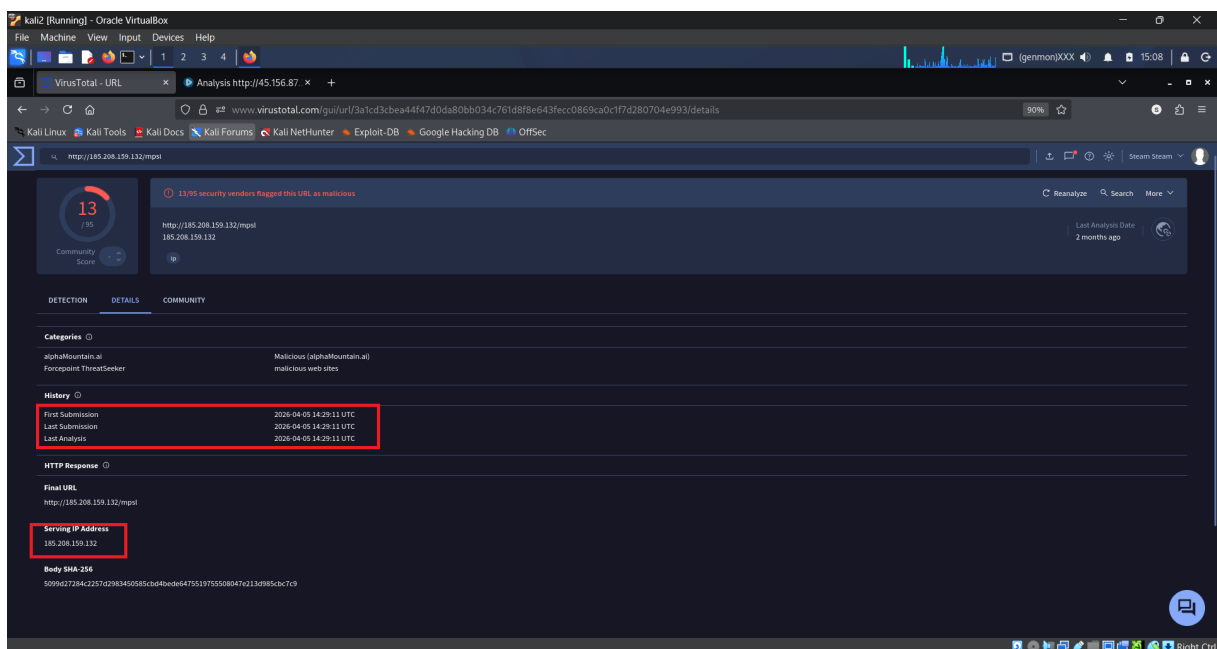


Figure 57: Link 24 — VirusTotal details

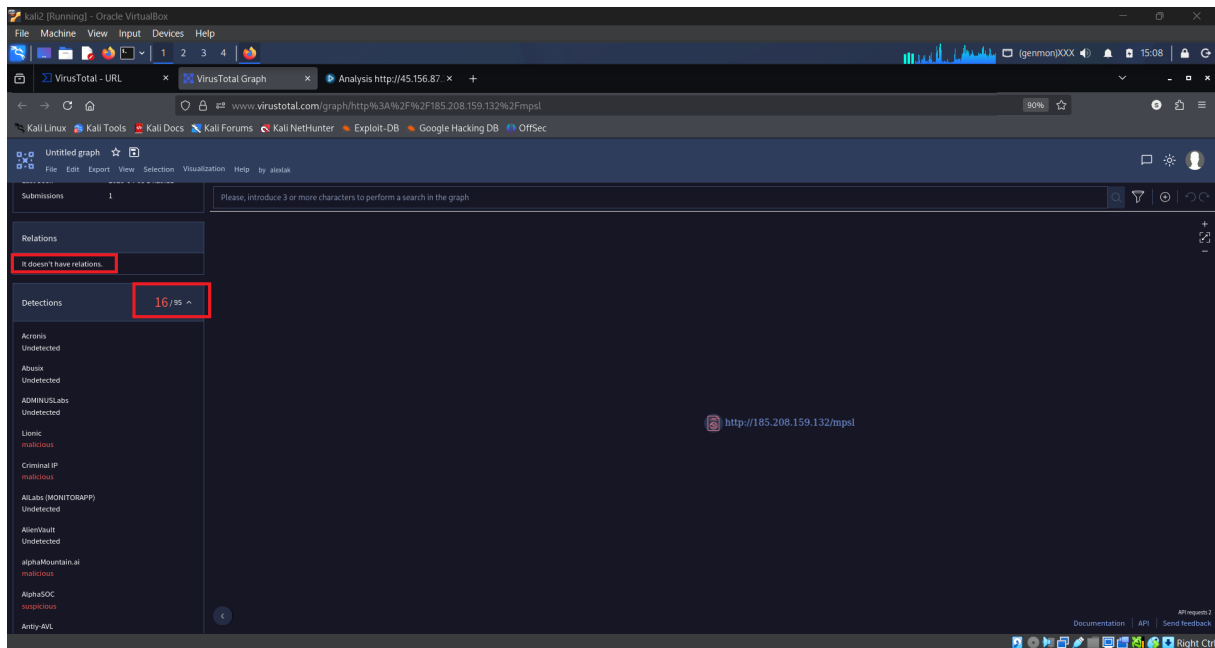


Figure 58: Link 24 — VirusTotal Graph

6.4.3 Link 58 — 222.127.71.141:56631/i (live Mirai/Mozi payload)

222[.]127[.]71[.]141:56631/i returns **HTTP 200** with Content-Type: `application/zip` and a **300.74 KB** body (a packed ELF), served by `nginx` on the non-standard port **56631**. VirusTotal flags **14/95** (ADMINUSLabs, Cluster25, Dr.Web and GreyNoise *Malicious*; BitDefender, CyRadar, Emsisoft, ESET, Fortinet, G-Data, SOCRadar and Sophos *Malware*) and tags it `application/zip`, `downloads elf` and `non-standard port`. First VT submission 2026-04-05, VT Graph 16/95, no relations.

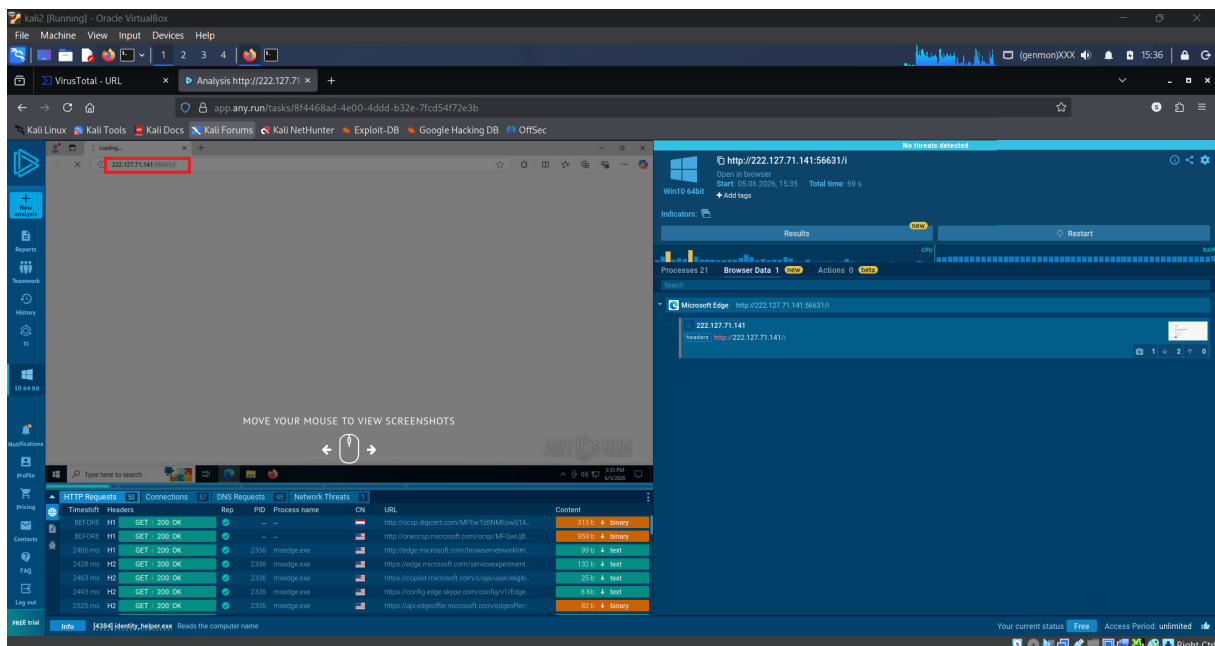


Figure 59: Link 58 — ANY.RUN

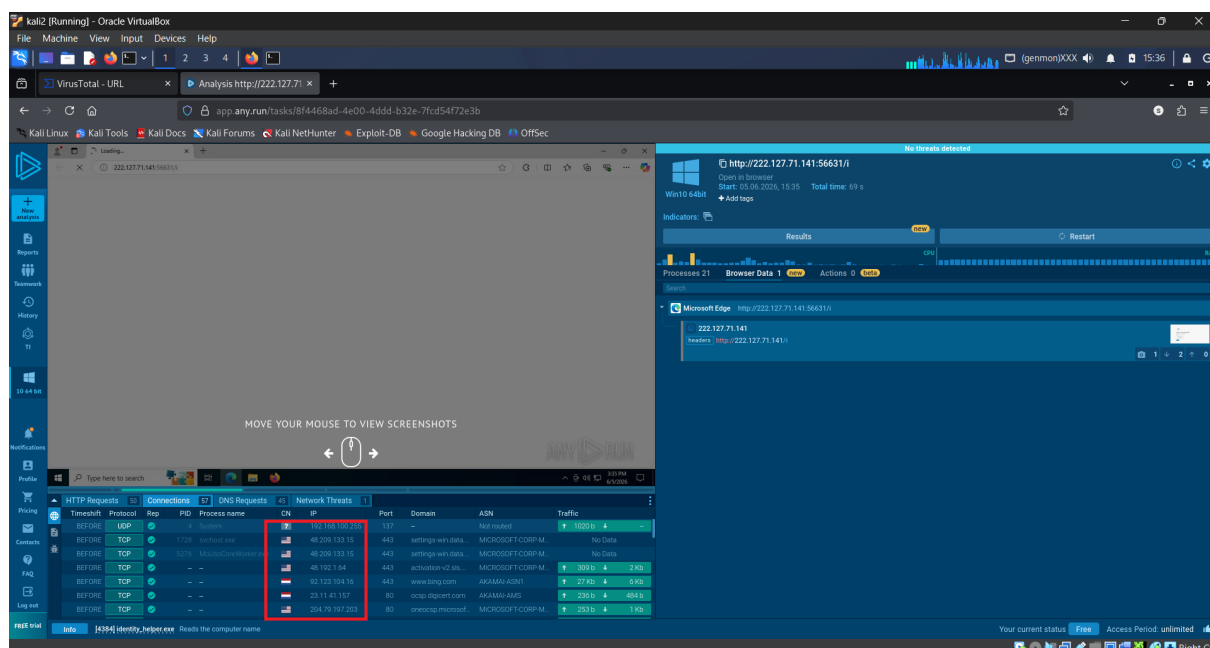


Figure 60: Link 58 — ANY.RUN connections

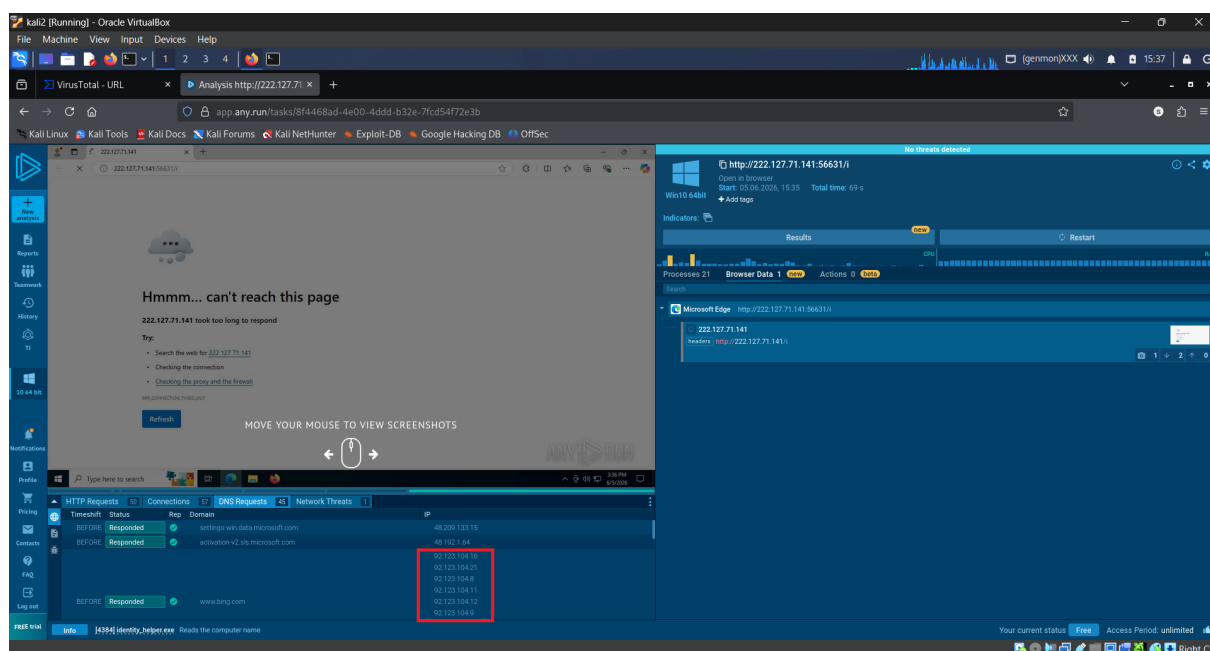


Figure 61: Link 58 — ANY.RUN DNS

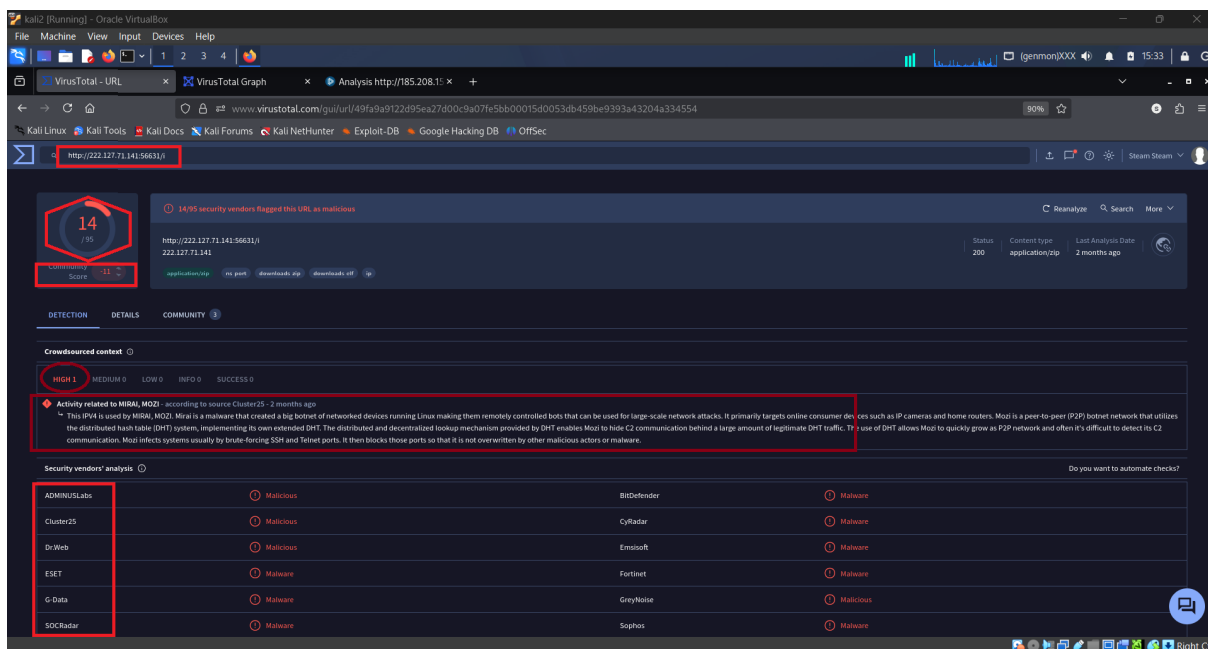


Figure 62: Link 58 — VirusTotal

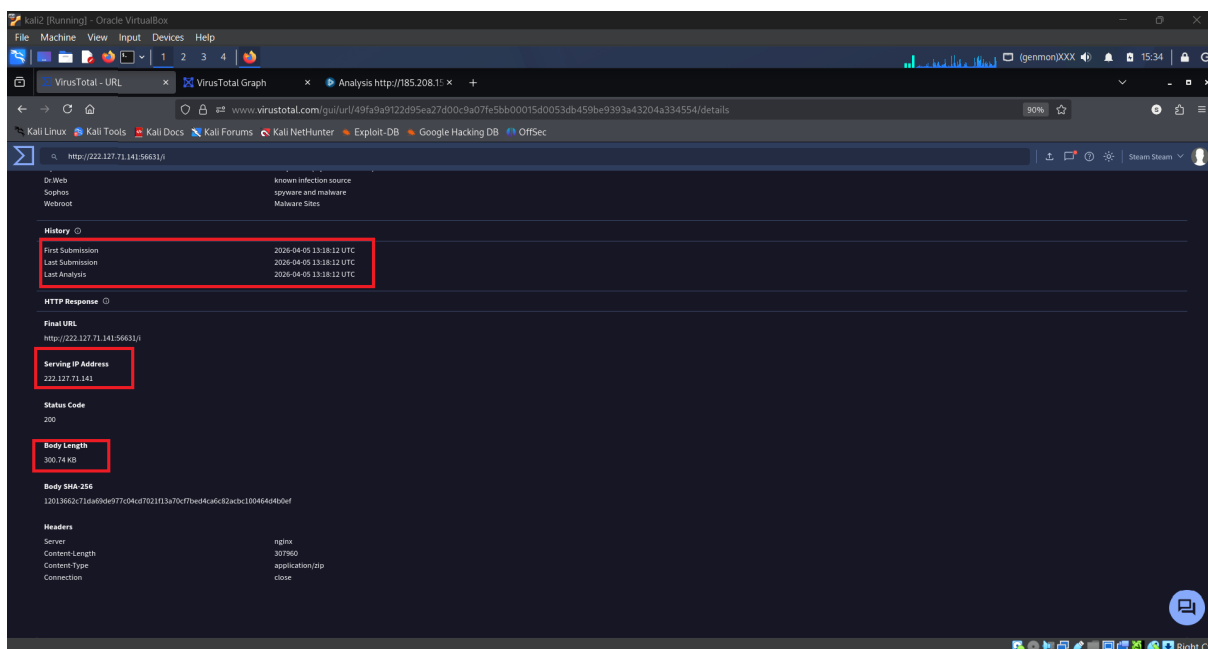


Figure 63: Link 58 — VirusTotal details

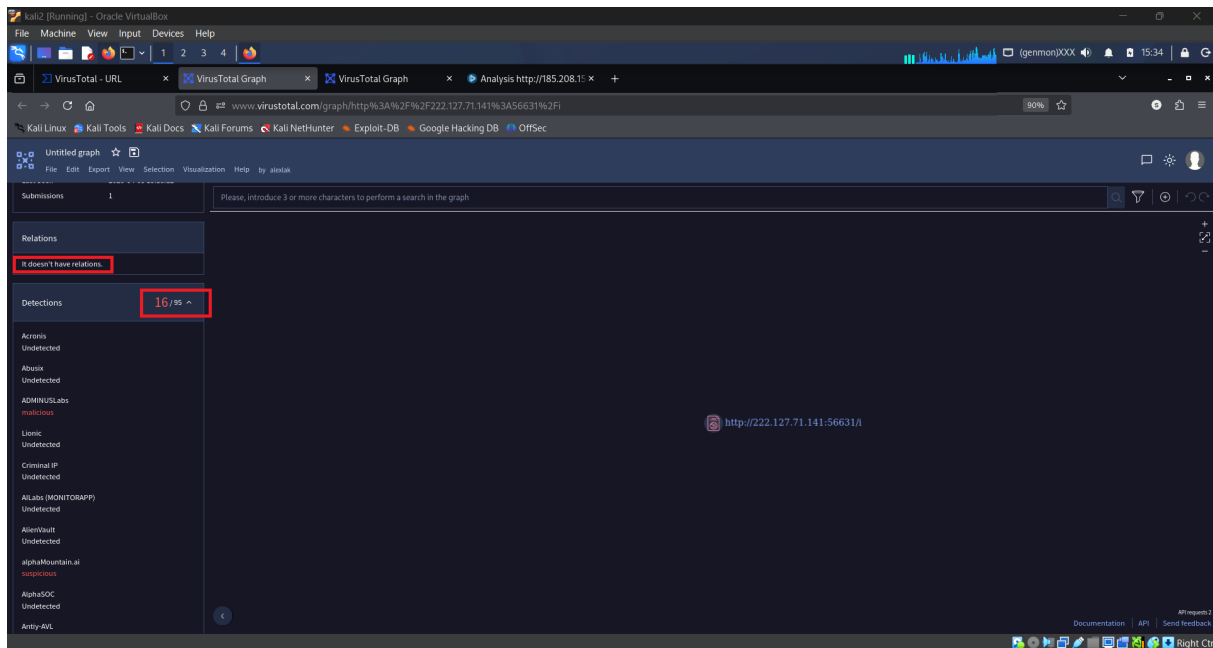


Figure 64: Link 58 — VirusTotal Graph

6.4.4 Link 41 — 114.239.199.122:59871/i

At VirusTotal capture it returned **HTTP 200** with Content-Type: `application/zip` and a **300.74 KB** body, served by `nginx` on the non-standard port **59871**.

VirusTotal flags **14/95** (ADMINUSLabs, AILabs/MONITORAPP, Cluster25, Netcraft and URLhaus *Malicious*, BitDefender, CyRadar, Emsisoft, ESET, Fortinet, G-Data and Lionic *Malware*) with a community score of `-11` and the tags `application/zip`, `downloads-zip`, `downloads-elf`, `ip` and `ns-port`.

In the ANY.RUN browser the endpoint timed out (`ERR_CONNECTION_TIMED_OUT`) with one network threat surfaced consistent with a loader path that returns a raw binary and a host that is only intermittently reachable.

First/last VT submission 2026-04-05; VT Graph 16/95, no relations.

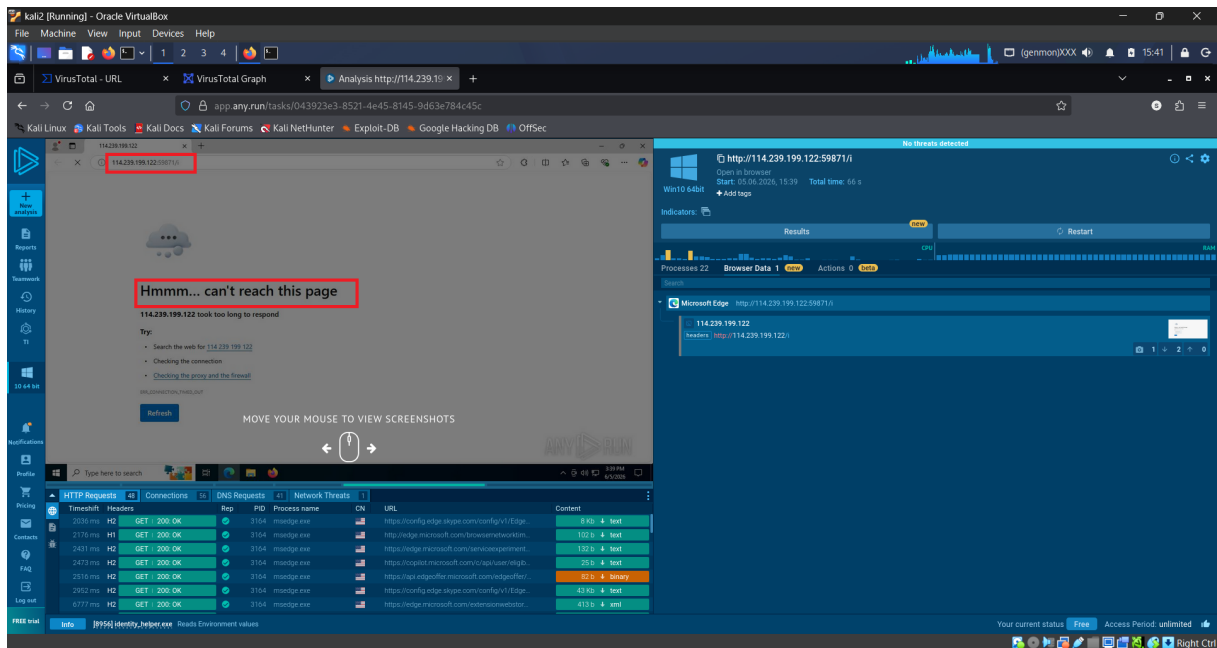


Figure 65: Link 41 — ANY.RUN

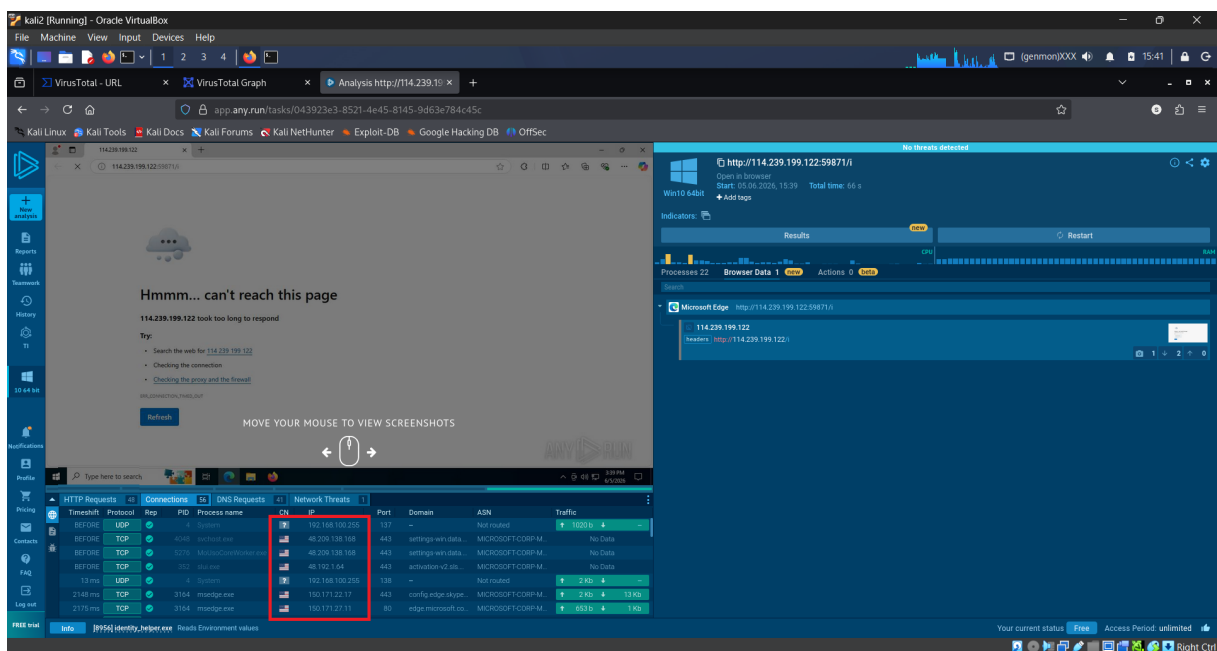


Figure 66: Link 41 — ANY.RUN connections

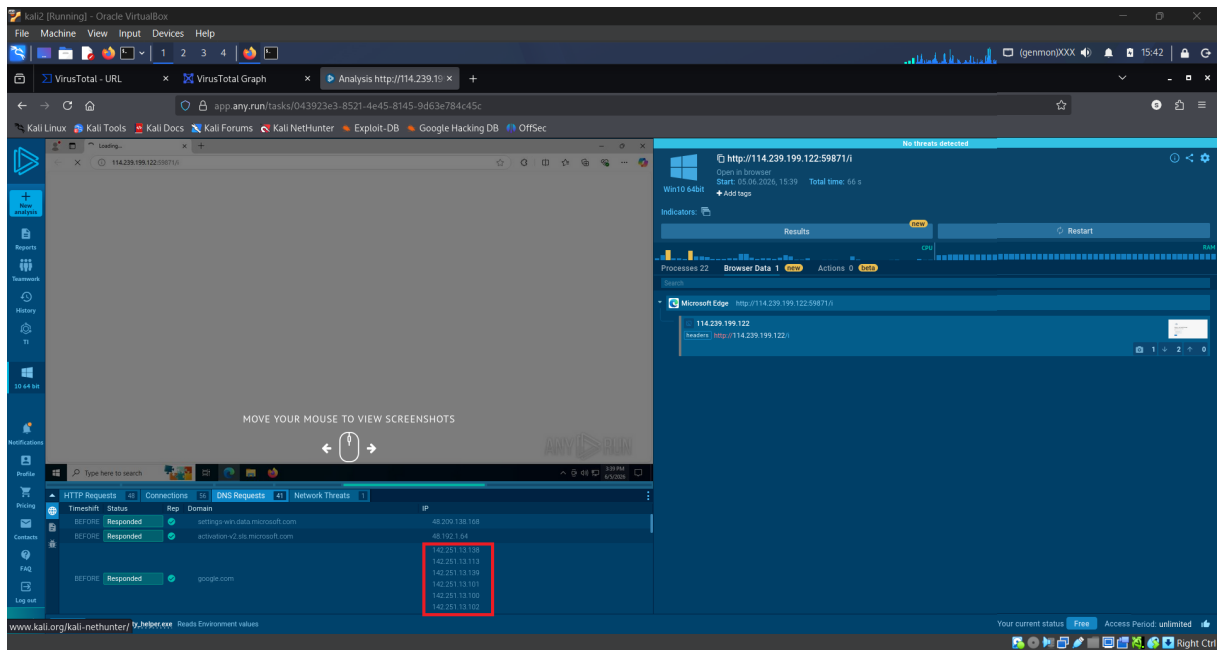


Figure 67: Link 41 — ANY.RUN DNS

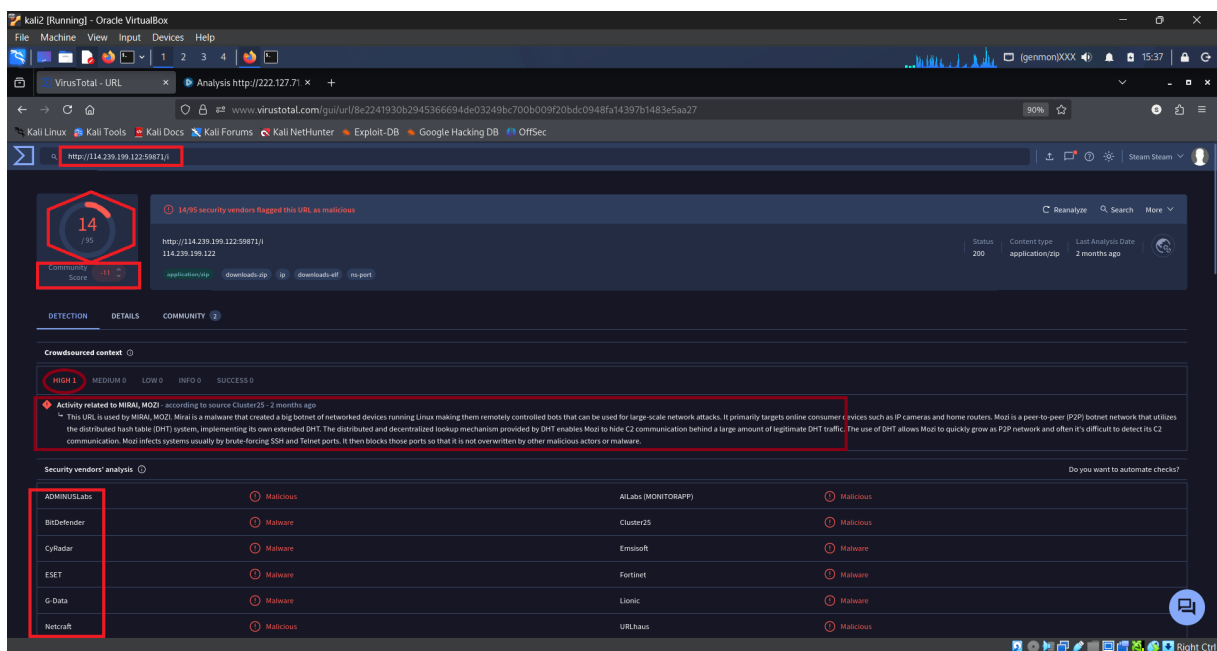


Figure 68: Link 41 — VirusTotal

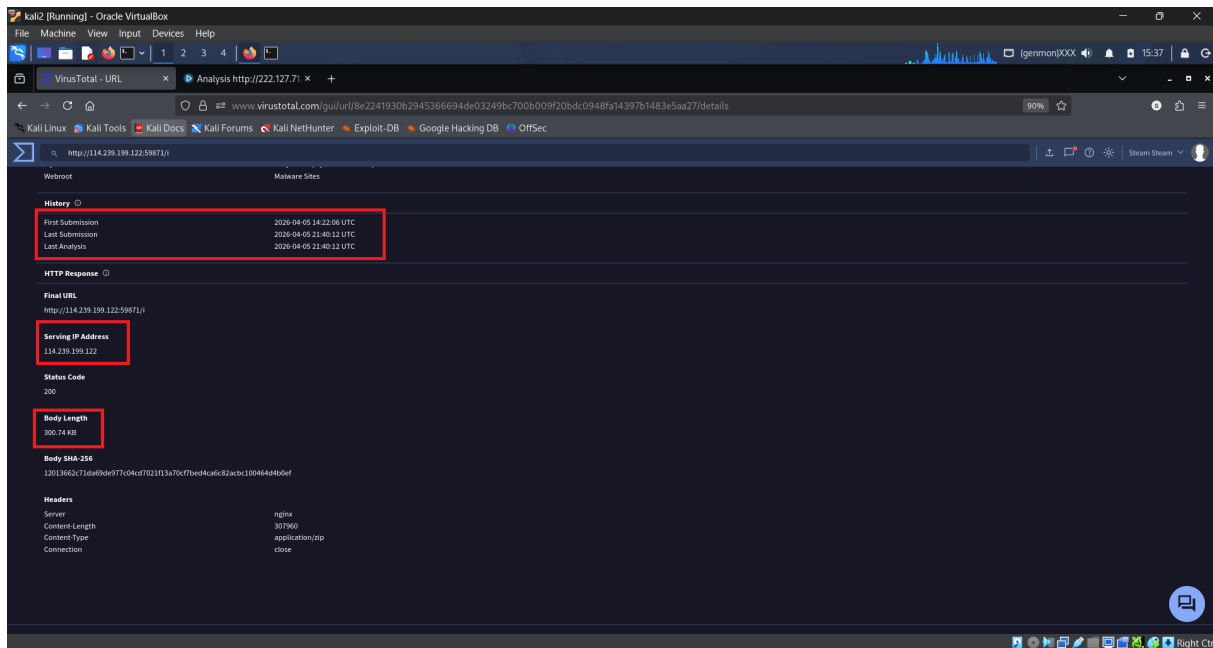


Figure 69: Link 41 — VirusTotal details

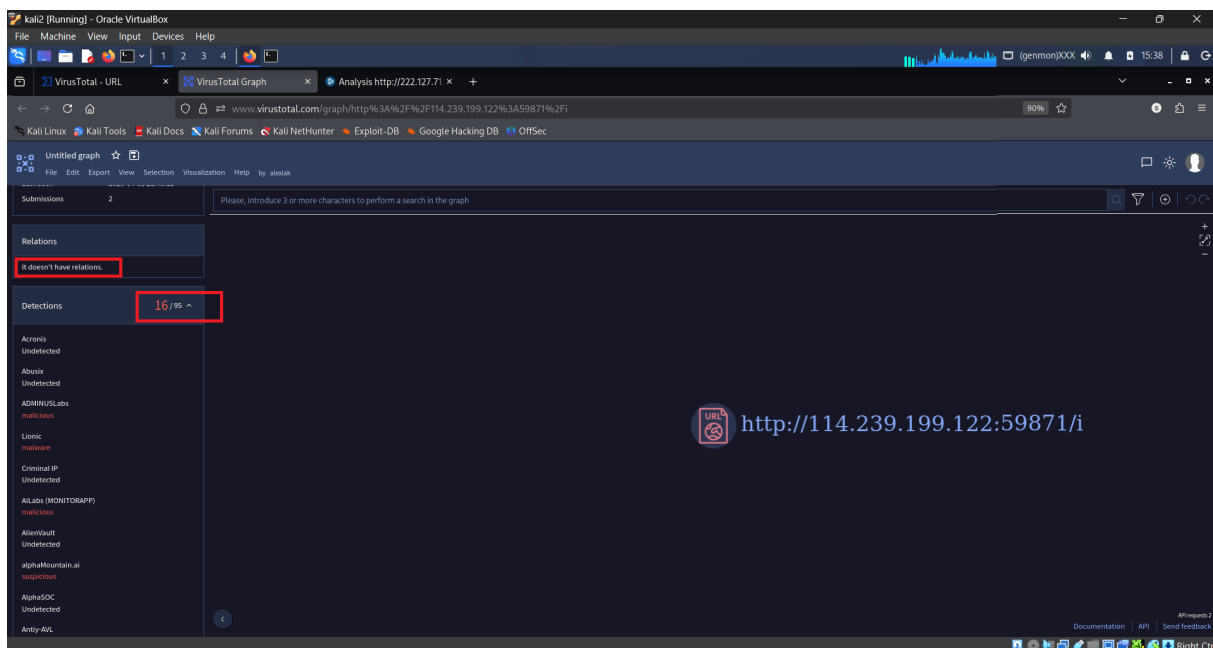


Figure 70: Link 41 — VirusTotal Graph

6.4.5 Link 69 — 110.39.239.111:52560/i

VirusTotal **17/95** with a community score of **-11** (ADMINUSLabs, alphaMountain, Cluster25, CRDF, Dr.Web and GreyNoise *Malicious*, BitDefender, CyRadar, Emsisoft, ESET, Fortinet and G-Data *Malware*).

At capture the endpoint returned **HTTP 200** with Content-Type: `image/png`, a small **4.65 KB** body and HTML meta tags, lightweight loader/landing response on `/i` rather than the full ELF, showing the bot rotates what it serves.

In ANY.RUN browser timed out (`ERR_CONNECTION_TIMED_OUT`) with one network threat. First/last VT submission 2026-04-05; VT Graph 19/95, no relations.

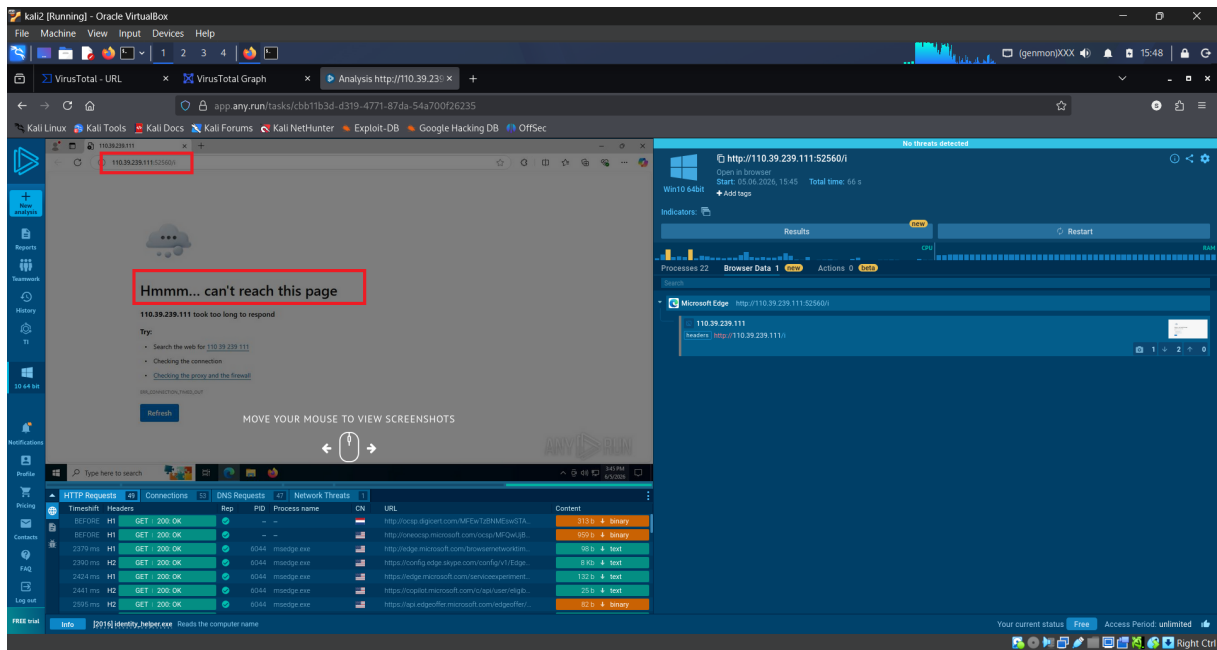


Figure 71: Link 69 — ANY.RUN

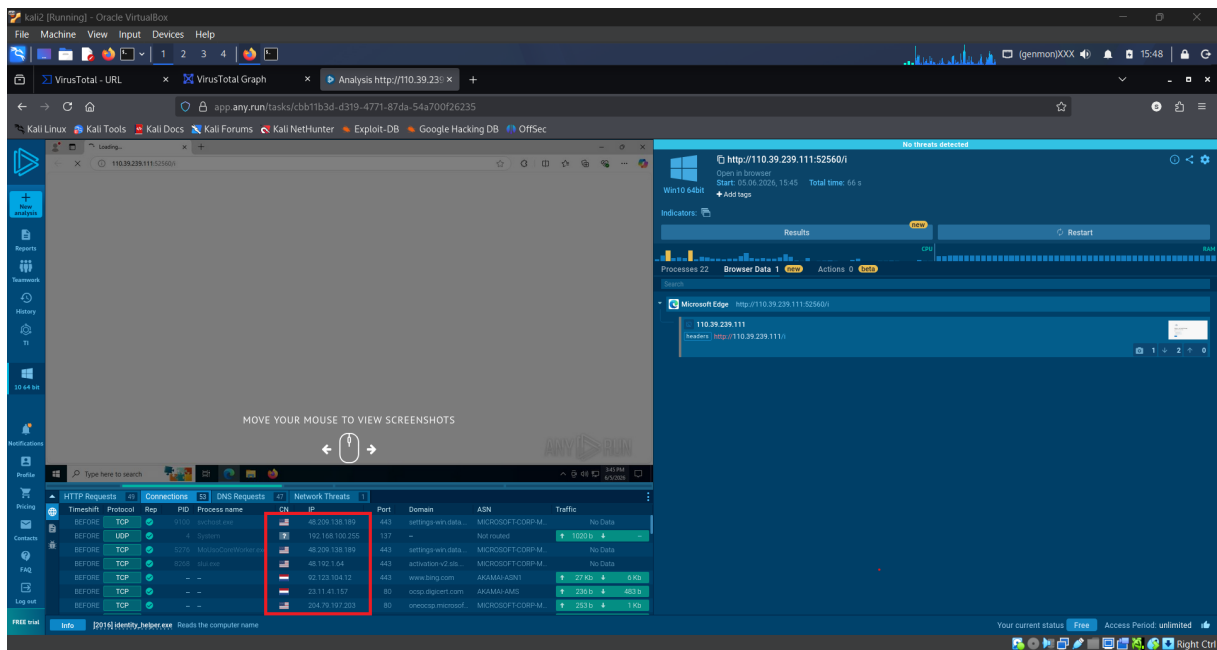
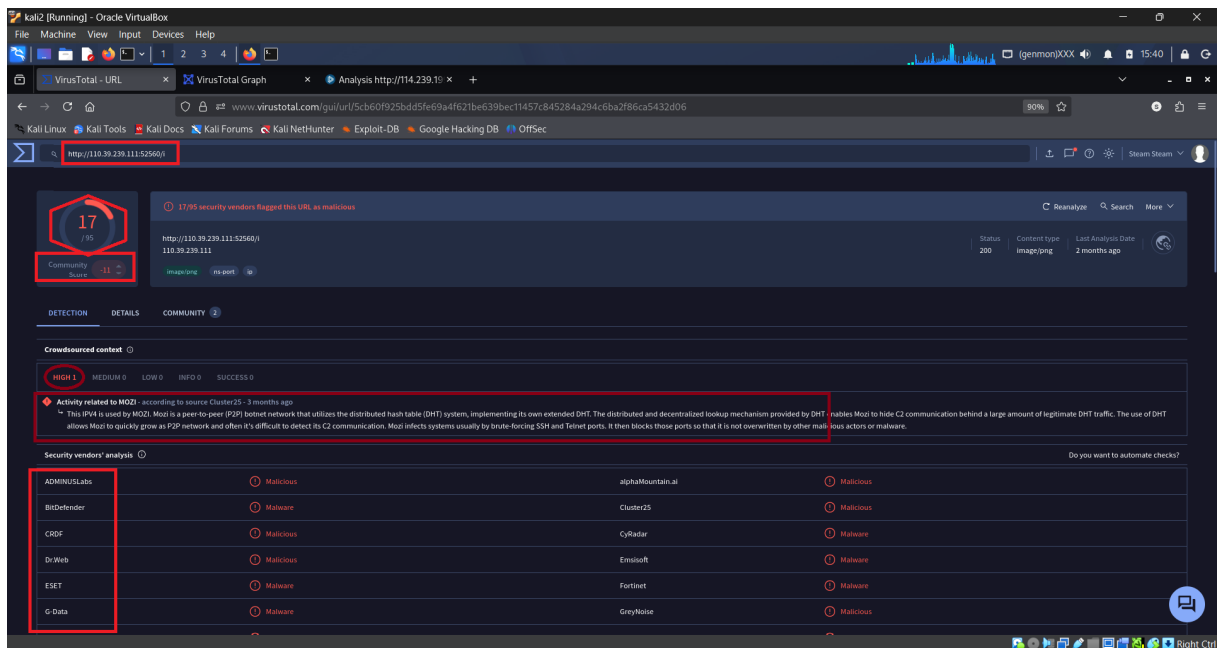
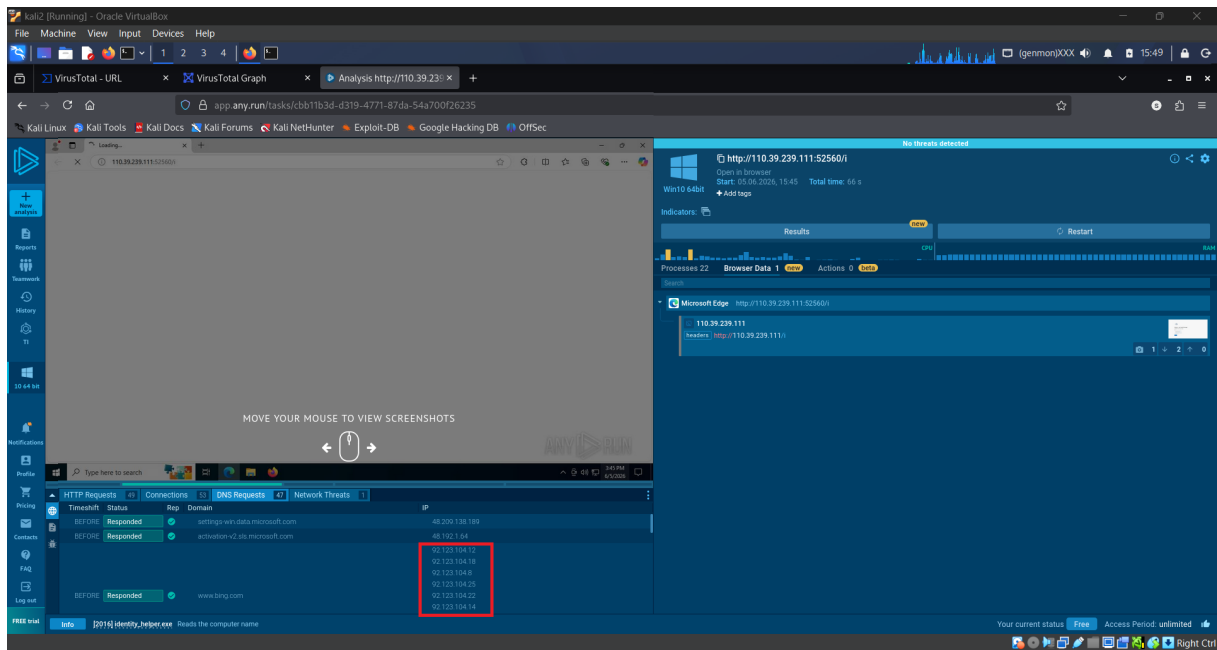


Figure 72: Link 69 — ANY.RUN connections



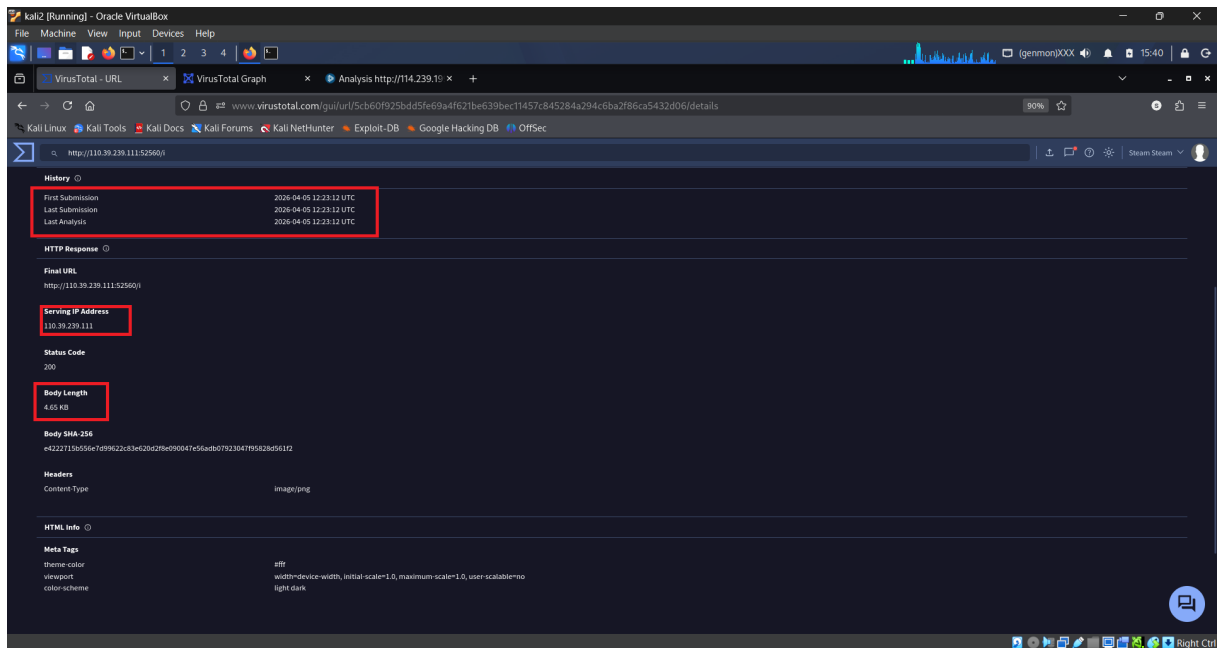


Figure 75: Link 69 — VirusTotal details

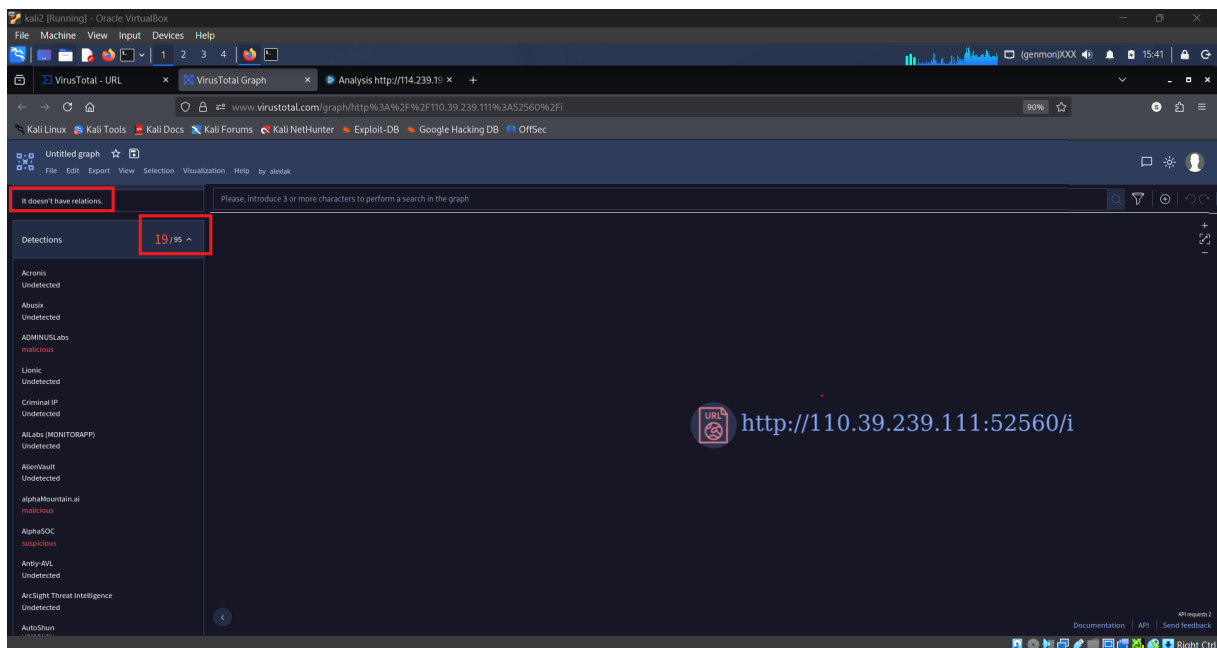


Figure 76: Link 69 — VirusTotal Graph

6.4.6 Key Takeaways — Category C

- **Architecture-specific delivery** /main_mps1 and /mps1 are the MIPS-little-endian builds, the same hosts serve arm/arm5/arm7/sh4/ppc/x86_64 variants, cross-compiled for IoT CPUs.
- **Invisible to URL/DNS controls** raw IPs, plain HTTP, no TLS, and a non-standard port (56631) serving an application/zip ELF, this must be caught at the firewall / IDS, not by domain reputation.
- **Intermittent availability** the binary hosts time out between campaigns, so blocking must target the IP / port / path patterns rather than relying on live reach-ability.

7 Techniques Identified

7.1 Delivery & Evasion Techniques

Technique	Seen?	Evidence
URL obfuscation	Yes	Typosquats / homoglyphs (<code>trzr-wallt</code> , <code>uphuuld-walet</code>); random numeric sub-labels
URL shortening	Upstream	Campaign delivered via a shortened link in e-mail; final landings shown here
Domain shadowing	Partial	Free-subdomain abuse on <code>pages.dev/netlify.app</code> rather than classic DNS-record hijack
Cloud-service abuse	Yes	Netlify, Cloudflare Pages, <code>.shop/.digital</code> throwaway domains
HTTPS abuse	Yes	Phishing/drainer pages use auto-issued TLS to fake legitimacy; botnet (Category C) stays on plain HTTP

7.2 MITRE ATT&CK Mapping

ID	Technique	Cluster
T1566.002	Phishing: Spearphishing Link	A, B
T1656	Impersonation (brand / vendor spoofing)	A, B
T1583.001	Acquire Infrastructure: Domains (typosquatting)	B
T1583.006	Acquire Infrastructure: Web Services (Netlify, CF Pages)	A, B
T1608.001/.004	Stage Capabilities: Upload Malware / Drive-by Target	A, C
T1204.001	User Execution: Malicious Link	A, B
T1110.001	Brute Force: Password Guessing (SSH/Telnet spread)	C
T1105	Ingress Tool Transfer (wget/curl of bin.sh + binaries)	C
T1059.004	Command & Scripting Interpreter: Unix Shell	C
T1571	Non-Standard Port (high ephemeral C2 ports)	C
T1027	Obfuscated/Packed Files (UPX, stripped ELF)	C
T1498/T1499	Network / Endpoint Denial of Service (botnet goal)	C

8 Risk Assessment

Question	Finding
Phishing / malware / exploit kit?	A = phishing; B = crypto drainers; C = malware delivery.
Credential theft possible?	Yes — C1 harvests personal/financial data; C2 harvests wallet recovery phrases.
Are users at risk?	Yes. Any user who opened the e-mail link could reach a live phishing page, any exposed Linux/IoT device could be conscripted by C3.
Overall severity	HIGH / CRITICAL

9 Indicators of Compromise (IOC)

9.1 Malicious Domains (C1 + C2)

#	Domain (defanged)	Cluster
1	informacoes-limpabrasil2026[.]netlify[.]app	A
2	walletedinar[.]com	A
3	Skillwicked[.]cc	A
4	flintbrowser[.]pages[.]dev	A
5	cadastrolimpaa[.]shop	A
6	livre-acesso feirao[.]shop	A
7	051516xx[.]vectorprospera[.]digital	A
8	trzr-wallt-io[.]pages[.]dev	B
9	us-en-io-download[.]pages[.]dev	B
10	en-uphuuld-walet-us[.]pages[.]dev	B

9.2 Malicious URLs — Phishing & Crypto (C1 + C2)

#	URL (defanged)
1	hxxps://informacoes-limpabrasil2026[.]netlify[.]app/
2	hxxps://walletedinar[.]com/
3	hxxps://Skillwicked[.]cc/
4	hxxp://walletedinar[.]com/
11	hxxps://flintbrowser[.]pages[.]dev/
12	hxxps://cadastrolimpaa[.]shop/
13	hxxps://livre-acesso feirao[.]shop/inicio/
106	hxxps://051516xx[.]vectorprospera[.]digital/?=check[.][.][.]
5	hxxps://trzr-wallt-io[.]pages[.]dev/
6	hxxp://trzr-wallt-io[.]pages[.]dev

#	URL (defanged)
7	hxxps://us-en-io-download[.]pages[.]dev/
8	hxxp://us-en-io-download[.]pages[.]dev
9	hxxps://en-uphuuld-walet-us[.]pages[.]dev/
10	hxxp://en-uphuuld-walet-us[.]pages[.]dev

9.3 Botnet Loader / Infected-Bot Hosts (C3)

Table 3: IoT botnet loader / bot hosts serving /i and /bin.sh.

#	IP (defanged)	Port(s)	Endpoints
1	60[.]23[.]236[.]125	35619	/i
2	110[.]37[.]111[.]110	37136	/bin.sh /i
3	39[.]74[.]83[.]3	52343	/i
4	114[.]239[.]199[.]122	59871	/bin.sh /i
5	113[.]239[.]71[.]103	55329	/bin.sh
6	182[.]117[.]8[.]232	37380	/bin.sh /i
7	42[.]230[.]191[.]97	49822	/bin.sh
8	110[.]36[.]26[.]86	49018	/bin.sh /i
9	175[.]175[.]164[.]88	46771	/bin.sh /i
10	110[.]39[.]228[.]163	39775	/bin.sh /i
11	110[.]37[.]122[.]34	49966	/i
12	105[.]186[.]248[.]234	33035	/i
13	222[.]127[.]71[.]141	56631	/bin.sh /i
14	124[.]131[.]158[.]186	57890	/bin.sh /i
15	170[.]244[.]180[.]22	60885	/bin.sh
16	112[.]238[.]156[.]226	44295	/i
17	182[.]117[.]108[.]122	45751	/bin.sh /i
18	221[.]15[.]5[.]7	34979	/bin.sh /i
19	222[.]134[.]173[.]114	39695	/i
20	110[.]39[.]239[.]111	52560	/bin.sh /i
21	106[.]59[.]114[.]57	37837	/bin.sh /i
22	119[.]178[.]250[.]160	57977	/bin.sh /i
23	60[.]19[.]219[.]238	52577	/bin.sh /i
24	110[.]37[.]43[.]127	53103	/bin.sh /i
25	115[.]63[.]33[.]161	39490	/bin.sh /i
26	175[.]151[.]116[.]102	46020	/i
27	124[.]89[.]121[.]42	61335	/i
28	222[.]219[.]79[.]204	54149	/bin.sh
29	60[.]23[.]77[.]120	45032	/bin.sh /i

Table 3: IoT botnet loader / bot hosts serving /i and /bin.sh.

#	IP (defanged)	Port(s)	Endpoints
30	125[.]43[.]24[.]160	38148	/bin.sh /i
31	123[.]235[.]72[.]116	57923	/i
32	182[.]116[.]93[.]70	55118	/bin.sh /i
33	46[.]180[.]158[.]120	2111	/bin.sh /i
34	42[.]232[.]176[.]236	39468	/bin.sh /i
35	125[.]47[.]208[.]112	45672	/bin.sh /i
36	59[.]176[.]71[.]127	46152	/bin.sh /i
37	115[.]48[.]162[.]62	50466	/bin.sh
38	115[.]51[.]92[.]201	54137	/i
39	182[.]112[.]7[.]86	49191	/bin.sh
40	42[.]239[.]109[.]61	48558	/i
41	182[.]114[.]33[.]61	42919	/bin.sh /i
42	45[.]184[.]19[.]72	35528	/bin.sh /i
43	222[.]139[.]204[.]216	54088	/bin.sh /i
44	36[.]70[.]193[.]241	55890	/i
45	222[.]140[.]187[.]63	46533	/i
46	219[.]155[.]211[.]115	45753	/i
47	112[.]239[.]96[.]184	39644	/i

10 Recommendations

1. **Block & sinkhole** every IOC in Section 9 across the secure e-mail gateway, web proxy, DNS resolver and perimeter firewall.
2. **Hunt retroactively** in proxy/DNS/firewall logs for any prior connection to these hosts, isolate and re-image any device that contacted a Category C loader.
3. **User awareness** targeted phishing briefing covering brand typosquats, free-hosting padlocks ($\neq$ safe).
4. **Harden IoT/Linux** disable Telnet, enforce strong/keys-only SSH, change defaults, segment IoT VLANs, and rate-limit egress to block bot beaconing.
5. **Detection content** proxy/IDS rules for /bin.sh, /i, /main_<arch> and /bins/<arch> fetches over HTTP to raw IPs on non-standard ports.

11 Knowledge Graph & Attack Workflow

To make the methodology reproducible and the relationships between indicators explicit, the investigation was captured both as a **repeatable analysis workflow** and as a **threat knowledge graph**. The workflow records *how* every one of the 113 indicators was processed, the knowledge graph records *what* those indicators turned out to be and how they connect.

Diagram 1 Five-Phase Investigation Methodology

Applied to every one of the 113 indicators harvested from the e-mail campaign.

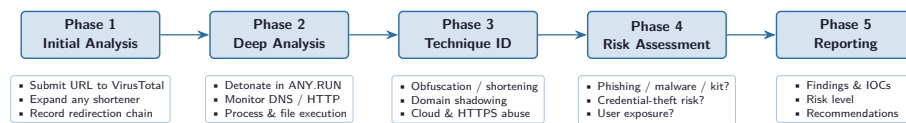


Figure 77: Attack workflow

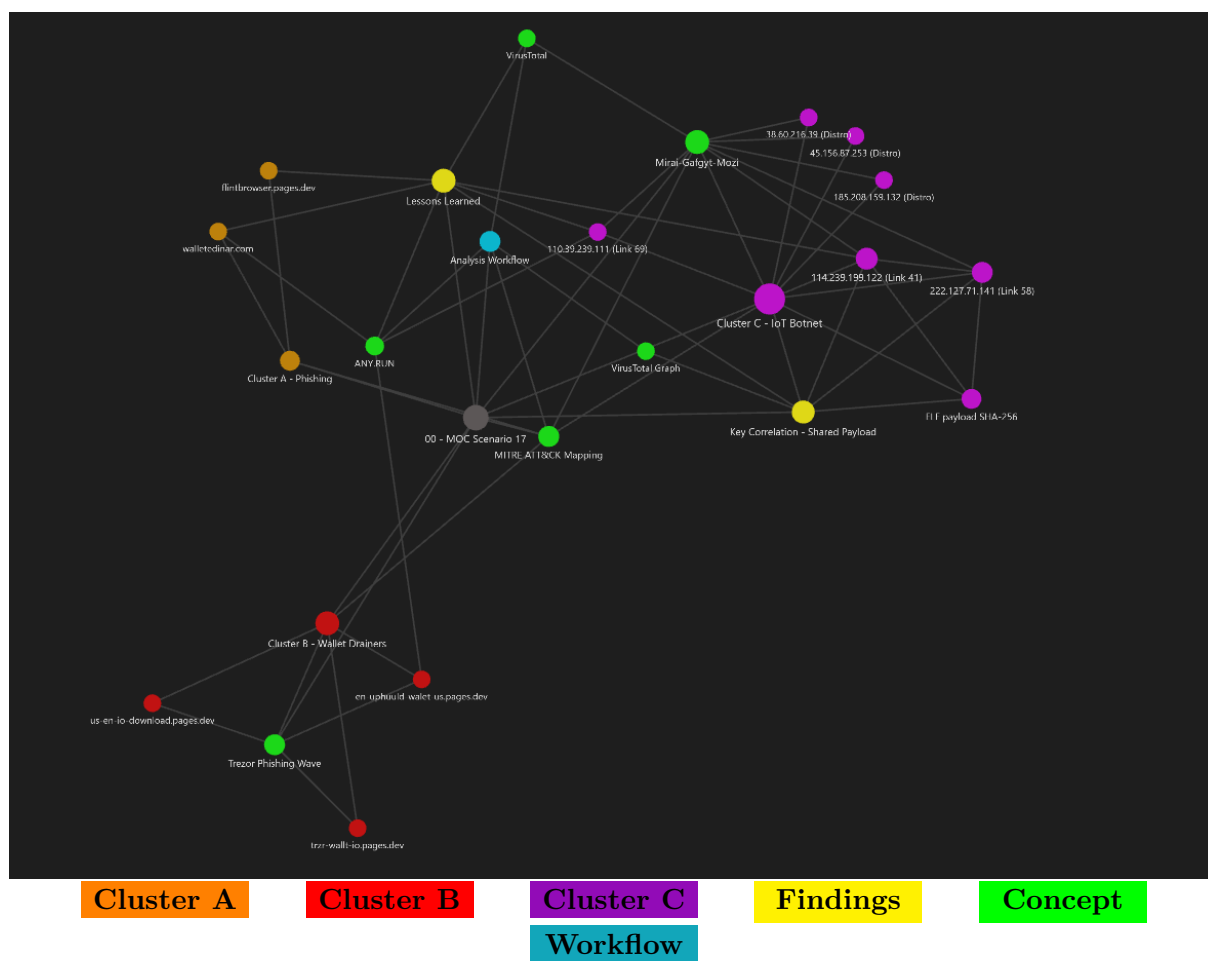


Figure 78: Obsidian knowledge graph (KG)

12 Lessons Learned

- **Low detection scores don't mean safe** — Some malicious links had 1/95 on VirusTotal. Treat fresh infrastructure as “unproven,” not “clean.”
- **Watch behavior, not just names** — A site named like a crypto drainer turned out to be a phishing clone after dynamic analysis.
- **Sandbox timeout != dead host** — Some loaders timed out in browser but returned live binaries (HTTP 200). Check VT HTTP response panel.
- **Match patterns, not just lists** — Two different IPs served identical 300.74 KB ELF files. Spotting size matches reveals hidden relationships.
- **Crowdsourced notes are gold** — One-line VT notes gave better threat attribution (MIRAI/MOZI, Telnet brute-force) than raw engine scores.
- **Process discipline matters** — Overwritten screenshots caused rework. Use strict naming (1<N>-anyrun-1) and defang IOCs (hxxp, [.]).
- **Next time:** Hash the actual ELF from live loaders, automate bulk VT lookups, and capture WHOIS/GeoIP per bot IP.

13 Conclusion

This investigation triaged **113 URLs** delivered by a single e-mail campaign and resolved them into **three coordinated but distinct threat clusters**. Static reputation analysis (VirusTotal) combined with interactive detonation (ANY.RUN) **confirmed**: an authority and brand-spoofing **phishing** set abusing free cloud hosting with auto-issued TLS (T1566.002, T1656, T1583.006), a Trezor/Uphold **crypto wallet-drainer** set built on typosquatted ***.pages.dev** domains that harvest the victim's recovery (seed) phrase (T1583.001, T1204.001) an **irreversible** loss, and a large **Mirai/Gafgyt/Mozi IoT botnet** delivery network serving multi-architecture ELF payloads over plain HTTP (T1110.001, T1105, T1059.004, T1571, T1027).

13.1 Report Objectives Status

- ✓ **All 113 indicators triaged & clustered** into A (phishing, 8), B (wallet drainers, 6) and C (IoT botnet, 99).
- ✓ **Static & dynamic analysis completed**: VirusTotal / VirusTotal Graph reputation plus ANY.RUN detonation of every representative.
- ✓ **Phishing cluster characterised**: cloud-hosted, TLS-backed regional lures.
- ✓ **IoT botnet network mapped**: 3 distribution servers, multi-arch ELF, ~47 loader hosts, Cluster25 attribution to Mirai/Mozi.
- ✓ **ATT&CK mapped & techniques identified**: delivery/evasion checklist + full technique-to-cluster matrix.
- ✓ **IOCs consolidated & defanged**: domains, IPs, URLs and hashes ready for gateway / proxy / DNS / firewall blocking.
- ✓ **Knowledge graph & workflow delivered**: reproducible five-phase pipeline, triage decision flow and an interactive threat knowledge graph.

★ Thank You for Reading! ★